



AICPA Trust Services Criteria

VMware Cloud Foundation 9.1

June 23, 2026

Table of Contents

Disclaimer.....3

Version.....4

Introduction.....4

Additional Resources4

Third Party Identifiers and Mappings4

Coverage Levels4

Controls..... 6

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260623-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations working toward a SOC 2 examination against the AICPA Trust Services Criteria. The Trust Services Criteria, published by the AICPA, are the control criteria used in SOC 2 examinations. They are organized into common criteria covering the control environment, communication and information, risk assessment, monitoring, and control activities, together with additional criteria for availability, confidentiality, processing integrity, and the privacy of information. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for undergoing a SOC 2 examination and meeting the criteria remains with the service organization.

<https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022>

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Additional Resources

This is one of a library of companion guides that map VMware Cloud Foundation and its advanced services to security and compliance frameworks. For each framework, the guide is published as a spreadsheet, a CSV data file, a Markdown document, and a PDF, together with a Security Configuration Guide crosswalk that identifies the VCF technical hardening settings relevant to that framework. The companion guide library, the VMware Cloud Foundation Security Configuration Guide, and related security documentation, sample scripts, and Q&A are available at <https://brcm.tech/vcf-security>.

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.

- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control A1.1

The entity maintains, monitors, and evaluates current processing capacity and use of system components (infrastructure, data, and software) to manage capacity demand and to enable the implementation of additional capacity to help meet its objectives.

SCF Controls: CAP-01, CAP-02, CAP-03, CAP-04

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in capacity and performance management through VCF Operations, which delivers capabilities organized around three functional areas: assess, optimize, and plan. These capabilities allow administrators to evaluate whether physical capacity is sufficient to meet current or forecasted demand, balance supply against consumption, and manage production capacity as organizational requirements change.

The assess capability evaluates current and projected resource utilization across compute, storage, and networking. VCF Operations includes a capacity analytics engine that analyzes historical resource utilization data and generates projected utilization metrics. The engine computes and publishes metrics in the Capacity Analytics Generated group, including a capacityRemainingPercentage that tracks the most constrained resource relative to usable capacity. Capacity dashboards display key indicators including time remaining before capacity is projected to run out, the amount of remaining capacity, the number of virtual machines that can fit in remaining capacity, and reclaimable resources that can increase available capacity. The Capacity Summary dashboard provides details on available resources and what is currently running on those resources. The recommended approach for usable capacity is to maintain a green state by calculating total capacity minus high availability reservation for the time remaining.

The optimize capability helps administrators manage resources within the virtualized infrastructure to maintain performance and maximize resource utilization while keeping capacity within acceptable limits. The Workload Optimization screen lets administrators optimize workload placement based on policy settings, accessible via the Workload Placement tab under Capacity. Capacity Optimization allows forecasting the impact of adding workloads by modeling various scenarios to determine whether desired workloads can fit in targeted data centers. Administrators configure capacity policy settings by defining requirements and tolerances for their environment, such as CPU utilization thresholds, and then configure object groups and policies accordingly. At the vSphere layer, Distributed Resource Scheduler (DRS) continuously compares cluster and host-level metrics against an ideal resource usage given resource pool attributes, current demand, and a configurable imbalance target, automatically migrating virtual machines to maintain load balance. vSphere also applies admission control when creating or modifying resource pools, rejecting reservation requests that would exceed available capacity to prevent over-commitment of guaranteed resource allocations.

The plan capability uses historical resource utilization data and real-time predictive projections to forecast future capacity needs. The capacity engine uses an industry-standard statistical analysis model of demand behavior for its projections. Infrastructure Planning shows time remaining and the impact on CPU and memory when capacity changes, including graphical representations of whether removing capacity decreases the time remaining before resources run out. Committed scenarios allow capacity to be reserved so that operations teams do not perform ad hoc resource increases on workloads while a capacity manager is engaged in resource planning for new projects.

At the storage layer, vSAN provides storage-specific capacity and performance metrics. VCF Operations collects disk I/O and disk space metrics to monitor vSAN disk group performance, including read-cached hit rate, write-buffer free percentage, cache disk destage rate, congestion metrics, and outstanding I/O statistics. vSAN displays deduplication and compression savings information when these space efficiency features are enabled. vSAN also supports auto-policy management to optimize capacity utilization based on cluster size and type. The vSAN Performance Dashboard in VCF Operations provides a consolidated view of storage performance alongside compute and network resources.

The Consumption layer within VCF extends these capacity management capabilities to Kubernetes workloads running on VMware Kubernetes Service (VKS) and the vSphere Supervisor. At the namespace level, vSphere Namespace resource capacity can be configured with explicit limits on CPU, memory, storage, and storage policy consumption. When a vSphere Namespace is configured, a resource pool is created on VMware vCenter, and administrators can apply capacity and usage quotas to bound what workloads in that namespace may consume; by default, this resource pool is created without capacity or usage quotas, requiring administrators to configure limits explicitly. The StoragePolicyQuota resource allows per-namespace limits on storage capacity allocated under a given storage policy, specified via the spec.limit parameter. VKS Cluster Management quota policies provide an additional boundary at the cluster management layer, with preconfigured templates (small, medium, and large) that define common limits on CPU and memory requests, or a custom template that allows specification of CPU and memory limits and request quantities for various resource types.

Within Kubernetes namespaces, ResourceQuota objects control resource allocation across pods and containers, allowing administrators to set per-namespace quotas on CPU, memory, and storage. ResourceQuota configuration can be enabled to protect system-critical priority classes, including system-node-critical and system-cluster-critical, from resource contention. LimitRange resources work alongside ResourceQuota to set default and maximum resource requests and limits at the pod level, reducing resource exhaustion from workloads that do not specify their own constraints; cluster administrators can use LimitRange to set per-claim storage request ceilings and ResourceQuota to cap total namespace storage consumption. Kubernetes pods can be configured with resource requests and limits at both pod-level and container-level, providing fine-grained control over CPU and memory allocation.

At the node level, Kubernetes nodes report capacity and allocatable resources including CPU, memory, ephemeral storage, hugepages, and pod count limits. The kubelet systemReserved configuration reserves CPU cores and memory for system processes, protecting node stability from workload interference. For workloads requiring stronger latency and performance guarantees, kubelet resource management policies can be configured. Node overprovisioning capacity reservation is configured by defining resource requests and limits for placeholder pods in a Deployment manifest, with total reserved resources calculated as the product of replica count and per-pod resource quantities, keeping headroom available for newly scheduled workloads.

The Kubernetes kube-scheduler manages availability, performance, and capacity through scheduler policies and profiles. Kube-scheduler metrics can be used to build capacity planning dashboards, assess current or historical scheduling limits, and identify workloads that cannot be scheduled due to resource shortfalls. Kubernetes Dynamic Resource Allocation allows consumable device capacity to be requested via ResourceClaimTemplate objects, with requestPolicy constraints controlling how those capacities are consumed across allocations; device capacity can define a default request policy value and valid range with step increments. The Supervisor Monitor tab under vSAN provides a Capacity view for tracking how much capacity stateful service objects are consuming.

VM classes in VKS support two reservation types: guaranteed, which fully reserves configured resources so that requests equal limits, and best effort, which does not hold resources in reserve. The choice of VM class reservation type affects how compute capacity is consumed under varying load conditions and is relevant to capacity planning for VM-based workloads on the platform. Kubernetes production cluster guidance recommends maintaining a capacity expansion plan based on expected pod and container counts, with additional capacity provisioned to allow critical workloads to reschedule in the event of node failures.

VMware Private AI Services (PAIS) provides several mechanisms that support capacity management for AI workloads. These mechanisms operate at multiple layers: organization quotas, region quotas, zone configurations, VM class and storage class reservations, infrastructure policies, and observability for capacity trending.

The foundation of capacity management in PAIS is the organization quota system. Organization region quotas in VCF Automation accept only finite CPU and memory limits and reservations; unlimited resources cannot be assigned. CPU and memory reservations cannot be over-provisioned, though CPU and memory limits and storage can be. VCF Automation creates a resource pool for the namespace in the clusters that correspond to the specified zones, applying the reservation and limit values to that resource pool so the platform enforces the quota at runtime.

Within organizations, capacity is allocated through region and zone quotas. Provider administrators use the VCF Automation Provider Management portal to configure a region and assign region quotas, with quotas based on the zones selected for one or multiple supervisors. For each zone, CPU and memory limits and reservations are specified along with reserved or non-reserved VM classes and storage classes; storage limits per storage class are configurable. Region quotas can include explicit GPU resource counts by profile (for example, H100 and L40 vGPU profiles assigned per zone). The PAIS SupervisorNamespaceClassConfig captures these per-zone CPU limits, CPU reservations, memory limits, and memory reservations as a managed configuration object. When an organization quota spans multiple supervisors in the same region, a separate region quota is required for each supervisor, so administrators account for each physical boundary in their capacity plan.

VM class reservations provide another layer of capacity control designed specifically for AI workloads. Zone capacity is configured through reserved VM class instances, where each reservation specifies a VM class name and a count of reserved instances in the zone. VM class capacity is reserved in Supervisor zones to support resource availability for the workloads that run there. For workloads requiring GPU resources, VM classes with GPU reservations require capacity configuration using the `dcli` command, which sets reserved VM class instances with a count parameter per zone. Guaranteed VM classes are not permitted in a region quota with zero reservation, and guaranteed VM classes are not allowed in a quota unless CPU and memory reservations are provided to all zones, so resource availability commitments are tied to explicit capacity configuration. GPU-enabled workload domains receive license capacity allocation, while the management domain does not.

When AI catalog items are created in VCF Automation through the Private AI Services quickstart, an infrastructure policy is selected to define the quality and quantity of resources that the PAIS DSM database can consume from vSphere clusters; the policy also determines which storage policies and VM classes are available. A default storage policy can be selected to define storage placement and resources for the database. AI Kubernetes cluster deployments require selection of a storage class that defines storage placement and resources for the virtual machines, and the PAIS VKS control plane configuration requires specification of a VM class and storage class to represent the resources allocated to control plane nodes. PAIS model endpoints similarly use storage class policies that describe storage requirements and classes of service for the VMs created for the Kubernetes cluster nodes running the model. The containerd storage volume used by PAIS workloads is sized at 100 GiB and mounted at `/var/lib/containerd`, giving administrators a fixed local-image footprint to plan against.

PAIS also supports observability for capacity planning. A Prometheus server is deployed in the Private AI Services namespace with its own metrics database backed by a Persistent Volume; storage size for that database is inferred from the metrics retention property in the `PAISConfiguration` custom resource, allowing administrators to plan monitoring infrastructure capacity alongside AI workload capacity. The VCF Consumption CLI connects to the Supervisor endpoint and streams metrics from the PAIS controller pod, and PAIS metrics can be visualized in Grafana for monitoring and troubleshooting, including LLM completion API response times, inference engine tokens-per-second generation rate, and GPU compute and memory utilization. These signals feed the organizational capacity planning process that the control evaluates.

VMware vDefend (Contributes)

VMware vDefend includes capacity and performance management capabilities specific to its security processing infrastructure through the Security Services Platform (SSP).

The SSP provides a Platform Host Capacity view that gives administrators visibility into resource utilization across the security processing cluster. This view tracks cluster data, unexported flow data, total flows, prioritized applications and groups, the average number of flows every five minutes, and the data collection status per cluster. The SSP also displays a time-series graph showing flow distribution over an hour and generates a warning notification when unexported flows affect the prioritized collection of applications and groups. SSP monitors which hosts are operating within capacity and which are capped when flows on the host exceed capacity. The system dashboard provides flow processing capacity analysis to display cluster sizing requirements.

When approaching capacity limits, vDefend provides actionable guidance: administrators can monitor specific metrics, add worker nodes, disable flow collection on certain hosts or clusters, or rebalance virtual machines across transport nodes to manage system performance. Resource reservation is enabled by default for SSP deployments, reserving the required CPU

and memory at the resource pool level. The documentation advises against oversubscribing host CPU and memory, and recommends adjusting virtual machine allocations or migrating virtual machines when resources are insufficient.

SSP includes tools to manage license pool consumption for capacity reservations in mission-critical production sites and to set hard limits for development environments, supporting capacity planning across different environment tiers.

Host Transport Node Metrics monitoring helps detect capacity constraints within the Distributed Firewall processing layer, allowing administrators to optimize resource allocation and verify that security enforcement does not affect workload performance. DFW Resource Utilization Metrics provide a dedicated view for capacity planning and performance troubleshooting within the Distributed Firewall. For IDS/IPS deployments, administrators can assess current CPU and memory load on ESX hosts to identify hosts with unused capacity that can accommodate the IDPS engine without performance degradation.

Broader infrastructure capacity planning across compute, storage, and networking is handled by VCF Operations, which provides the full assess, optimize, and plan lifecycle for the overall VCF environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to capacity planning with DR-specific guidance and tooling that address network bandwidth, compute, and storage dimensions for contingency operations.

vSphere Replication requires storage and network bandwidth assessment before deployment. Bandwidth requirements are calculated by measuring the peak data change rate in each Recovery Point Objective (RPO) period against the available link speed. Using peak data change rate rather than average accounts for burst periods and helps avoid RPO violations during periods of high activity. When network-based storage within a single vCenter instance shares the network for replication traffic, administrators should plan for increased bandwidth requirements across multiple traffic levels.

PNR supports recovery site capacity planning through compute resource mappings and resource pool configuration. Reservations, affinity rules, and limits for recovered virtual machines can be set by configuring resource pools on the recovery site and establishing resource pool mappings accordingly. The number of concurrent power-on and power-off operations can be limited to avoid timeouts in large environments. PNR Server supports a maximum of 10 concurrently running recovery plans, an operational boundary administrators should account for when planning DR coverage across multiple workloads.

PNR includes unified monitoring dashboards within VCF Operations that provide capacity-relevant visibility. The dashboards display a historical chart of bandwidth consumed by replication tasks relative to available capacity, a protected capacity timeline for cloud file systems with selectable time segments, and the change in capacity consumption over time for each protection group based on snapshot generation. PNR also monitors resource consumption on the PNR Server host and raises configurable alarms when resource thresholds are reached, providing advance warning of capacity constraints before they affect contingency operations.

For organizations using the VCF Automation integration, the PNR Proxy supports selection of a storage class that maps physical storage to a class policy and assigns storage classes with capacity limits to Organizations through region quotas. Multi-region deployment topologies can be designed to contain the impact of a disaster event to a single region.

Recovery plan testing validates that recovery site capacity is adequate before an actual contingency event. Testing exercises resource allocation on the recovery site so that capacity shortfalls can be identified and corrected before they affect actual recovery operations.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to capacity management through Infrastructure Policies, VM classes, IP pool sizing requirements, and per-database resource monitoring. These mechanisms give administrators the tools to plan for and constrain resource consumption within the database platform.

Infrastructure Policies are the primary capacity control mechanism in DSM. Administrators configure Infrastructure Policies to define and set limits on the specific compute, storage, and network resources that database workloads can consume from vSphere clusters. The DSM console displays all configured infrastructure policies, including their compute, storage, and

networking resource definitions and the VM classes each policy permits, giving administrators a view of the resource boundaries placed on DSM-managed workloads.

VM classes provide the per-database resource allocation unit. Each VM class specifies the vCPUs and memory in GiBs assigned to provisioned database VMs. When a user provisions a database, they select from the VM classes defined in the Infrastructure Policy. Administrators can adjust vCPU and memory allocations for database VMs at runtime without reprovisioning the database, supporting capacity adjustments as workload demands change. In DSM, enforcement of specific hardware allocations extends to SQL Server clusters to maintain their performance and stability within the containerized environment.

IP pool sizing is an explicit capacity planning requirement in DSM. IP pools must be sized to support the total number of database clusters expected to run simultaneously, plus reserve capacity for maintenance operations such as database engine upgrades and cluster topology changes, each of which temporarily requires additional IP addresses. DSM recommends monitoring IP pool utilization and expanding pool ranges or creating additional pools before capacity is reached. Global alerts are available to notify administrators when IP pool capacity approaches its limits.

The DSM Monitoring page provides visibility into database VM performance and resource consumption. Administrators can view metrics including Active Connections, Data Disk Usage, Write Throughput, Read Throughput, and Thread Resource Utilization for each database node VM. DSM also tracks system resource utilization metrics for CPU, memory, and data disk use through VCF Operations to help identify potential bottlenecks.

The Provider VM itself has sizing requirements tied to the volume of services it manages. Resources configured for a DSM Provider VM must be determined based on the type of environment in which it runs and the volume of services it manages, requiring upfront capacity planning when deploying the DSM management plane.

When DSM is deployed with VCF Automation as a provider, the Supervisor cluster must have sufficient CPU, memory, and storage resources available to schedule the DSM Consumption Operator pod. In this deployment model, infrastructure policies are created as cluster-scoped resources in the consumption cluster, and capacity planning for the Supervisor cluster is a prerequisite for successful scheduling.

Satisfying this control fully requires organizational processes for capacity forecasting and review that extend beyond what DSM provides at the platform level. DSM supplies the technical controls for constraining and monitoring database resource consumption; the broader organizational capacity management program, including demand forecasting, regular capacity reviews, and escalation processes, must be defined and operated by the organization.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides application-layer capacity management mechanisms across three areas: real-time capacity visibility through Pool and Service Engine metrics, proactive capacity management through elastic scaling and configurable resource controls, and multi-tenant capacity governance through the VCF organization-managed mode introduced in 9.1.

On the visibility side, the Pool Metrics system tracks both Estimated Capacity (the pool's maximum possible connections) and Available Capacity (currently open connections) at the pool level. Pool Metrics deliver specialized analytics and performance data representing the health and capacity of backend pool servers. At the individual server level, the `l4_server.avg_available_capacity` metric estimates connections-per-second capacity available for each server, calculated as the difference between maximum capacity and average load. The License Hub Platform Dashboard Resources tab visualizes hardware consumption overall and per controller and worker node, including System Load tracking of overall CPU demand against allocated vCPU capacity on a 15-minute average.

On the scaling and configuration side, each Service Engine has a maximum capacity for processing traffic measured in terms of traffic throughput or SSL transactions per second, which is a function of the SE VM size (number of vCPUs or memory), type of traffic, and deployment environment. CPU and memory reservations with limits set to unlimited are recommended for Service Engine virtual machines to achieve consistent and deterministic performance. Elastic HA N+M mode allows administrators to define a buffer expressed as M, an integer count of buffer Service Engines. When an N+M group is scaled

out to the maximum number of Service Engines, Avi Load Balancer permits additional virtual service placements into the spare capacity represented by M. Pool configuration allows setting the maximum number of connections per server on the Advanced tab to help prevent servers from being overloaded and to maintain optimal connection handling.

In the 9.1 Avi for VCF integration, organization-managed mode adds Service Unit quota enforcement per organization. Provider administrators can assign either a quota measured in Service Units or specific Service Engine Groups to organizations through the VCF Automation Provider Management portal, establishing resource governance to help prevent organizations from over-consuming shared Avi Load Balancer resources. In organization-managed mode, the provider or Load Balancer administrator manages resource assignments to enforce quotas and resource boundaries, and organization administrators can edit a Service Engine Group to scale the underlying performance (CPU and memory) or modify high-availability behaviors. Service Engine capacity provisioned on the Avi Controller is periodically reported, and the license quota reservation mechanism can be configured to keep a specific amount of capacity always available for a tier when a consumption ceiling is set.

These mechanisms give operations teams the metrics and controls needed to assess current application delivery capacity, monitor utilization trends, and adjust Service Engine group configuration or scale out in response to demand. The organizational processes for defining capacity plans, setting review cadences, acting on threshold alerts, and making scale decisions remain the responsibility of the organization.

Control A1.2

The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data backup processes, and recovery infrastructure to meet its objectives.

SCF Controls: BCD-01, BCD-08, BCD-08.1, BCD-08.2, BCD-09, BCD-09.1, BCD-09.2, BCD-09.3, BCD-10, BCD-10.1, BCD-11, BCD-11.1, BCD-11.2, BCD-11.3, BCD-11.4, BCD-11.6, BCD-12, BCD-12.1, BCD-12.2, DCH-01, DCH-01.2, IRO-01, IRO-02, PES-01, PES-07, PES-07.1, PES-07.2, PES-07.3, PES-07.4, PES-07.5, PES-08, PES-08.1, PES-08.2, PES-09, PES-09.1, PES-10, PES-11, PES-12, PES-13, PES-15, RSK-01, RSK-01.1, RSK-03, RSK-04, SEA-01.2, THR-09, THR-10

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in capabilities for secure recovery and reconstitution of infrastructure and workloads to a known state after a disruption, compromise, or failure. These capabilities span compute-level high availability, storage-level data protection, structured backup and restore workflows for management components, and disaster recovery across sites.

At the compute layer, vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts following a physical machine failure, restoring workloads to their prior operational state. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure with no data loss or downtime. Proactive HA supports maintenance mode as a remediation method, allowing the platform to respond to hardware degradation indicators. On TPM-equipped hosts, VMware ESX supports a Secure ESX Configuration recovery key that is required to restore the host configuration following TPM failure, TPM reset, motherboard replacement, or TPM device replacement; administrators can retrieve and store this key using ``esxcli system settings encryption recovery list`` and should keep it in a secure, off-host location.

At the storage layer, vSAN fault domains distribute data according to storage policy so that it remains available even when hardware failures occur. vSAN stretched clusters extend a cluster across two availability zones, providing site-level resiliency against the loss of an entire availability zone. When one site becomes unavailable, the surviving site continues operations, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSAN Data Protection uses native snapshots stored locally on a vSAN Express Storage Architecture (ESA) cluster to support point-in-time recovery from operational failures or ransomware attacks. Changed Block Tracking (CBT) tracks changes on disk sectors, enabling incremental backups through VADP-integrated partner backup solutions.

For large-scale disruptions, Application Disaster Recovery enables failover to a secondary site, with data replication so recovery options exist in the event of catastrophic failure. Disaster recovery can also be implemented for fleet-level components, covering the management plane itself. VCF documentation recommends planning and testing disaster recovery strategies regularly to validate that recovery time objectives (RTO) and recovery point objectives (RPO) can be met.

VCF includes structured backup and restore workflows for its management components. Administrators create a series of backup jobs that capture the state of related components, including VCF Operations, NSX Manager, and VMware vCenter, at a common point in time. VCF Operations backup is configured to take a backup on state change. VMware vCenter supports both file-based and image-based backup methods. The file-based restore procedure is a two-stage operation: stage 1 deploys a new vCenter appliance, and stage 2 transfers data from the backup location to that appliance; the restored appliance operates in non-HA mode, so vCenter High Availability must be reconfigured after recovery completes. Simultaneous backups of VCF Operations fleet management component nodes support restoring the nodes to a logically consistent state, so further integrity remediation is not required after a restore. The platform also recommends backing up the management domain vCenter and VCF Identity Broker appliance following any substantial modifications to the identity source configuration, such as a VCF SSO reset, to preserve a known-good recovery point.

For VMware vCenter specifically, the vCenter Management API provides a unified restore process that handles multiple vCenter components in a single operation. After a file-based or image-based restore, the reconciliation API checks whether vCenter partners in embedded linked mode are available, synchronizes vCenter data and services with the partners, and runs

vCenter services. The appliance recovery API exposes a restore client interface for programmatic restore operations, supporting automation of recovery workflows.

VCF Operations supports image-based backup and restore as a recovery process for single node, primary node, replica node, data node, and collector failures. VCF Operations for Networks supports backup and restore of its deployment data to enable recovery when the existing setup is unrecoverable. VCF Operations HCX provides backup and restore operations through its appliance management interface, and its Mobility Groups support workload migration with state tracking, retry capabilities, and reverse migration from destination back to the original source.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere namespaces, and VCF Services consumption, extends recovery and reconstitution capabilities to containerized workloads and self-service deployments. At the Kubernetes control-plane level, ReplicaSets and Deployment controllers continuously monitor pod health and reschedule workloads to healthy nodes when pods or nodes fail. Liveness probes detect application-level failures and trigger container restarts; readiness probes gate traffic until a workload recovers from transient faults or overloads. These self-healing mechanisms operate without manual intervention for transient failures. Pod Disruption Budgets allow administrators to define minimum availability constraints that the platform respects during voluntary disruptive actions such as node upgrades or certificate rotations, so those operations proceed without taking down an entire service.

VKS clusters support structured backup and restore through VKS Cluster Management and Velero-based mechanisms. VKS Cluster Management backup operations can capture an entire cluster or a subset of data resources, and restore operations allow the operator to specify the scope of resources to recover. Restore operations include file system backups by default; CSI volume snapshots can be optionally selected for restoration. CSI Volume Snapshots deliver crash-consistent backups with support for block mode and file system mode, incremental backups, deduplication, compression, and encryption, and provide a resilient safety net for VKS clusters when primary storage infrastructure fails. CloneFromSnapshot custom resources expose a status.phase field that tracks restore progress through multiple phases, giving operators visibility into the state of ongoing recovery operations. The Velero plugin for vSphere supports backup and restore of vSphere pods, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

Deploying workloads across multiple failure zones using the Cluster API defines worker nodes across multiple failure domains with automatic healing rules that reschedule workloads when a zone becomes unavailable. Replicating control plane components across at least three failure zones limits the impact of a single-zone failure on the Kubernetes control plane itself. For VM Service workloads, the IaaS Services Console and Local Consumption Interface provide a Resources tab where users can create snapshots with optional memory capture and guest file system quiescence, and can revert a VM to a prior snapshot to restore it to a known state.

Deployment rollback is available natively in Kubernetes through Deployments with revision history, allowing administrators to return to a previous known-good revision when a newly deployed version fails. The Harness CI/CD Supervisor Service extends this with automated rollback capabilities that can revert to a previous stable state when deployment failures are detected.

Immutable infrastructure patterns supported by Kubernetes, combined with infrastructure-as-code stored in version control, provide a reproducible mechanism for reconstituting a cluster to a known, authorized state. Every change to the declared state is recorded in version control, and the cluster can be rebuilt from that record after a compromise or failure. VKS Cluster Management Policy Insights expose Sync signals that indicate when policy definitions fail to propagate from the management plane to the targeted VKS cluster estate, helping operators detect and remediate policy drift before it affects recovery posture.

Restore operations require that the target infrastructure be in place before a restore can proceed. VCF documentation recommends implementing a consistent backup strategy to safeguard the infrastructure against unforeseen disruptions and to support effective disaster recovery.

VMware vDefend (Contributes)

VMware vDefend contributes to secure recovery and reconstitution through backup and restore capabilities for its own security infrastructure, and through disaster recovery features that maintain security policy continuity across site failover events.

The Security Services Platform provides backup and restore functionality, accessible through the System > Backup and Restore interface, that allows recovery of a platform instance to its previous configuration when the current instance is in a non-recoverable state. The backup scope includes the full system inventory: tokens, Bare Metal servers, and Bare Metal server interfaces are captured as part of inventory backup, and required certificates from the backup server are restored automatically during the restore process. The platform must be in a healthy state to perform backup operations; backup and restore cannot proceed when the platform is unhealthy. Certificate consistency between backup and restored Security Services Platform environments must be maintained to avoid NDR Sensor disruptions. Backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Administrators should back up the Security Services Platform before performing scale-out operations, and Bare Metal Service operations (onboarding, offboarding, or upgrading Bare Metal servers) should not be performed while backup or restore is in progress.

The Security Services Platform can be deployed on vSAN stretched configurations, which supports recovery from site failures and reduces recovery time at the infrastructure level.

For disaster recovery scenarios, NSX Federation maintains security posture during workload migration and site failover by propagating Distributed Firewall rules, security groups, and microsegmentation policies across multiple sites. When workloads fail over from a protected site to a recovery site, the vDefend security policies governing east-west traffic at the destination site are already in place. vSphere HA can be configured to handle host-level failures affecting Security Services Platform appliances.

The broader recovery of compute infrastructure, storage, virtual machines, and application workloads to a known state is handled by other VCF components such as Protection and Recovery, vSAN Data Protection, vSphere Replication, and vCenter backup and restore.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides mechanisms for secure recovery and reconstitution of virtual machine workloads to a known state after a disruption, compromise, or failure.

Recovery is organized through protection groups and recovery plans. Protection groups define which virtual machines are protected, while recovery plans orchestrate the sequence of steps required to recover those workloads at the recovery site. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state governs which operations are permitted at each stage of the DR lifecycle. Recovery plans support two primary modes: planned migration for orderly, scheduled failover, and disaster recovery for unplanned site failures. A single recovery plan can also be configured to serve both disaster recovery and cyber recovery operations, allowing organizations to maintain consistent recovery procedures across different incident types.

Recovery plan testing is a built-in capability. Recovery plans should be tested before use for planned migration or disaster recovery to validate their functionality. This confirms that the recovery process will bring protected virtual machines online at the recovery site and that inventory mappings correctly place workloads on the appropriate networks, storage, and compute resources.

Cyber Recovery extends reconstitution capabilities with an Isolated Recovery Environment (IRE) designed for compromise scenarios such as ransomware incidents. The IRE provides a dedicated, isolated segment of the recovery environment that blocks direct private network connections from production, allowing compromised workloads to be analyzed and validated before being returned to production. Cyber Recovery transitions virtual machines through a controlled sequence of states, including Entering validated, Validated, Staging, and Staged, to prepare them for recovery. This state-based workflow supports data integrity validation prior to production restoration.

Recovery plan compliance checks verify that protection groups are actively replicating, that sufficient point-in-time snapshots are available for each virtual machine in the plan, and that all workflow steps can execute without conflict. Continuous compliance monitoring provides warnings when VM configuration status deviates from expected state.

The Configuration Import/Export Tool enables administrators to export PNR server configuration data, including inventory mappings, placeholder datastores, advanced settings, array manager configurations, and protection group definitions. This capability supports configuration backup and reconstitution of the PNR environment itself after a failure or migration.

PNR integrates with VCF Operations for recovery plan lifecycle visibility. The Recovery Plans Details dashboard shows the current phase of the DR lifecycle, including whether a plan is ready, whether a test is in progress, and whether incomplete recovery or cleanup operations require attention. PNR also supports recovery of VCF Automation and VCF Operations services: when a disaster event affects the management domain containing these services, PNR enables service recovery in another management domain.

All communications between PNR and VMware vCenter instances use TLS certificates and private keys. The PNR Appliance supports importing server certificates signed by a certificate authority to establish secure communications across both protected and recovery sites.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the secure recovery and reconstitution of database services to a known state following a disruption, compromise, or failure.

For backup-based recovery, DSM supports point-in-time recovery (PITR), which restores a backup to a newly created database VM. During the restore operation, the administrator can specify the database name, choose the target datastore location, and configure management settings. DSM supports restoring backups from either local or cloud-compatible (S3-compatible) storage, with restoration permitted to any point in time within the configured backup retention period. When restoring a deleted database, DSM's Archives tab allows users to access databases with retained backups and create a new database VM from a selected restore point, including options to restore to the most recent available timestamp or a custom point in time. PITR coverage extends across PostgreSQL, MySQL, and SQL Server database engines. For SQL Server, DSM automatically manages the database recovery model based on backup status, using Full Recovery for databases with automated backups enabled and Simple Recovery otherwise. Cloning a MySQL or PostgreSQL database is functionally equivalent to PITR to the latest available time, giving operators an additional path for rebuilding a known-good database instance. For failed clusters, DSM supports restoration to a different cluster with the option to target either the latest available time or a specific custom restore point.

For active recovery and failover of PostgreSQL databases, DSM provides a multi-site disaster recovery deployment model in which a secondary instance replicates from the primary across sites. When a failover is needed, DSM provides a switchover workflow that reverses the roles of instances, redirecting the secondary to become the new primary and restoring the database service to a fully operational state. DSM also provides a switchover workflow for failback, allowing operators to reverse instance roles again after the primary site is restored. DSM requires trust validation of the new primary database certificate when redirecting secondary instances during disaster recovery switchover, and operators with the DSM user role must manually establish trust between primary and secondary instances by retrieving the Certificate Authority from the primary and adding it to the Provider VM that will host the secondary. For backup-location certificates, DSM supports a Trust On First Use (TOFU) configuration that extracts and trusts certificates for specific backup locations, and at least one backup location must be configured with a trusted root certificate when a data service policy requires or allows automated backups. DSM also preserves the backing virtual machines of removed database nodes in an idle state until an instance is promoted again, maintaining infrastructure capacity for disaster recovery operations.

The resiliency of the DSM Provider Appliance itself is supplied by the underlying VCF platform (see VCF Coverage); DSM relies on vSphere High Availability to restart the appliance on another host in the event of a host failure, and does not add a separate management-plane HA mechanism. If a DSM provider restore fails for any reason, the documented procedure is to re-deploy the appliance and then follow the recovery procedure again rather than re-attempting the restore workflow on the same appliance.

DSM tracks recovery operations through its audit and operations interfaces. Event logs record Provider Restore Success events with timestamps, allowing operators to verify that recovery operations completed. Restore operation progress is visible in the Operations tab and Operations view, and a new entry appears in the Databases view table when a restore completes. To

support integrity of recovery artifacts, the DSM Consumption Operator deployment includes Signature Verification of packages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer recovery and reconstitution mechanisms at the load balancing and application delivery tier.

The Avi Controller cluster can be deployed across two availability zones, with defined failure scenarios and documented recovery actions for each zone-loss case. Availability zones should be configured based on fault domains associated with shared power supplies, shared networking devices, or other common infrastructure to reduce the risk of virtual service unavailability. When the cluster enters manual recovery state following a failure or compromise, Avi automatically revokes all Service Engine secure channel credentials and causes Service Engines to reboot themselves, halting all application traffic delivery. This returns the data plane to a controlled, known state. Service Engines that subsequently re-establish connectivity to a recovered Controller node reconfigure themselves automatically to connect only to that node.

If all three Controller cluster nodes are permanently unavailable, recovery must be performed using a backup and restore procedure. When a Controller node fails but is not permanently lost, it can be recovered by bringing the existing node back online, which is transparent to existing data traffic, or by rebuilding a new Controller node, which is disruptive to existing connections. Factory reset recovery is irreversible and deletes all Controller configuration, requiring the database to be recreated from the configuration archive. When a Service Engine is compromised or rebooted independently, all configurations including private keys and public certificates are wiped from the Service Engine, providing a clean starting state for reconstitution.

Elastic High Availability (Elastic HA) provides fast recovery for individual virtual services following the failure of a Service Engine, redistributing workloads to surviving Service Engines without requiring a full cluster-level recovery event. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, so application services are restored in a defined sequence.

Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling global-level recovery and reconstitution for applications served across multiple sites.

Avi provides configuration backup and restore capabilities for the Controller. A remote backup destination should be specified to protect against non-recoverable Controller cluster failures. The Controller checks and obtains user consent prior to performing a restore operation. After a storage failure requiring a full restore, the Controller is restored from the configuration archive. The restore process follows a defined sequence: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Post-restore validation verifies the count of restored configuration objects, including clouds and Service Engine groups, confirming that the reconstituted state matches the backup. Restore operations report state information including the operation type, image version, and cluster node name. The Controller logs restore completion events with timestamps, node IP addresses, task status, and success or failure messages for audit trail purposes.

Avi's recovery mechanisms address the application delivery tier. VM-level backup and restore for the Controller and Service Engine VMs, storage-level recovery, and infrastructure reconstitution depend on the underlying VCF platform. See VCF Coverage for those mechanisms.

Control A1.3

The entity tests recovery plan procedures supporting system recovery to meet its objectives.

SCF Controls: BCD-03.1, BCD-04, BCD-11.1, BCD-11.5

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VMware vDefend (Contributes)

VMware vDefend Security Services Platform (SSP) provides backup and restore capabilities for the security platform itself, offering several mechanisms that support routine verification of the backup process.

SSP includes a configurable backup schedule that supports recurring backups, which can be toggled on or off. Backup frequency can be set as weekly on a selected day and time, or as an interval-based schedule ranging from a minimum of 6 hours to a maximum of 720 hours. The SSP Backup History section displays backup operation status, showing Completed when a backup operation is successful, giving operators direct visibility into whether scheduled backups are completing. When a scheduled backup fails, SSP generates a Scheduled Backup Error alarm to notify operators of the failure.

Backup and restore operations generate pod logs that record detailed error messages, including database query failures and volume attachment errors, supporting diagnosis of backup failures. If an operation becomes stuck in a FAILED or QUEUED state, operators can inspect cluster-api pods and backup pod status to troubleshoot the condition.

The SSP Installer data backup produces duplicate platform configuration data that can be restored in the event of hardware malfunctions, software malfunctions, data corruption, malware incidents, or unintentional data deletion. Restore operations require adequate storage on the target server, the same NSX instance that was onboarded at the time of backup, and the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored SSP environments is required to avoid service disruptions, including disruptions to NDR Sensors.

vDefend's contribution is to the operational health and backup completion visibility of the security platform itself. The control asks whether the organization routinely tests backups for reliability and integrity; vDefend provides the scheduling, status tracking, and alerting mechanisms that support such testing, but automated restoration testing and integrity validation of backup content require supplemental organizational procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing capabilities that exercise the recovery process and verify the integrity and availability of replicated data at the recovery site. The cadence and scope of routine testing remain an organizational practice.

Recovery plan tests run virtual machines on a test network and against a temporary snapshot of replicated data at the recovery site, isolating test execution from production data and from ongoing operations at either site. Tests can be run as often as needed and cancelled at any time without impacting production systems. Testing exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. PNR documentation recommends testing recovery plans before use for planned migration or disaster recovery to validate functionality before production execution, as failure to test may result in data loss during an actual disaster recovery. After a reprotect operation completes, running a test recovery verifies that errors are resolved before running a planned migration or disaster recovery. After testing completes, the cleanup capability removes test artifacts so they do not persist in the recovery environment.

Recovery plan testing can be configured to replicate recent changes to the recovery site so that the test exercises the latest copy of protected virtual machines, though this may increase synchronization time. PNR can generate and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup for audit trail purposes, providing a record of testing activity that administrators can reference.

PNR monitors protection group and recovery plan health, detecting critical issues including loss of connectivity to protected or destination sites, snapshot replication failure, and recovery plan malfunction. The Protection and Recovery management pack integrates with VCF Operations to enable data collection from PNR Cloud instances and provide centralized dashboarding of recovery telemetry.

Traditional backup testing capabilities, including platform component backup validation and VADP-based third-party backup verification, are provided by the underlying VCF platform (see VCF Coverage). Establishing a routine test schedule, defining acceptance criteria, and recording test outcomes for audit are organizational responsibilities that sit outside PNR's automated scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides automated backup capabilities, backup health monitoring, integrity-verification mechanisms, and on-demand restore tooling that support an organization's routine backup verification practices. A formal backup testing program itself requires organizational process.

DSM supports automated backups for databases with configurable backup schedules and retention periods. PostgreSQL databases use configurable settings for backup location, retention period, and backup schedule, controlled by the Enable Automated Backups setting during database creation or through database settings afterward. DSM data service policies can be configured to require automated backups, allow them as optional, or disallow them, giving administrators a way to enforce backup coverage on databases under a policy. High Availability clusters require automated backups to be enabled before databases can be provisioned. Backup chain integrity depends on retaining the last full backup and all subsequent incrementals. If any incremental in the chain is deleted, DSM cannot restore the full data, which is a consideration when designing retention policy and backup chain management procedures.

Backup health is actively monitored. DSM validates the connection and operational status of the backup storage repository, verifies the bucket name, checks credential expiration, confirms certificate expiration dates, and validates that there is sufficient available repository space. Scheduled backup failure alerts notify administrators when a scheduled backup operation fails, and the monitoring framework supports metrics-based and status-condition alerts that identify critical failure conditions including database engine degradation, non-operational status, and automated or transaction log backup failure. Webhook payloads triggered by data service operation failures can be validated using the TEST function before deployment so that failure notifications reach the intended target. A trusted root certificate must be configured for each backup location used by a data service policy that requires or allows automated backups.

For data integrity verification, DSM PostgreSQL distributions include the amcheck extension at versions 1.2, 1.3, and 1.4 across the supported PostgreSQL builds, which provides functions for verifying relation integrity directly inside the database. Administrators can use amcheck to spot-check that a restored database's internal structures are sound after a recovery exercise, giving the testing program a database-engine-level data integrity check.

Administrators have several mechanisms to verify recoverability. DSM supports point-in-time recovery (PITR) that restores a backup at a specific point in time to a new database instance, with restoration possible to any point within the configured backup retention period. The restore creates a new database VM with a user-specified name and datastore location, so the test restore does not affect the source database. Deleted database backups remain available and can be restored to a newly created database VM at the most recent timestamp or to a specific point in time, supporting test restores of historic state. On-demand backups can be triggered manually for primary PostgreSQL databases to capture a known-good state before a planned change or verification exercise. DSM Provider VM recovery from backup is supported through the restore-provider command with the pgbackrest.conf path, which restores the Provider VM to the latest timestamp after a terminal failure during non-upgrade operations. The Provider VM requires a Provider Backup Repo to be configured before recovery is possible. Tenants can also restore a database to a specified restore point through the VCF Automation UI when DSM is consumed through VCF Automation.

While DSM provides the backup infrastructure, monitoring, validation, integrity-verification, and restore capabilities that form the technical foundation of a backup testing program, the organization must conduct scheduled restore tests against non-production environments to validate actual data recoverability, document the results, and maintain a formal testing cadence. DSM does not automate test restores to a separate environment, so these organizational procedures are required to fully satisfy this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides backup and restore capabilities for the Avi Controller configuration, including automated scheduling, multiple storage destinations, pre-restore integrity validation, and post-restore verification.

The Controller backup scheduler automates periodic backup operations. Configuration data can be written to local storage on the Controller with a configurable retention count, or to a remote backup destination. Configuring a remote backup destination is recommended to protect against scenarios where the Controller cluster fails in a non-recoverable fashion. In

VCF-integrated deployments, VCF Operations is used to configure the external backup server and storage path; by default, Avi Load Balancer backups are stored on the same server where VCF Operations appliance backups are stored. For single-node Controller deployments and when recovering from a complete VM or disk failure, enabling periodic external configuration backups is mandatory. Administrators can use the ``show backups`` CLI command to list available backup files, and the ``export`` command to capture a full system configuration or individual virtual service configurations. A backup must be verified as taken prior to initiating any upgrade operation. After upgrades, backups should be stored with clear labeling that includes version and date.

Restore operations can be initiated through the CLI using the ``import`` command with the ``keep_uuid`` option to restore to an empty Controller, or through the REST API by attaching a configuration backup file and providing the decryption passphrase. Before any restore proceeds, the Avi Controller performs pre-restore validation checks that verify Controller Cluster readiness, upgrade operation status, ServiceEngineGroup upgrade status, backup configuration version compatibility, FIPS mode alignment between the backup and the target environment, the presence of required file objects, and configuration validity. These checks are logged with timestamps, including FIPS configuration status and image validation state. In VCF-integrated environments, the restored Controller instance must remain synchronized with the VCF Operations lifecycle.

After a restore completes, the Controller performs post-restore validation tasks that verify the successful restoration of configuration objects, including counts of restored Clouds and ServiceEngineGroups. This confirms that backup data has been correctly applied before the system returns to service.

Organizations should establish a defined process to periodically execute test restores, verify that recovered configurations are complete, and record results as evidence of backup program effectiveness.

Control C1.1

The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.

SCF Controls: AST-04, DCH-01, DCH-01.2, DCH-02, DCH-03, DCH-06.2, DCH-18, PRI-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label,

and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl` snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend contributes to sensitive and regulated data protection by enabling microsegmentation through the vDefend distributed firewall (DFW), which restricts unauthorized inter-application and intra-application-tier traffic to reduce the network attack surface around workloads that process sensitive data. The DFW enforces Layer 2 through Layer 7 access policies, including application identity-based and user identity-based controls and FQDN filtering, enabling organizations to define precise access restrictions around workloads handling regulated data. The DFW also supports targeted deny rules scoped to infrastructure groups such as DNS and DHCP servers through the Applied-To field, supporting phased adoption of least-privilege network access for critical infrastructure services.

Security Services Platform (SSP) extends this protection through several mechanisms. SSP Application Protection in Strict Mode enforces application-level firewall rules across all application workloads, with scoring based on workload coverage, traffic coverage, and lock-down policy adoption. SSP Environment Protection evaluates whether workloads are protected by environment-specific segmentation policies such as development, production, and test tiers, helping operators confirm that workloads handling regulated data operate within appropriately isolated zones. Security Intelligence within SSP enables administrators to enforce microsegmentation by converting observed allow flows to explicit deny rules after confirming no additional unprotected flows exist. SSP also identifies risky application protocols that transport data in clear text and recommends enforcing minimum secure protocol versions across internal communications, directly supporting protection of sensitive data in transit.

SSP's Segmentation Monitoring and Security Segmentation Score surface residual protection gaps. Segmentation Monitoring categorizes infrastructure services as fully protected, partially protected, or not protected, and provides recommendations for servers and services lacking full policy coverage. The Security Segmentation Score quantifies the number of unprotected traffic flows hitting default allow rules out of all unique flows associated with known risk factors, giving operators a measurable indicator of exposure across the environment.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, protecting the confidentiality of data processed by the detection platform itself. vDefend does not provide data-at-rest encryption for workload storage or data classification capabilities; those controls remain the responsibility of VCF platform capabilities and organizational data management practices.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to protecting sensitive and regulated data by maintaining replicated copies at geographically separated sites and providing orchestrated recovery when primary copies are compromised or corrupted. Bidirectional protection is implemented by protecting datastore groups or storage policies using array-based replication, or by protecting individual virtual machines using vSphere Replication, allowing organizations to keep regulated workloads recoverable across paired sites.

Protection groups allow administrators to organize regulated workloads and apply consistent replication and snapshot policies across the virtual machines and datastores subject to the same data protection requirements. PNR protection groups support an immutability mode that, when enabled, prevents the data protection group from being modified or deleted, which addresses tamper resistance for the configuration that governs how regulated workloads are protected. For multi-tenant or shared recovery scenarios, PNR maps resources, networks, folders, and datastores on protected sites to separate datacenters, networks, folders, and placeholder datastores on the shared recovery site, preserving customer data isolation across the recovery boundary.

vSAN Snapshots and Replication provides VM restore and clone operations from existing snapshots, supporting recovery of regulated workloads to a known-good point in time. PNR records operational information into log files that do not contain sensitive information such as private keys or passwords, which limits the recovery tooling itself as a source of disclosure. The Protection and Recovery dashboards in VCF Operations provide cross-site visibility into protected and recovery sites, vSAN snapshot and replication state, and VCF Protection and Recovery Cloud regions, supporting monitoring of regulated workload protection.

Encryption at rest for primary storage, data classification, granular access controls at the data layer, and key management are provided by the underlying VCF platform rather than PNR itself.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the protection of sensitive and regulated data through several database-platform mechanisms covering data in transit, data retention, storage policy enforcement, tenant isolation, and application-level cryptographic capabilities.

For data in transit, DSM requires TLS connections to database clusters. Clients establish these connections by adding the relevant certificate authority to the OS trust store, or by retrieving the CA certificate from a custom certificate secret through the DSM API for automated workflows. Beginning with DSM, DSM enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. A TLS certificate for secure communication between the Consumption Operator and the DSM provider must be obtained and configured by the cloud administrator before enabling self-service consumption.

For backup and data retention, DSM includes automated backup capabilities with configurable schedules supporting both full and incremental backups. Database administrators configure backup storage locations and retention periods on a per-database basis. DSM retains automated backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. Control plane backups are stored in S3-compatible object storage with a unique identifier tied to the control plane ID. DSM supports point-in-time recovery (PITR), restoring a backup at a specified point in time to a newly created database VM. PITR is accessible through both the DSM interface and the VCF Automation UI. If an incremental backup in a backup chain is deleted, DSM cannot restore data from later incremental backups in that chain, so maintaining a consistent backup schedule is important for recoverability.

For storage placement and access constraints, DSM infrastructure policies control which storage types and storage policies are available for database virtual machines and govern VM placement within the infrastructure. Storage policies in DSM determine the datastore placement of database VMs and filter available storage options to those compatible with the specified compute resource. Data service policies can be defined and enforced across tenants for MySQL, PostgreSQL, and SQL Server databases, including allowlists that restrict users to approved provisioning parameters. In multi-tenant deployments using VCF Automation, administrators can assign object stores and data service policies to specific tenants or organizations, enforcing isolation and resource constraints across database clusters.

For application-level data protection, PostgreSQL databases in DSM support the pgcrypto extension (version 1.3), which provides cryptographic functions that can be applied to secure specific data fields. DSM also stores its own internal user credentials encrypted using PGCrypto symmetric encryption with a dedicated encryption key. For SQL Server databases, DSM uses an internal management login that restricts user-defined triggers to a database-level security context, blocking access to server-level permissions during management operations.

Because this control asks whether mechanisms exist to protect sensitive and regulated data wherever it is processed or stored, DSM's contribution is at the database platform tier. The organization remains responsible for classifying what data is sensitive or regulated, configuring database-level access controls that restrict which authenticated users can read or write protected data, selecting storage and backup policies that satisfy encryption and data residency requirements for specific regulated categories, and maintaining a governance program that maps data classification to handling requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and

other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control C1.2

The entity disposes of confidential information to meet the entity's objectives related to confidentiality.

SCF Controls: AST-09, DCH-08, DCH-09, DCH-21, MON-10, PRI-05

Aggregate Coverage: Contributes

VCF (Contributes)

DCH-21 addresses the secure disposal, destruction, or erasure of information. VCF provides several technical capabilities that contribute to this control, though a complete information disposal program requires organizational policies and procedures that define when and how data should be disposed of.

vSAN encryption includes a disk erasure capability. When enabling vSAN encryption, administrators can select the "Erase disks before use" option to wipe existing data from storage devices before they are encrypted. This provides a mechanism for sanitizing physical storage media within the VCF environment when disks are being repurposed or encryption is being enabled. For encrypted storage, revoking or rotating encryption keys renders previously encrypted data inaccessible without requiring a full disk overwrite. vSAN supports generating new Key Encryption Keys (KEK) and Data Encryption Keys (DEK) and re-encrypting all data on storage using new keys through a rolling disk reformat. This key rotation capability, combined with the two-tier key hierarchy, provides a cryptographic erasure path for decommissioning encrypted storage.

TPM 2.0 integration binds encryption keys to the physical host. Each VMware ESX host obtains encryption keys and persists them in its Trusted Platform Module across reboots, allowing encryption operations to continue when the key server is unavailable. Because keys are bound to the host's TPM, clearing the TPM during host decommissioning removes the locally cached key material. At the virtual machine level, vSphere also supports a virtual Trusted Platform Module (vTPM) for individual VMs. Removing a vTPM device from a virtual machine causes all encrypted information on that machine to become unrecoverable, providing a VM-level cryptographic disposal path when workloads are decommissioned.

For backup and recovery data, VCF's best-practice guidance calls for securely deleting decrypted files after completing restore operations for VCF Operations, VMware vCenter, and NSX components. Backup files are encrypted, and administrators are expected to control access to decrypted files and securely delete them once the restore is complete. This helps prevent sensitive recovery data from persisting beyond its intended use.

For virtual machine lifecycle management, VCF Operations provides a reclamation interface with a DELETE VM capability that removes powered-off virtual machines from the environment, supporting the disposal of virtual machine data when systems are decommissioned. Guest information stored within a virtual machine can also be cleared, though this operation requires the virtual machine to be powered off first.

VCF Operations supports automated data retention and purging. Configuration data collected from monitored objects is purged from the system after a configurable number of days. Administrators can configure historical data retention settings through Administration, Global Settings, Data Retention to manage the lifecycle of operational data. This provides automated disposal of aging monitoring and configuration data without manual intervention. When adapter instances are deleted, VCF Operations removes the adapter instance and clears associated objects from the system, including historical data and role assignments. Administrators can optionally delete related objects when removing an adapter instance, or retain them selectively. If an adapter instance is recovered before the end of the retention period, the related objects are unmarked and not deleted.

vCenter also maintains task and event information for a configurable retention period and can be configured to discard this data periodically to manage database growth; these settings are available under Configure Database Settings in vCenter.

The VCF Operations orchestrator provides a "Delete a keystore" workflow that removes keystores, supporting the secure disposal of cryptographic keys when they are no longer needed.

Content Library enforces access controls on item deletion, restricting it to users with Edit or higher permissions on writable libraries. This role-based restriction helps ensure that disposal actions are authorized.

VCF Operations provides audit visibility into deletion activities. The platform raises an alert when any entity is deleted, creating a record that supports accountability for disposal actions. VCF Operations also tracks orphaned disk space as a sustainability metric, measuring the aggregated size of orphaned disks that are candidates for reclamation, which helps administrators identify residual data that should be cleaned up.

Secure disposal of physical media, organizational data retention schedules, disposal verification processes, and chain-of-custody documentation for media destruction are responsibilities that fall outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend contributes to secure information disposal through mechanisms built into its security analytics and threat prevention components. While vDefend is not a storage or media sanitization product, it collects and retains security-relevant data including network flow records, threat analytics, security policy metadata, and classification labels, and provides mechanisms for disposing of that data when it is no longer needed.

Security Services Platform provides deactivation paths that result in permanent deletion of associated data. Graceful deactivation of Bare Metal Security Service deletes all associated server information including certificates and inventory, and blocks the decommissioned server from reconnecting to the platform. A forceful deactivation path is also available that performs the same permanent data removal and deregistration. When an NDR Sensor is offboarded, Security Services Platform clears all registration and trust data from the system. The force offboard endpoint capability in Endpoint Management immediately deletes all endpoint data from the License Hub. Deleting a Security Services Platform instance removes the platform and all its associated components.

Security Services Platform supports certificate management with an explicit Remove action, including deletion of certificates for web proxies. Role assignments for remote users and groups can be deleted when LDAP is configured as an authentication provider. The platform backs up tokens and Bare Metal server inventory as part of inventory backup, supporting controlled lifecycle management and enabling intentional disposal after a backup is confirmed.

Malware Prevention Service rules and Service Virtual Machines can be deleted through Security Services Platform. The platform records metrics for purged records from Malware Prevention Service tables, covering inspection events, intercepted entities, and malware classification data, providing visibility into automated data purge activity.

Security Intelligence supports label deletion, which clears all associated label assignments to compute entities in the Security Intelligence visualization. Label assignments are also automatically cleared up to 30 days after an associated compute entity is deleted from inventory.

These capabilities address the disposal of vDefend's own operational and security analytics data. Broader information disposal requirements, such as sanitizing storage media, managing organizational data retention schedules, enforcing disposal verification processes, and cryptographic erasure of application data, fall outside vDefend's scope and are handled by other VCF components or organizational processes.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates and preserves multiple categories of operational and security-specific logs that support after-the-fact investigation of recovery-related events.

PNR records operational information into log files that exclude sensitive data such as private keys and passwords. vSphere Replication maintains dedicated security audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the appliance and at `/var/run/log` on ESX hosts. Security-relevant events captured in these logs include authorization error messages, certificate verification failures, and session activity such as logout events with timestamps, user identity, source IP address, and operation IDs.

PNR records structured event data across its components, with each event carrying a corresponding alarm that PNR can trigger for health tracking and issue resolution. Protection group activity is logged as typed events: consistency group

additions, datastore membership changes, and protection group errors are recorded as Info- or Error-level events, respectively. vSphere Replication generates typed audit events for replication lifecycle transitions, including when virtual machines and hosts are configured or unconfigured for replication. Recovery operations are preserved in a per-plan history log; reprotect operations are included in this log and can be exported as a report, providing a record for post-recovery verification.

The Clean Room Orchestrator records events with a structured schema that includes timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Snapshot task events are captured upon completion and are accessible through the Snapshot log interface in the event details panel.

For forwarding and long-term retention, the PNR Appliance natively supports forwarding log files to remote syslog servers for log analysis and centralized monitoring. PNR supports forwarding events to VCF Log Management (version 9.0 and above), enabling log data to flow into centralized log management infrastructure. PNR also integrates with Microsoft Azure Log Analytics Workspace for custom log collection using Data Collection Rules (DCR) and Data Collection Endpoints (DCE), providing a cloud-native retention path.

Per-component logging levels can be adjusted through the advanced configuration interface. The `logManager.Persistence` setting controls the logging verbosity for persistence-related events, with a default value of verbose, allowing administrators to tune log volume to match available storage and retention requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains an event log system that records system activities, configuration changes, and operational events, with an audit trail that tracks who made configuration changes and when. The Avi Controller preserves a permanent log of the underlying events and metrics that triggered alerts, retaining those records beyond the alert expiry period.

The 9.1 documentation specifies that events raised by Avi Load Balancer components must persist in a secure manner for a minimum of 90 days for audit compliance. The retention policy is configurable: administrators can adjust the periodic interval and the threshold that triggers policy enforcement based on system and infrastructure requirements. The Avi Controller analytics API supports querying event logs for periods of up to one year, and the documentation recommends reviewing event logs over a one-year window to maintain audit trails of configuration changes.

For compliance-grade long-term retention beyond the on-appliance minimum, Avi provides the Syslog-Audit-Persistence feature, configured through the Controller's Alert Actions settings. This feature streams audit compliance events to external syslog servers. The Avi Controller and Service Engine also log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk destinations. The documentation recommends streaming all logs directly to an external server such as Splunk for assured retention; Avi's Controller Settings allow specification of syslog server destination details.

There are retention constraints that organizations should account for when designing their log retention architecture. Configuring syslog notifications in the Avi Controller forwards alert events to syslog servers but does not directly export virtual service logs; those must be pulled from an external logging system through the API or scripted to be pushed from the Controller to a remote destination. In the absence of active queries, application logs do not leave the Service Engines that collected them. For retention periods beyond the built-in minimum, administrators must configure Syslog-Audit-Persistence or an equivalent export mechanism to an external destination and maintain that destination's storage capacity and retention settings independently.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CC1.1

COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.

SCF Controls: CPL-01.1, CPL-02, CPL-03, GOV-01, GOV-04, GOV-05, GOV-14, HRS-01, HRS-05, HRS-05.1, HRS-07, HRS-07.1, RSK-06, TPM-01, TPM-03, TPM-05, TPM-05.4, TPM-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC1.2

COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.

SCF Controls: GOV-01, GOV-01.1, GOV-02, GOV-04.1, GOV-04.2, GOV-05, GOV-05.1, GOV-05.2, GOV-08, GOV-10, HRS-01, HRS-02, HRS-03, HRS-03.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC1.3

COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.

SCF Controls: GOV-01.1, GOV-04, GOV-04.1, GOV-04.2, HRS-01, HRS-03, HRS-03.2, PRI-01, PRM-06, TPM-04.3, TPM-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC1.4

COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.

SCF Controls: AAT-01, AAT-11, AAT-13, AAT-13.1, GOV-02, HRS-01, HRS-02.2, HRS-03, HRS-03.2, HRS-04, HRS-13, HRS-13.4, PRM-02, PRM-03, SAT-01, SAT-02, SAT-03, SAT-03.7, SAT-03.8, TPM-01, TPM-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC1.5

COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.

SCF Controls: CPL-01, CPL-01.1, GOV-01.1, GOV-04.1, GOV-04.2, GOV-05, GOV-05.1, GOV-05.2, HRS-01, HRS-03, HRS-03.2, HRS-06, HRS-06.1, HRS-07, HRS-07.1, HRS-08, HRS-09, HRS-09.1, HRS-09.2, HRS-09.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC2.1

COSO Principle 13: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.

SCF Controls: AST-01, AST-02, AST-02.10, AST-02.8, AST-04, AST-04.1, BCD-02.4, CLD-09, DCH-01, DCH-01.1, DCH-02, DCH-06.2, DCH-11, DCH-19, DCH-22, DCH-24, GOV-05, GOV-09, GOV-15, HRS-03, OPS-03, SEA-14.2, TPM-01.1, TPM-04.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory

Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-O2 compliance.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the

subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control CC2.2

COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.

SCF Controls: AST-04.1, AST-04.2, CHG-01, CHG-02, CHG-05, CPL-01, CPL-01.2, CPL-02, GOV-01.1, GOV-01.2, GOV-02, GOV-03, GOV-05, GOV-05.1, GOV-05.2, GOV-06, GOV-07, GOV-08, GOV-09, HRS-01, HRS-03, HRS-07.1, IAO-01.1, IAO-03, IRO-01, IRO-02, IRO-02.4, IRO-04, IRO-07, IRO-09, IRO-10, IRO-10.2, IRO-11.2, OPS-01, OPS-01.1, OPS-03, PRM-01, PRM-05, SAT-01, SAT-02, SAT-03, SAT-03.2, SAT-03.3, SAT-03.5, SAT-03.6, SEA-01, SEA-02.1, TPM-05.4, TPM-05.5, VPM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC2.3

COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.

SCF Controls: CPL-01, CPL-02, GOV-01, GOV-01.1, GOV-01.2, GOV-06, GOV-07, HRS-01, HRS-07.1, IAO-03, IRO-02, IRO-04, IRO-09, IRO-10, IRO-10.2, IRO-10.4, IRO-11.2, IRO-14, OPS-03, PRI-01, PRI-02, PRI-14, SAT-03.2, TDA-01, TPM-01, TPM-05, TPM-05.1, TPM-05.2, TPM-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC3.1

COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.

SCF Controls: CPL-01, GOV-01.1, GOV-01.2, GOV-06, GOV-08, GOV-09, GOV-15, GOV-16, GOV-17, OPS-03, PRM-01, PRM-03, PRM-04, PRM-06, RSK-01, RSK-01.1, RSK-01.3, RSK-01.4, RSK-01.5, RSK-04, RSK-05, RSK-09, SEA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC3.2

COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.

SCF Controls: GOV-17, RSK-01, RSK-01.1, RSK-01.3, RSK-01.4, RSK-01.5, RSK-02, RSK-02.1, RSK-03, RSK-03.1, RSK-04, RSK-05, RSK-06.1, RSK-08, RSK-09, RSK-09.1, RSK-10, SEA-01, THR-01, THR-02, THR-03, THR-09, THR-10, TPM-02, TPM-03, TPM-04.1, TPM-05.6, VPM-01, VPM-01.1, VPM-03.1, VPM-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC3.3

COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.

SCF Controls: AST-01, HRS-01, THR-01, THR-02, THR-04, TPM-01, TPM-03.1, TPM-04, TPM-04.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC3.4

COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.

SCF Controls: CHG-01, CHG-02, CHG-02.2, CHG-02.3, CHG-03, GOV-01.1, PRM-01, PRM-06, RSK-01, RSK-03, RSK-04, THR-01, THR-10, TPM-01, TPM-04.1, TPM-05.5, TPM-08, TPM-10, VPM-01, VPM-01.1, VPM-03, VPM-03.1, VPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical controls that govern configuration change processes across the infrastructure stack through VCF Operations, vSphere Lifecycle Manager, and VCF Automation.

VCF Operations includes a Configuration Drifts capability, accessible through Fleet Management > Configuration Drifts, that tracks changes in product configurations over time and allows administrators to compare current configurations against assigned desired values for VMware vCenter instances and vSphere clusters. When drift is detected, administrators are alerted so they can investigate and remediate. The config polling interval can be adjusted to control how frequently configuration data is collected from data sources, and drift detection can be scheduled at defined intervals. Together, these capabilities provide continuous monitoring of configuration state across the VCF environment.

Configuration templates in VCF Operations define a desired state for infrastructure configurations. Administrators create and manage these templates through the Fleet Management > Configuration Drifts interface. A configuration template represents a set of configurations that enables an administrator to define and monitor the intended configuration of managed resources. Templates can be assigned to policies, activated or deactivated as needed, and their attributes and properties can be overridden through the Policy Definition interface under Infrastructure Operations > Configurations.

For formal change control workflows, VCF Operations supports integrating configuration templates with a source control repository. This integration enables versioning, auditing, and centralized management of configuration templates. It also facilitates change control with reviews and supports continuous integration and continuous deployment pipelines for automated testing and validation of configuration changes before they are applied. This source control integration provides the traceability and approval workflows that configuration change control processes require.

VCF Operations provides policy management capabilities through its Infrastructure Operations Configurations module, where policies can be added, edited, and removed. Policy settings can be inherited from existing policies and modified with appropriate permissions, supporting a layered approach to configuration governance.

vSphere Lifecycle Manager (vLCM) enforces desired-state configuration for VMware ESX hosts, including drivers, firmware, and add-on software. Hosts are compared against approved baselines, and vLCM detects and can remediate deviations. vSphere Configuration Profiles provide an additional layer of periodic host configuration assessment, enabling management of the configuration of all hosts in a cluster collectively to help maintain consistency in host configuration at a cluster level. The cluster configuration in vSphere Configuration Profiles is represented as a JSON document that can be extracted from a reference host, imported, or drafted manually; the ClusterConfiguration.Modify privilege is required to create or modify this desired-state document.

VCF Operations governs lifecycle management for VCF components, including updates and patches. Before any update can be applied, VCF Operations requires a precheck to verify that the environment is ready for the change. This built-in gate helps prevent untested changes from being applied to production infrastructure. vSphere Lifecycle Manager synchronizes to its download sources, including VCF Operations, on a regular and automatic basis, providing a controlled channel for software updates. If out-of-band changes are made directly through vCenter or NSX Manager, VCF Operations can detect these changes and synchronize its inventory with the updated state, providing visibility into changes made outside the standard change control process.

VCF Automation includes approval policies that require review before changes to deployed catalog instances take effect. Approval policies enable project administrators to review all changes to deployed catalog items before resources are

consumed or modifications are made, providing a gate for configuration changes in provisioned environments. Day 2 actions on deployments, such as changing project assignments, are controlled through the VCF Automation actions framework.

For workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, the platform extends configuration change governance through Kubernetes-native mechanisms. All configuration changes to cluster resources are expressed as object specifications applied through the Kubernetes API server, which is the authoritative entry point for any modification to cluster state. Before applying changes, operators can use `kubectl diff` to preview the delta between the current cluster state and a proposed configuration, allowing review of what will change before it is committed. Kubernetes Deployment objects track the previously applied configuration through the `kubectl.kubernetes.io/last-applied-configuration` annotation, preserving the prior state and supporting rollback; `StatefulSet` controllers similarly use `ControllerRevision` objects to track historical configuration changes for version tracking and rollback of stateful workloads. Kubernetes documentation recommends storing object configuration in a source control system such as Git to enable change review processes and audit trails at the workload layer.

Access to the Kubernetes API server is governed by Kubernetes RBAC. Roles and ClusterRoles define what resources a subject can modify, and RoleBindings and ClusterRoleBindings assign those permissions to specific users or service accounts, restricting the identities that can alter cluster configuration. Admission controllers provide a further layer of change governance: validating and mutating admission webhooks intercept API requests before they are persisted, allowing organizations to enforce configuration standards or reject non-compliant configurations. Kubernetes `MutatingAdmissionPolicy` objects, declared using CEL expressions with structured merge diff, define desired configuration values that are enforced as resources are created or updated, with Parameter resources allowing policy configuration to be maintained separately from policy definitions. VCF Automation Kubernetes Management provides Mutation policies that can be assigned at the organization level to enforce policy-driven modifications to workloads across VKS clusters. For control plane configuration, `kubeadm` manages the `ClusterConfiguration` object stored in the `kubeadm-config` `ConfigMap` in the `kube-system` namespace, which is the authoritative source of control plane settings; individual control plane components can be reconfigured using patch files, with the recommended practice of updating one node at a time to maintain cluster availability during reconfiguration.

Standard packages deployed on VKS clusters, such as Harbor, Cert Manager, and Istio, are updated through the VCF CLI using the `vcf package installed update` command, which specifies the installed package name, target version, values file, and namespace, creating a structured and repeatable path for configuration changes to these components. For add-ons, `vcf addon install update` reconfigures an existing add-on with modified configuration parameters, separating configuration values from the deployment mechanism. VM class configurations in vSphere Supervisor are updated through the Data Center CLI command `com vmware vcenter namespacemanagement virtualmachineclasses update`, which allows administrators to modify instance storage volumes and storage policy assignments in a controlled manner. For environments using the Argo CD Supervisor Service, all configuration is managed exclusively through the `argocd.spec` field; direct modification of the underlying `argocd-cm` `ConfigMap` is not permitted, requiring all configuration changes to go through a declared, version-controlled specification rather than ad hoc in-place editing.

Role-based access control across VCF components restricts which users can initiate configuration changes. Many ESX configuration settings require use of specific command-line tools (`configstorecli` or `esxcli`), limiting ad-hoc modification. Audit logging across VCF components records configuration changes for accountability and review. VCF Operations tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when. User permission changes are also tracked to capture when such changes were made and who made them. The `SystemConfiguration.Administrators` group in VCF SSO provides designated administrators the ability to view and manage system configuration through the vCenter Management Interface on port 5480, including viewing and restarting services, while APIs that modify critical system configurations remain restricted even for members of this group. At the Kubernetes layer, all configuration changes processed through the API server are recorded in Kubernetes audit logs; the audit policy governs which API calls are logged and at what verbosity, producing a record of who changed what and when across the Consumption layer, and these logs can be forwarded to external log management or SIEM systems.

VMware vDefend (Contributes)

VMware vDefend provides configuration change control mechanisms within its network security policy domain, contributing to governance of technical configuration changes for firewall rules, IDS/IPS settings, and microsegmentation policies.

Security Services Platform includes a deployment wizard that conducts thorough validations before implementing any configuration changes, verifying that configurations are correct and compatible before they take effect. This pre-deployment validation reduces the risk of misconfigurations that could disrupt network security enforcement or create unintended policy gaps. Security Intelligence extends this with staged policy enforcement, where initial policy recommendations can be deployed while traffic is allowed but monitored. Administrators can verify that recommended rules do not disrupt legitimate operations before enabling full enforcement, providing a controlled transition path for firewall policy changes.

Security Intelligence includes a Monitoring capability that checks for changes in the scope of input entities every hour when enabled. This change detection helps administrators understand when underlying conditions have shifted and policies may need updating. Security Intelligence also tracks the number of new configurations per configuration type on an hourly basis, providing visibility into the rate and scope of policy changes across the security environment.

In multi-site deployments, vDefend enforces a hierarchical configuration model through the Global Manager and Local Manager architecture. In federated environments, the Global Manager centrally manages IDS/IPS signatures, profiles, Distributed Firewall (DFW) and Gateway Firewall (GFW) policies, oversubscription settings, and syslog settings across all mapped Local Managers. Settings configured on a Local Manager remain local to that site and are not propagated to other managers, supporting site-specific change control while preserving global policy consistency.

vDefend provides a draft-based publishing model that gives administrators explicit control over when policy changes take effect. Administrators can create manual drafts of firewall configurations, save them as new configurations or updates to existing ones, and lock them with a required comment before publishing. When a draft is published, vDefend automatically saves an auto draft that captures the configuration state immediately before the publish operation. This auto draft is a rollback mechanism, allowing administrators to restore the previous firewall policy state by republishing it if an applied change produces unintended results. Auto drafts and manual drafts can also be cloned and saved for additional change management flexibility.

vDefend IDS/IPS provides a bulk edit feature for system signatures that includes a Reset action, allowing administrators to restore default signature configurations when changes need to be reversed.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display

messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides technical mechanisms that support configuration change control for managed database infrastructure. System-wide settings are accessible only to DSM administrators through the Settings view in the Provider interface and the Dashboard, which restricts who can initiate configuration changes. This role-based access model limits changes to infrastructure policies, VM class definitions, network settings, and directory service configuration to authorized personnel.

DSM supports controlled change scheduling through its Maintenance Policy, which allows administrators to configure a start date and duration window for applying software updates to DSM appliances and the DSM plug-in. The Maintenance Policy editor is accessible from the Version & Upgrade section under the DSM System tab in both the vSphere Client and the DSM UI. The policy cannot be modified while a Provider Appliance software update is in progress, preventing changes to the update schedule during active operations. For database minor-version upgrades, DSM provides a separate maintenance window setting with a default configuration of six hours beginning each Saturday at 23:59, giving administrators control over when updates are applied to individual database instances.

DSM's Operations tab provides visibility into the progress of database configuration changes as they are applied. System configuration is managed through a `dsmsystemconfig` Custom Resource within the gateway that can be inspected via SSH access to the appliance VM, allowing administrators to review applied settings and verify configuration state.

Certain configurations are intentionally protected from modification after initial deployment. The Management Network for the Provider VM cannot be changed after deployment. Infrastructure policies actively in use by a database cannot have existing settings modified, though new compute resources can be added to them. Policies not currently assigned to any database can have settings changed at any time. Certain MySQL parameters are restricted from user modification by design. System-level settings cannot be modified when applying DSM system settings fails, providing a safety constraint against partial configuration changes.

DSM does not provide a formal change management workflow with approval routing, change ticketing, or mandatory review steps. Satisfying this control fully requires organizations to establish governance procedures that operate alongside DSM's technical controls, including formal change authorization processes, documentation requirements, and post-change verification practices that DSM itself does not enforce.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: `CONFIG_CREATE`, `CONFIG_UPDATE`, and `CONFIG_DELETE`. `CONFIG_UPDATE` events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

Control CC4.1

COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.

SCF Controls: CPL-02.1, CPL-03, CPL-03.2, CPL-04, GOV-05, GOV-05.1, GOV-05.2, IAO-01, IAO-02, IAO-02.1, IAO-02.2, IAO-03.1, IAO-04, IAO-06, PRM-03, PRM-04, PRM-05, PRM-06, RSK-01, RSK-09, SEA-02, TDA-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-

compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should

supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to

identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CC4.2

COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.

SCF Controls: CPL-01.1, CPL-02, GOV-01.1, GOV-01.2, GOV-05, GOV-15.3, IAO-04, IAO-05, RSK-04.1, RSK-06, TDA-15, TPM-09, VPM-02, VPM-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC5.1

COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.

SCF Controls: GOV-08, GOV-15, GOV-15.1, GOV-15.2, HRS-11, OPS-01.1, OPS-02, PRM-01.2, PRM-06, RSK-01, SEA-01, SEA-01.1, SEA-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several centralized management capabilities that support organization-wide implementation of cybersecurity and data protection controls, though it does not constitute a complete governance, risk, and compliance (GRC) platform on its own.

VCF Automation Organizations offer a centralized structure for access control and resource sharing across the platform. Organization administrators can distribute infrastructure and configure access management to groups within their organizations using the organization management functionality in VCF Automation. IT teams and cloud service providers can monitor resource usage, control permissions, and provide managed services through VCF Automation Organizations while maintaining security through network isolation. The Organization Administrator role can create and manage policies centrally, providing a single point of control for security policy definition and enforcement within the VCF environment. VCF Automation also supports role-based access control through group membership and role assignment management in its Access Control interface.

VCF SSO and the VCF Identity Broker provide centralized authentication and identity management across VCF components. The Identity Broker acts as a centralized authentication source, and VCF SSO integrates with it to manage authentication for VCF instance components. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and provides VCF SSO and centralized management of federated access through unified identity configuration. Role-based access control (RBAC) enforces consistent authorization policies across the stack: vCenter allows fine-grained control over authorization with permissions and roles by associating a role to a user or group on objects in the vCenter object hierarchy, and vSAN similarly supports RBAC and permissions management.

For network security management, NSX Manager provides centralized policy and grouping constructs. Security groups are defined and managed through NSX Manager, and in multi-site deployments, global security groups can be created on an NSX global manager and consumed by associated local managers, enabling consistent group definitions across geographically distributed environments. vDefend policies on Tier-0 and Tier-1 gateways are managed centrally from NSX Manager. For distributed firewall enforcement, microsegmentation, and advanced security policy at the vNIC level between workloads, VMware vDefend is a separate product that extends NSX networking; when deployed, its policies are managed from the same NSX Manager interface. PowerShell cmdlets such as `InvokePatchSecurityPolicyForDomain` are available for programmatic creation of security policies, supporting automation of security policy deployment at scale. The VCF distributed switch includes built-in security controls that help protect network traffic, providing baseline security capabilities that are centrally configured through vCenter.

VCF Operations provides continuous monitoring and operational visibility across the environment. Its configuration management capabilities include scheduled drift detection for vCenter and cluster objects, enabling proactive detection of configuration deviations from the desired state. Administrators can view and compare configuration drifts and identify settings that have changed. VCF Log Management provides centralized log aggregation that collects logs from all VCF components, including vCenter, ESX, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. The VCF Log Management cluster is the central point for log collection, aggregation, and analysis for all VCF instances within a given fleet.

VCF Operations is the lifecycle management layer, coordinating configuration and updates across VCF components from a single management plane. It simplifies provisioning new infrastructure, managing passwords, installing certificates, and patching or upgrading infrastructure components.

An auditor evaluating this control should verify that the organization has designated VCF Automation Organizations as the centralized structure for access control and policy management, that VCF SSO and Identity Broker are configured for centralized authentication across all components, that NSX Manager security policies are defined and applied consistently across all workload domains, that VCF Operations drift detection is scheduled and monitored, and that VCF Operations is used as the authoritative source for component lifecycle operations. The auditor should also confirm that these VCF-native capabilities are integrated into the organization's broader cybersecurity governance framework, as VCF addresses the technical control implementation layer but does not replace the need for organizational policies, risk management processes, and compliance monitoring tools.

VMware vDefend (Contributes)

VMware vDefend contributes to centralized management of cybersecurity controls by providing a unified management plane for network security policy across the virtualized data center. vDefend's centralized capabilities span firewall policy, intrusion detection and prevention, malware prevention, and traffic analytics, all managed through a single interface or, for multi-site deployments, through Global Manager.

The vDefend distributed firewall (DFW) allows administrators to define, organize, and enforce microsegmentation policies from a central management plane. Policies are organized into pre-defined categories (Infrastructure, Environment, Application) that provide a logical structure for managing large rule sets. Administrators can create security groups based on VM attributes, IP sets, or dynamic criteria, and apply east-west firewall rules to those groups consistently. When rules are published, they are pushed from the management plane to every host in the targeted clusters, so enforcement is uniform across the environment without requiring per-host configuration. For multi-site or federated deployments, NSX Federation Security provides centralized management of security policies across all sites through Global Manager. Distributed and Gateway Firewall policies created from Global Manager are synchronized to Local Managers at each registered site. Administrators can define custom regions within a federated deployment and assign specific Security and Network policies to those regions, enabling policy scoping at geographic or administrative boundaries.

In 9.1, vDefend extends centralized policy management to VPC-scoped workloads in VCF Automation. Five system-defined security strategies are available for VPC security posture: VPC Isolation, VPC Isolation with essential services, VPC External Connectivity, VPC Secure Connection, and NONE. Project Administrators can select a pre-defined security posture that enforces Secure by Default principles, rather than manually configuring firewall rules for individual VPCs. The Distributed Firewall supports Organizations in VCF Automation for multi-tenant policy isolation, and the Organization Admin (Tenant Admin) role holds full access to manage Transit Gateway firewalls, distributed firewalls, and all VPC gateway firewalls within that tenant context.

Distributed IDS/IPS and Malware Prevention are centrally managed. IDS/IPS profiles and signature sets are configured centrally and distributed to hosts, and Distributed Malware Prevention rules follow the same publish model as firewall policies. In multi-site environments, IDS/IPS signature management is centralized through Global Manager, which distributes updates to multiple Local Managers and supports both automatic update and manual version control.

Security Services Platform provides centralized network security analytics and visibility through Security Intelligence, which analyzes traffic flows across the data center and generates policy recommendations, including recommended security policies and security groups, that administrators can review and publish as Distributed Firewall rules. The platform includes segmentation planning tools that help administrators design and implement microsegmentation strategies from a central vantage point. Security Services Platform also extends centralized policy management to bare metal servers, where security policies are defined, propagated, and enforced through the same centralized model as virtualized workloads.

Role-based access control within vDefend and Security Services Platform governs who can perform security operations. Security Services Platform defines five roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector, each with differentiated permissions for policy publishing, traffic visualization, and configuration changes. Configuration of Distributed Firewall policies requires explicit DFW Manage/View rights and rights for Groups and Services, so access to centralized policy management is controlled at the permission level.

vDefend's centralized management is scoped to network security controls. Organization-wide centralized management of all cybersecurity and data protection processes, including identity management, compute hardening, compliance tracking, and governance, requires the broader VCF platform and external GRC systems.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports separation of duties for replication and disaster recovery operations through role-based access control that augments vCenter roles with PNR-specific permissions. PNR adds several predefined roles to vCenter that are available in the role drop-down for assigning permissions to users and user groups. Each role includes a defined set of privileges that allows users to complete specific actions while restricting access to resources belonging to other users.

By default, the vCenter administrator role inherits all PNR and vSphere Replication privileges upon installation. PNR also supports assigning protection and recovery roles to users or user groups that do not hold vCenter administrator rights, allowing those users to perform protection and recovery operations without granting full vCenter administration. When a user requires privileges for both PNR and vSphere Replication operations without holding vCenter administrator rights, the recommended approach is to add the user to two separate user groups, each assigned the appropriate role, so the combined privileges are explicit and auditable. Users granted the vCenter administrator role after PNR installation must have PNR roles manually assigned on PNR objects, so that elevated platform roles do not automatically convey replication-administration rights to those users.

PNR enforces additional duty separation across the recovery workflow. Testing a recovery plan and running a recovery plan require separate privilege assignment to help prevent unintended changes that take significant time and effort to reverse. PNR administrators can assign `SrmAdministrator` or `SrmProtectionGroupsAdministrator` roles to automatic-protection users or groups, allowing protection responsibilities to be delegated independently of plan execution.

The Clean Room Orchestrator component within PNR adds its own role model with Organization-level roles and service-specific roles. Access to the Clean Room Orchestrator is governed by Global Console Admin and Recovery Admin service roles, separating overall console administration from recovery operations within the isolated recovery environment. Service-specific roles can be assigned to users in addition to Organization-level roles, allowing organizations to delegate clean-room responsibilities without granting broader administrative scope. PNR also applies resource isolation on shared recovery sites to maintain separation between different organizations' virtual machines.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a role-based access control (RBAC) system that organizations can use to implement Separation of Duties across the Avi control and data planes. The Avi for VCF guide identifies role-based separation of duties as a core design principle, enabling application teams to autonomously consume load-balancing services using resources assigned to their organization.

The Avi Controller supports three privilege levels for each resource: Write (full create, read, modify, and delete access), Read (view-only access without modification capability), and No Access (which restricts the user from reading or listing the resource entirely). Administrators can create custom roles that assign these privilege levels independently for each system resource, enabling precise allocation of capabilities to specific personnel without granting broader access than required. Roles are combined with tenant assignments to define the complete authorization profile for each user, making it possible for a team member responsible for virtual service operations to hold write access to load balancing resources while holding no access to certificate management or WAF policy configuration. Permission categories cover two main areas: Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management).

The Extended Granular RBAC system provides additional access scoping through label-based permissions for cloud objects. When no filters are configured, a user can access all objects according to the privileges in the assigned role. Granular RBAC per field allows administrators to restrict write access to specific sub-resources within objects, enabling fine-grained separation of configuration responsibilities. Virtual services also support RBAC configuration during creation, allowing granular access control for managing and monitoring individual applications independently.

In VCF organization-managed mode, a Provider or Load Balancer Administrator manages resource assignments to organizations to enforce quotas and resource boundaries. At the data plane level, Service Engine groups are an inherent method of providing data plane isolation, and Service Engine Group allocation at the project level keeps each project within its designated boundaries. A service provider can allocate isolated Service Engines to each tenant or place multiple tenants in the same group depending on resource sharing requirements.

For Global Server Load Balancing (GSLB), both predefined and custom-defined roles are available. Function-specific roles such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` can be assigned to user accounts with tenant-level scope, allowing separate personnel to manage GSLB group membership configuration independently from health monitoring configuration.

The License Hub implements three distinct roles: Enterprise Admin (performs all operations), Auditor (views information and tracks activity without making changes), and Support Bundle Collector (collects system logs and diagnostics). This structure provides built-in separation of duties between operational and read-only audit functions for licensing management.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) implements RBAC by assigning tenants and roles to user accounts. HealthMonitor resources in AKO are scoped to a specific tenant, and the AKO CRD Operator manages namespace-scoped resources with tenant isolation for multi-tenancy support.

Organizations should identify which duties require separation based on their operational and compliance requirements, then configure Avi roles, tenant assignments, Service Engine group boundaries, and organization-managed mode settings to enforce those separations.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CC5.2

COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.

SCF Controls: AST-01.1, AST-04.2, CFG-03, CPL-01.2, IAC-08, IAC-21, PRM-01, PRM-04, PRM-05, PRM-06, PRM-07, RSK-08, RSK-10, SEA-01, TDA-01, TDA-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of configuration controls that restrict systems to only essential capabilities by controlling ports, protocols, and services across the platform stack.

At the hypervisor layer, VMware ESX hosts include a built-in host firewall that controls which ports and services are accessible. The firewall supports specification of allowed hosts through the `allowedHosts` parameter, so administrators can limit which IP addresses may connect to specific services. Services such as SSH (TSM-SSH) can be individually started or stopped through the VMware Host Client, giving administrators direct control over which management services are running. ESX lockdown mode restricts host access so that all management is performed through VMware vCenter, with an Exception Users list for controlled overrides when direct host access is needed. ESX also supports disabling unexposed features through isolation configuration parameters, removing functionality that is not needed in the environment.

Port groups on distributed switches are communication boundaries where security policies can be configured. Each port group carries its own security policy settings, including controls over promiscuous mode, MAC address changes, and forged transmits. Administrators can modify these policies to restrict which types of network traffic virtual machines are permitted to generate or receive. Each port group can also be assigned a VLAN ID to restrict traffic to a logical Ethernet segment. SpoofGuard and switch security profiles can be applied to distributed port groups to prevent traffic spoofing and enforce network security policies at the virtual switch layer. Distributed port groups also support Port Blocking Policies, which allow administrators to selectively block ports from sending or receiving data, including blocking all ports within a group simultaneously. Traffic Filtering and Marking Policy can be applied at the individual distributed port or uplink port level to permit or stop traffic flows through virtual machines, VMkernel adapters, and physical adapters. Port-level configuration overrides on distributed virtual switches are deactivated by default, so permitting per-port policy exceptions requires deliberate administrator action. The virtual serial port proxy provides an additional gateway that enforces security for remote serial port connections, restricting access to only authorized communication paths.

Management traffic is isolated on dedicated networks. The Fleet Level Components on Dedicated Management Network model uses VLAN-backed distributed port groups to provide isolation from other networks. NSX allows configuration of services with port and protocol pairing, and these services can be referenced in firewall rules to allow or block specific types of traffic.

The platform documents explicit port requirements for each component. When vSAN is enabled on a cluster, required ports are added to ESX firewall rules and configured automatically, keeping firewall configuration aligned with actual service requirements rather than leaving unnecessary ports open. VCF Operations Cloud Proxy requires only ports 4505, 4506, and 8443 via TCP for application monitoring, establishing a minimal set of allowed network communication paths. These defined port lists give administrators a clear baseline of what must be open rather than relying on permissive defaults.

VCF Operations supports firewall hardening, which when activated restricts network access to internal services, limiting exposure to only the ports and protocols required for operation. A service discovery policy setting controls whether the system actively discovers services on the network; disabling this policy reduces the attack surface by preventing unnecessary service enumeration, though administrators should be aware that turning it off changes the security posture of the operating system. For orchestration functions, VCF Operations enforces privilege requirements where ports below 1024 can only be opened with superuser privileges on Linux systems, providing an inherent restriction on which processes can bind to well-known service ports. VCF Operations also collects ESX security properties including service running status, firewall rulesets,

service policies, and disabled protocols when the vSphere Hardening Guide policy is applied, giving administrators visibility into the least-functionality posture of each host.

The Security Configuration Guide provides recommendations for disabling unnecessary services and enabling security features on ESX hosts as a baseline for least-functionality configuration.

At the workload consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor enforce least functionality across compute, kernel, and network dimensions for containerized workloads. Pod Security Admission (PSA), enabled by default in Supervisor clusters running VKS 1.25 and later, enforces Kubernetes Pod Security Standards at the namespace level. Administrators configure each namespace with an enforcement profile from three options: Privileged (no restrictions), Baseline (blocks known privilege escalation paths), and Restricted (heavily restricted, following pod hardening practices). Each profile supports three independent modes: enforce (rejects non-compliant pods at admission), audit (records violations in the audit log without blocking), and warn (surfaces policy warnings to the requesting user without blocking), allowing operators to gain visibility into policy gaps before tightening enforcement. The Restricted PSA level requires containers to drop all Linux capabilities, blocks host networking, host PID, and host IPC namespaces, restricts volume types to a safe subset, disallows privilege escalation by setting `allowPrivilegeEscalation` to false, and requires a defined Seccomp profile. Supervisor applies the `vmware-system-restricted` Pod Security Policy by default to VKS clusters, which blocks privileged container access, helps prevent root escalation, and restricts permitted volume types; standard packages such as Contour also reference this policy so that system components operate under the same restricted constraints. VKS Cluster Management Security Policies provide an additional management layer for pod security within VKS clusters; when creating a security policy, the Restricted pod security policy template offers a preconfigured tight security context that constrains pod privileges and capabilities across the cluster.

Kubernetes pod and container security context configuration allows administrators to add or drop specific POSIX kernel capabilities through the `securityContext.capabilities` field, restricting which kernel operations individual containers may exercise. Pods can be configured with Seccomp profiles that filter the system calls available to containers; the `RuntimeDefault` profile applies the container runtime's default system call filter and blocks calls not required by typical applications, while custom profiles allow more precise control. The Restricted Pod Security Standard makes a defined Seccomp profile mandatory for compliant workloads. Supervisor also supports SELinux, which restricts access to files, applications, ports, and processes through labels and security policies enforced on tagged processes, and AppArmor profiles that restrict a container's abilities by enforcing a defined set of rules and restrictions on process behavior at the kernel level. On Ubuntu and Photon nodes in VKS clusters, AppArmor additionally controls file system access and network access, extending mandatory access control across multiple resource dimensions beyond process behavior alone. These mechanisms operate independently of Kubernetes admission controls and provide a defense-in-depth layer for workload capability restriction. Kubernetes ephemeral containers disallow ports, `livenessProbe`, and `readinessProbe` fields, further restricting their capabilities relative to standard containers.

Network-level least functionality for VKS workloads is enforced through Kubernetes `NetworkPolicy` objects, implemented by Antrea or NSX-based CNI plugins in Supervisor, which restrict ingress and egress traffic at the pod and namespace level by port, protocol, and peer selector. Cluster administrators can restrict the IP address ranges allowed for Kubernetes Services through centralized management of `ServiceCIDR` resources, reducing the scope of reachable service endpoints across the cluster. Access to control plane ports such as the etcd API port should be restricted at the network level to only specified and trusted IP address ranges. VKS control plane nodes enforce a set of default inbound firewall rules that administrators cannot override, covering only the ports required for control plane operation, including TCP 6443 for the kube-apiserver, TCP 2379-2380 for etcd, TCP 22 for SSH, TCP 179 for BGP, and TCP 10100 for the kapp-controller, among others. The kubelet `allow-privileged` flag controls whether privileged containers are permitted on cluster nodes. The Istio CNI plugin, configurable through the `istioCNI.enabled` setting, manages pod network interfaces and enforces network policies without requiring privileged containers, reducing the need for elevated privileges in service mesh deployments. Kubernetes guidance documented in Supervisor materials states that access control components operating with high privileges should be isolated from general workloads using namespace boundaries, so that privilege is scoped to where it is operationally required.

VCF Automation provides security groups that define isolation settings for on-demand private or outbound networks, allowing administrators to restrict which services and ports are accessible within network segments. Network profiles support isolation

policies defined as either on-demand or existing security groups, enabling granular control over network communication boundaries.

For ongoing compliance verification, VCF Network Operations provides a search query capability to identify firewall rules that permit any port, querying for rules where the action is set to allow and the service is configured as "any." This allows administrators to systematically find and remediate overly permissive rules that violate least-functionality principles, restricting access to only the ports and protocols that are explicitly required.

VMware vDefend (Meets)

VMware vDefend provides the primary enforcement mechanism for least functionality at the network layer, allowing administrators to configure systems so that only essential ports, protocols, and services are permitted.

vDefend (DFW) operates per workload and supports Allow, Drop, or Reject actions on traffic matching defined services with specific port and protocol pairings. Administrators build policies that permit only the traffic required for a workload's function while denying everything else. DFW policies can explicitly block insecure protocols such as Telnet, FTP, and TFTP across the data center, actively blocking protocols that should not be present in the environment. DFW governance implements a least-privilege posture by preventing overly permissive rules such as "ANY/ANY/ANY ALLOW," guiding administrators toward specific port and protocol restrictions rather than broad allow policies. Rules are processed in precedence order across multiple policy sections, giving administrators fine-grained control over which traffic categories are evaluated first.

vDefend extends least-functionality enforcement to inter-project and perimeter boundaries. Gateway Firewall rules support configurable service selection, allowing administrators to specify a blanket block on all protocols or access restricted to specific ports for selective inter-project communication. Enterprise administrators can configure inter-project isolation policies that allow only essential infrastructure protocols while denying all other inter-project communication, defining perimeter-level traffic boundaries based on what each segment actually requires.

Security Intelligence, part of the Security Services Platform, provides traffic flow analysis with protocol and port filtering. Administrators can analyze observed flows using Exclude or Match criteria, supporting up to 15 entries of single ports, port ranges, or protocols. This visibility helps administrators verify that only essential ports and protocols carry traffic and identify unexpected communication patterns that may indicate unnecessary services remain enabled. Security Intelligence also provides guidance on restricting risky application protocols that transport data in clear text, flagging these for restriction or replacement as part of the overall least-functionality posture.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting

organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to the Least Functionality control through its infrastructure policy framework and data service policy allowlists, which restrict what network resources, compute configurations, and service parameters are available to database consumers.

Infrastructure policies are the primary mechanism. Each infrastructure policy requires the selection of specific network port groups for each compute resource (network-port-group setting), and at least one IP pool must be defined for each selected port group (ip-pools setting). This constrains which network segments database instances can attach to, restricting consumers from selecting arbitrary network endpoints. Infrastructure policies must be explicitly enabled before they become available for database provisioning; policies that are not yet ready for use can be kept deactivated (infrastructure-policy-enabled setting), which limits which network configurations are offered to consumers at any given time. DSM also validates infrastructure policy IP ranges against system configuration networks, detecting and rejecting overlapping configurations before they take effect.

Data service policies build on infrastructure policies to create a tiered allowlisting mechanism. Each data service policy requires the selection of at least one infrastructure policy, and in the self-service consumption model, the DataServicePolicy custom resource's allowedInfrastructurePolicies field enumerates precisely which infrastructure policies authorized consumers may use. Database users cannot select infrastructure configurations outside the approved set defined by administrators. Infrastructure policies also filter storage policies to display only those compatible with the designated compute resources, further narrowing the options available at provisioning time.

Infrastructure policies create broader resource guardrails as well: the overall policy framework restricts the quality and quantity of resources DSM users can consume from vSphere clusters, and database clusters are deployed with infrastructure and storage policies that enforce isolation and resource constraints from the moment they are provisioned.

Data service policies support an "Allow with a List" option, which creates a specific allowlist of approved parameters that users can select from during provisioning. SQL Server data service policies extend this pattern: they require selection of at least one infrastructure policy and restrict instance provisioning and server-level configuration, including Active Directory integration and high availability settings, to administrators only.

For PostgreSQL databases, DSM provides an additional connection control capability. The Block Database Connections operation can stop existing client connections and block new ones from being established, with exemptions only for monitoring, replication, and internal service traffic. This allows administrators to restrict access to a database instance to only the services required for continued operation.

DSM's contribution to this control is scoped to the database-as-a-service layer. Restrictions on ports, protocols, and services at the network perimeter, host, or hypervisor level depend on the underlying VCF platform, NSX networking configuration, and vDefend firewall policies outside DSM's direct control. Organizations should complement DSM's policy framework with platform-level network security controls to fully address the Least Functionality requirement.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides mechanisms for restricting ports, protocols, and services at the application delivery layer, supporting least-functionality configurations for application traffic and management access.

At the application traffic layer, each virtual service accepts traffic only on explicitly configured service ports. The per-Service-Port profile configuration (ApplicationProfile or NetworkProfile) can be overridden on a per-service-port basis for advanced use cases. Virtual Service Network Security Policies can match on service port to filter traffic based on TCP service ports on which the virtual service is listening, allowing administrators to explicitly permit or block traffic by protocol and port on a per-virtual-service basis.

For Controller management access, Avi provides several mechanisms to restrict access to management channels. The Client Management Access configuration allows administrators to define allowed SSH clients, allowed CLI shell clients, allowed external HTTP(S) clients, and allowed external SNMP clients separately, each scoped to specific IP addresses, ranges, subnets, or IP groups. Management channels not included in the configured allowlist are blocked. This configuration is accessible through the Securing Management IP Access workflow in the Controller UI under System settings. Trusted host profiles can be configured to restrict which hosts are permitted to access the Controller, providing an additional layer of host-identity-based access restriction. The Controller also limits the allowed ciphers and HMACs for management sessions, reducing the cryptographic surface exposed on each management channel.

Security groups for Avi Controller and Service Engines specify the protocol ports for which traffic is permitted between components, providing a defined port inventory that administrators use to scope surrounding network controls.

These capabilities apply at the application delivery boundary. Least-functionality controls for the underlying compute, storage, and network virtualization layers are provided by VCF, which is rated Meets for this control.

Control CC5.3

COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.

SCF Controls: AAT-13.1, GOV-02, GOV-03, GOV-04, GOV-04.1, GOV-05, GOV-14, HRS-03, HRS-03.2, HRS-10, OPS-01.1, OPS-03, RSK-06, VPM-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC6.1

The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.

SCF Controls: AST-01, AST-02, AST-04.1, CFG-02, CFG-03, CLD-01, CLD-11, CRY-01, CRY-03, CRY-04, CRY-05, CRY-08, CRY-09, CRY-09.1, CRY-09.2, CRY-09.3, CRY-09.4, DCH-02, IAC-01, IAC-01.2, IAC-02, IAC-03, IAC-04, IAC-05, IAC-08, IAC-09, IAC-09.1, IAC-10, IAC-10.8, IAC-15, IAC-16, IAC-20, IAC-20.1, IAC-21, IAO-01, IAO-02, IAO-07, NET-01, NET-01.1, NET-03, NET-03.1, NET-04, NET-05.1, NET-06, NET-06.1, NET-14.3, PRI-01.6, PRI-05.1, SEA-01, SEA-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcidentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Meets)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces logical access control through a privilege-based authorization model. A privilege in PNR is the right to perform a specific action, such as creating a recovery plan or modifying a protection group. PNR restricts login access to VMware vCenter administrators by default, and other users must be explicitly granted access by an administrator before they can perform any protection or recovery operations. PNR augments vCenter roles and permissions with additional privileges that allow detailed control over PNR-specific tasks and operations.

PNR roles follow least privilege through granular role assignment. The vSphere Replication predefined roles can be cloned and customized by adding or removing individual privileges, allowing administrators to create custom roles that grant only the minimum permissions needed for a specific function. The Propagate to Children option can be deselected to create permission hierarchies that override inherited permissions at specific nodes without affecting child object permissions. vSphere Replication enforces permission denial with an error message when users without appropriate privileges attempt restricted operations. PNR roles do not include vSphere Replication privileges, so a user who is not a vCenter administrator but requires both PNR and vSphere Replication operations should be added to two separate user groups rather than granted full vCenter administrator privilege.

For cross-site operations, PNR enforces dual-site authorization. PNR requires permissions on both vCenter objects and on PNR objects to function properly, and PNR verifies permissions on the remote vCenter instance as part of its access control validation. Removing a user's permission on a protected site stops that user from continuing operations on resources at that site. In shared recovery site configurations, the vCenter administrator must manage permissions so that each user has sufficient privileges to configure and use PNR while no user has access to resources belonging to other organizations. PNR restricts users in shared recovery site configurations from renaming, moving, or deleting data centers or hosts.

For automatic protection of virtual machines, administrators can assign the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group rather than granting global vCenter administrator privilege. The PNR clean room Orchestrator restricts connections to only IP addresses or IP address ranges that have been added to a configured management access list, providing network-layer access enforcement on top of the role-based model. For PNR deployed with VCF Automation, access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users. Provider Administrators select which replication classes each Organization can use, and Organization Administrators manage the pairing of namespaces and assignment of replication classes within their Organization.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) enforces logical access control through a two-tier role-based access control model at the platform level, combined with database-native privilege controls within provisioned database services.

At the platform level, DSM defines two roles: the DSM Admin role and the DSM User role. Administrators hold full visibility and management authority over all data services in the environment, while users assigned the DSM User role are restricted to viewing and managing only the objects they own. The DSM console enforces this separation by restricting the views and actions available to each role, so users cannot see or interact with objects outside their assigned scope. Role assignments and user management are configured through the vSphere Client Permissions interface under the Data Services Manager Configure tab.

Namespace-based scoping provides an additional layer of least-privilege enforcement. DSM User role assignments can be scoped to one or more specific namespaces, restricting a user's access to only the namespaces they are explicitly assigned, and DSM Users can view only the namespaces to which they have been granted access. Namespaces control database creation permissions such that only users associated with a given namespace can create databases within it. Namespaces that are externally managed through VCF Automation are treated as read-only within DSM. Only users with appropriate DSM permissions can configure infrastructure policies, keeping resource configuration authority separate from general data service access.

DSM supports both local users and LDAP-based directory service users. Local users are created through the DSM UI with role assignments that control namespace access. For LDAP environments, roles can be assigned to Directory Service Groups, enabling group-based access control. The DSM Admin role, when assigned to a Directory Service Group, grants super-user

permissions to all members of that group. This allows organizations to manage platform access through existing directory group structures.

Within provisioned databases, access enforcement is applied at the database engine level. PostgreSQL databases support the GRANT command to assign privileges on specific databases and schemas to individual database users; LDAPS-authenticated users require explicit grants for the databases and schemas they are authorized to access. MySQL databases require explicit privilege grants to LDAPS-authenticated users via the GRANT command to control database access, and DSM assigns operating privileges to the default database user while revoking create and update privileges on the mysql.system schema, limiting user access to system-level objects. For SQL Server databases, DSM grants the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. DSM's internal dsm_mgmt management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context. User-defined DDL triggers that execute during DSM management operations are confined to a database-level security context, blocking access to the server-level permissions held by the internal management account.

The DSM service account that communicates with VMware vCenter is required to hold only the specific vCenter permissions necessary for its operations, including service account creation, plug-in registration, and resource management. Administrators can verify and update these credentials through Settings > System Settings under Target vCenter. DSM clears the vCenter administrator credentials secret from storage after successful registration, reducing the exposure window for those credentials. A global alert is raised if the service account lacks the required permissions, supporting ongoing privilege verification.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi

Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Control CC6.2

Prior to issuing system credentials and granting system access, the entity registers and authorizes

SCF Controls: HRS-08, HRS-09, IAC-07, IAC-07.1, IAC-15.3, IAC-15.7, IAC-17, IAC-28.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support formal user registration and de-registration processes, though the organizational policies, approval workflows, and periodic entitlement reviews that govern these processes must be established separately.

VCF SSO is the centralized authentication and identity service, supporting multiple user provisioning methods. Organizations can choose between Just-In-Time (JIT) provisioning, where user accounts are dynamically created upon first login from a configured identity provider, and Groups Pre-provisioning, where users and groups are synchronized from a directory source in advance. JIT provisioning requires no additional configuration beyond the identity provider setup, and can also handle group membership with options for either pre-provisioned groups or just-in-time group creation. For directory-based provisioning, VCF supports syncing users directly from groups, including nested group synchronization that imports all users from a selected group and its child groups. Active Directory or LDAP integration provisions users and groups from the enterprise directory. VMware vCenter Identity Provider Federation also supports external OIDC providers, including Okta and PingFederate. When configured with PingFederate, the integration requires a SCIM 2 application and supports User Create, User Update, and User Disable/Delete operations by default, providing a direct mapping to the provisioning and de-provisioning lifecycle this control describes. After initial identity provider configuration, administrators log in to each component with the local admin account and assign the necessary service roles to provisioned users and groups. This two-step process, where accounts are first provisioned through VCF SSO and then granted specific roles, enforces a structured approach to access rights assignment.

VCF Operations provides centralized management of identity provider configuration and user and group provisioning across VCF instances. It supports importing user accounts from external authorization sources such as LDAP databases or SSO servers through the Access Control interface. Imported users and groups receive role-based access control permissions that govern what objects and interface areas they can access. Access groups define granular rights including the ability to add, edit, or delete dashboards, or to view, configure, or manage objects. User groups can be created manually, imported from a single sign-on server, or imported from an LDAP database. VCF Operations user accounts can also be disabled through the Access Control interface to deactivate a user.

VCF Automation includes an Access Control service that supports identity operations for managing groups and users. System Administrators can create other system administrator and user accounts in the provider organization. Organization Administrators can view role rights or create roles local to their organization. VCF Automation supports cloning of rights bundles and global roles, with the ability to modify selected rights for the cloned role. This allows administrators to build custom access configurations tailored to specific provisioning requirements. User accounts in VCF Automation can have their name, password, and role assignments edited through the Access Control interface. Provider administrators can create projects, assign users and groups, and allocate quotas to restrict available configurations. When OIDC is configured as the identity provider, imported users authenticate with the credentials established in the external identity provider.

For de-provisioning, VCF provides several mechanisms across its components. VCF Automation supports explicit user account deactivation: disabling a user does not remove them from the organization, allowing reactivation if needed later. Before a user can be deleted in VCF Automation, their access must be disabled first, enforcing a controlled removal process. VCF Operations user accounts can similarly be disabled through the Access Control interface. When the identity provider configuration is reset or deregistered in VCF SSO, the provisioned users and groups are removed, and service roles must be reassigned after reconfiguration. Deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes the provisioned users and groups.

In NSX, user accounts must be created and activated before any role assignments can be made. VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

At the Consumption layer, VMware Kubernetes Service (VKS) clusters within vSphere Supervisor enforce a Kubernetes-native access control model that ties permission assignment to explicitly defined RBAC objects and an authoritative identity source. DevOps users and groups to whom Kubernetes permissions are assigned must exist in the configured identity source integrated with VCF SSO, so that removing a user from the identity source revokes their ability to authenticate to VKS clusters. VKS cluster provisioning requires that cluster users and roles be defined as part of the cluster lifecycle, establishing a registration step before access rights can be granted. Access rights are assigned by creating RoleBindings or ClusterRoleBindings that associate a Role or ClusterRole with a specific user or group identity. These bindings name specific identity source principals and can be audited against the identity source to detect orphaned bindings where the referenced identity has been removed but the binding remains. Kubernetes documentation requires that user account creation prevent reuse of deleted user names, so that a newly provisioned account with the same name does not silently inherit the RoleBindings of its predecessor. VKS separates ServiceAccounts used by workloads from human user accounts, allowing different provisioning and de-provisioning procedures to be applied to each class of identity. IAM role trust policies for service accounts should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level. For administrators, the Kubernetes documentation recommends creating a least-privilege kubeconfig for routine work and reserving elevated permissions for break-glass access only.

The Argo CD Supervisor Service, when deployed, enforces its own RBAC layer through policy rules and group mappings. Local accounts can be defined in the localAccounts configuration and granted roles through RBAC policy rules and group assignments. Argo CD also supports OIDC authentication with global RBAC policies for federated identity scenarios. Cluster registration for Argo CD creates ClusterRole and ClusterRoleBinding objects that explicitly associate service account identities with their permitted cluster-wide scope. The Secret Store Supervisor Service similarly enforces RBAC for administrators, DevOps engineers, and application tenants, maintaining role-based separation within the Supervisor Services layer.

Across all components, VCF enforces a privilege model where fine-grained access controls are grouped into roles, which are then mapped to users or groups. Each VCF component, including VMware vCenter, VCF Operations, and VCF Automation, enforces permissions based on assigned roles, so provisioning a user account is distinct from granting specific access rights. Administrative operations in VCF Operations require a user with the ADMIN role, maintaining role-based separation.

VCF contributes the technical enforcement layer for user provisioning and de-provisioning. The formal registration process, approval workflows, and periodic entitlement reviews that this control requires are organizational responsibilities outside VCF's scope.

VMware Private AI Services (PAIS) integrates with an external OIDC provider for user authentication, configured through the PAIS activation process on an organization namespace with the issuer URL, client ID, and OIDC scopes. Identity and access management for PAIS is set up in coordination with the OIDC provider administrator, making the external OIDC directory the authoritative source of user identities for PAIS. The oidc-authorized-groups, oidc-groups-claim, and oidc-extra-audiences settings on the organization namespace configure which OIDC groups are accepted, which claim carries group membership, and which additional OAuth 2.0 audiences PAIS will accept when validating the Access Token.

Access to PAIS is gated on OIDC group membership through the authorizedGroups configuration. Only user accounts that belong to one or more of the specified authorized groups (such as group-for-pais-access-01 or group-for-pais-access-02) can access the service. The OIDC configuration includes a groups scope that surfaces group membership in the Access Token, so PAIS enforces the authorization decision at service access time based on current group membership in the external directory. Removing a user from an authorized OIDC group at the provider revokes that user's access to PAIS at the next token issuance.

Within the PAIS platform, organization administrators control which users can perform privileged operations. An organization administrator account is required to activate PAIS in an organization namespace in VCF Automation. A user must be added to a project and namespace in the VCF Automation All Apps organization before that user can provision GPU-accelerated VMware Kubernetes Service (VKS) clusters or request Deep Learning VM and AI catalog items. Catalog item visibility in VCF

Automation is scoped to project membership, restricting which users can request AI workloads from the Private AI Services Quickstart blueprints.

For the model gallery and image registry, a Harbor robot account is created for the project allocated to the model gallery, providing a non-interactive credential that is separate from end-user identities and can be rotated or removed independently. Personal access tokens generated from a user's account settings provide programmatic access to PAIS Knowledge Bases and linked data sources, allowing tokens to be issued, scoped, and revoked separately from the user's interactive sessions.

VMware vDefend (Contributes)

VMware vDefend contributes narrowly to this control by supporting role-based access control within its own management plane, where administrators can update or remove role assignments for Security Services Platform users when personnel roles change. The Security Services Platform (SSP) implements five defined roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Security Intelligence, a component within SSP, applies the same five-role model. Accessing User Management to modify or revoke role assignments requires Enterprise Admin privileges.

SSP role assignments can be applied to individual remote users or to remote user groups through mapping to groups in external identity providers, including Active Directory and LDAP-based directories. When organizational group membership is updated to reflect a personnel role change, the change propagates to vDefend access controls through the group mapping. The Enterprise Admin role holds full access to configure authentication and authorization, making it the role responsible for executing access revocation within the vDefend management plane.

Broader organizational access revocation following role changes across VCF, VMware vCenter, and other systems is handled through VCF SSO and enterprise identity lifecycle processes, which are outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) 9.1 provides structured user provisioning and de-provisioning capabilities that support a formal access rights lifecycle for both local accounts and directory-integrated users.

User accounts in DSM are managed through two identity sources: local users created and managed within the DSM platform itself, and LDAP/LDAPS users authenticated through an enterprise directory service such as Active Directory. DSM can be configured to use one or both identity sources independently. The first local user account is the DSM administrator, created during deployment of the DSM Provider Appliance. That account is mandatory and cannot be deleted. All subsequent local user creation requires administrator credentials, meaning only authorized personnel can add new accounts to the system.

When provisioning a local user, an administrator must specify the user's role, email address, and password through the DSM user creation workflow, accessible in the vSphere Client or the DSM UI. DSM's two built-in roles define the access scope: the Administrator role manages the platform, namespaces, and other users, while the User role creates and maintains individual databases. Namespace access is assigned at user creation. Administrators can modify both role assignments and namespace access for existing local users through the user management interface. Administrators can delete local user accounts when removal is the appropriate de-provisioning action. Alternatively, to prohibit a user's access to DSM while keeping databases running, an administrator can reset the user's password and delegate database management to a different user.

For directory-integrated environments, DSM supports LDAPS authentication and allows assignment of roles to Directory Service Groups, enabling group-based access control for LDAP users. When a user's directory group membership changes, their effective access within DSM reflects the group role assignment.

For SQL Server databases provisioned within VCF Automation, DSM data service policies define the allowed user types for databases created under the policy. Administrators can configure policies to permit Windows Principal authentication using Active Directory credentials, SQL User authentication using standard SQL Server login credentials, or both. For automated Active Directory integration, DSM requires a privileged Active Directory account with permissions to write service principal names (SPNs) and perform dynamic DNS updates. SQL Server databases map the dbo user, the database object owner, to administrator-controlled identities.

The Permissions view in the DSM dashboard provides a consolidated interface for creating, monitoring, and managing all configured user accounts and directory service groups. Because user login precedence between local and LDAPS accounts must be managed deliberately to avoid authentication conflicts, organizations should establish clear provisioning procedures that address the ordering and priority rules DSM applies.

DSM's mechanisms support the technical registration and de-registration workflow but do not themselves constitute a formal process. The control's requirement for governance-level procedures governing access rights assignment extends to organizational approval workflows, access review cycles, and documented registration practices that operate outside the platform. Organizations must establish these processes independently, using DSM's user management capabilities as the technical enforcement layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a native user management system accessible through Administration > Accounts > Users on the Avi Controller. Administrators can create local user accounts, assign each account a specific role and tenant scope, and remove accounts when access is no longer required. Each user account stores role and tenant assignments directly, supporting granular scoping of permissions per deployment.

Avi's RBAC model supports both local user accounts validated against an internal database and remote authentication through LDAP or SAML. Auth Mapping Profiles extend the RBAC model by binding external directory group membership to specific Avi roles and tenants at login time. When a user's group membership changes in the directory, the Auth Mapping Profile applies the updated role and tenant assignments on the next login, without requiring manual changes inside Avi. Multiple Auth Mapping Profile rules can be configured so that a single user's LDAP or SAML group memberships determine distinct roles across multiple tenants simultaneously. SAML integration with Microsoft Active Directory Federation Services (ADFS) is also supported, with configurable issuance authorization rules that control which users may access the relying party.

Avi Controller allows creation of custom roles according to specific access requirements when predefined roles do not fit an account's needs. The Tenant-Admin role can be scoped so that tenant administrators can create, update, and delete cloud infrastructure within their tenant boundary without affecting other tenants. Avi GSLB extends user provisioning to global load balancing by supporting the creation of non-admin users with assigned roles for granular access control across GSLB deployments. The Avi License Hub also supports role-based access control by assigning roles to individual users or groups defined in an external identity provider.

User accounts are attached by default to the Default-User-Account-Profile, and administrators can create new user account profiles with different concurrent session thresholds to meet organizational security requirements.

Organizations should establish and document formal procedures for user registration, access approval, and de-registration to govern how and when accounts are created or removed in Avi. The technical mechanisms Avi provides, including account creation and deletion, role assignment, and directory integration via Auth Mapping Profiles, support a formal lifecycle process but do not replace the organizational procedures the control requires.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CC6.3

The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.

SCF Controls: IAC-07, IAC-07.1, IAC-08, IAC-17, IAC-28.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides granular role-based access control (RBAC) mechanisms across VMware vCenter, VCF Automation, and VCF Operations that allow administrators to modify, revoke, and remove user access rights when personnel roles and duties change. Each component offers role management functions that support access adjustment in response to organizational changes.

In vCenter, roles are predefined sets of privileges that can be assigned to users or groups and associated with inventory objects. Only System Administrators can modify the rights in a predefined role. The AuthorizationManager includes a RemoveAuthorizationRole method that allows administrators to programmatically remove roles from the system, supporting automation of access revocation workflows when integrated with identity governance processes. Role assignments on vCenter objects can be modified or removed through both the UI and the API. The vCenter REST API also includes a dedicated Roles API with methods to list, create, update, and delete roles and to manage both global and local permissions.

The VMware Host Client provides role management at the VMware ESX host level, where editing a role's privileges automatically applies the changes to all users and groups assigned that role. Shell access for individual ESX users can also be deactivated, which prevents those users from granting shell access to other users or changing the passwords of users with existing shell access.

VCF Automation provides a layered role management model. System Administrators can create, edit, and delete global roles and publish or unpublish them across organizations. When a role is unpublished from an organization, it is removed from that organization and can no longer be assigned to users there. Organization users can use only those rights from their roles that are published to their organizations, so unpublishing a role or its associated rights immediately restricts what affected users can do. When the rights of a role are modified, the new set of rights is applied to all users assigned that role, allowing bulk access changes when duties shift across a team or department. Organization administrators can also create and edit organization-specific roles that are local to their organizations, providing fine-grained control at the organizational level. Roles assigned to users imported into VCF Automation can be edited at any time to adjust access control as needed.

VCF Automation supports disabling individual user accounts without removing the user from the organization. A deactivated user cannot log in, but the account remains available for reactivation if the person moves to a new role that requires access. Provider users can also be deactivated through the Access Control interface, after which the user cannot log in to VCF Automation. System administrators can revoke access tokens of users through the Administration access control settings, manage service account attributes, revoke previously granted access, and delete service accounts when access is no longer needed. The accessControls API enables programmatic modification and removal of specific ACLs.

For more granular control, VCF Automation supports defined entity access control with View (read-only), Edit (create, view, modify), and Full Control (create, view, modify, delete) permission levels that can be assigned to specific user roles. These defined entity rights work only in combination with an ACL entry, providing layered access restriction.

VCF Operations supports role management operations including editing, deleting, cloning, and exporting user roles. Administrators can create custom roles in addition to predefined roles, and each role's permissions can be modified through the Role Information page using a role tree with selectable permissions. Imported user groups can be edited to reassign Roles and Scopes, which supports adjusting access for groups of users when organizational changes occur. User accounts in VCF

Operations can be disabled by selecting a check box to deactivate the user. The administrators role should be assigned only to specific users who must access objects and perform actions across the entire environment.

When VCF is federated with an enterprise identity provider or directory service, changes to group memberships in the directory are reflected in VCF access. LDAP-based directory services such as Active Directory are supported for identity management. VCF Automation supports importing provider groups from LDAP, SAML, or OIDC identity providers. Removing a user from a directory group that maps to a VCF role effectively revokes that access without requiring manual intervention in VCF itself.

The VCF Consumption layer, which covers VMware Kubernetes Service (VKS) clusters and vSphere namespaces, extends these access control mechanisms into the Kubernetes workload plane. Each vSphere Namespace has role-based access control configured to govern user and service account permissions. VKS clusters use the Kubernetes RBAC model, where Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings define what actions identities can perform against Kubernetes API resources. Access follows a defined role hierarchy: DevOps and Platform Operator roles are assigned as non-admin or custom roles scoped to ServiceProviderUsers and authenticated through VCF SSO or Active Directory, while developer roles are scoped to read-only or no access. When personnel duties change, an administrator removes or modifies the relevant RoleBinding; changes take effect immediately upon the next API request. The Kubernetes RBAC API enforces an immutable roleRef field on RoleBindings and ClusterRoleBindings after creation, so changing the role that a binding references requires deleting and recreating the binding object, making the full set of subjects and their intended permissions explicit during each change. Users should not be added to the system:masters group, because members bypass all RBAC checks and gain unrestricted superuser access that cannot be revoked by removing RoleBindings. IAM role trust policies for service accounts should be scoped to specific service accounts and namespaces to enforce least privilege. Among Supervisor Services, Harbor Registry enforces role-based access control over access to container artifacts, the Secret Store Service uses RBAC to separate administrator, DevOps engineer, and application tenant permissions, and Argo CD implements RBAC through policy rules and group mappings with Casbin syntax that allow role assignments to be updated when job duties change within a GitOps workflow.

VCF contributes the technical mechanisms for adjusting and revoking access rights across all of its components, including the Consumption layer. The organizational process of detecting when role and duty changes occur, determining which access rights are no longer necessary, and initiating the appropriate access modifications remains outside VCF's scope. Organizations should integrate VCF's role management capabilities with their identity governance and human resources processes to trigger timely access reviews and revocations when personnel transitions occur.

VMware vDefend (Contributes)

VMware vDefend contributes narrowly to this control by supporting role-based access control within its own management plane, where administrators can update or remove role assignments for Security Services Platform users when personnel roles change. The Security Services Platform (SSP) implements five defined roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Security Intelligence, a component within SSP, applies the same five-role model. Accessing User Management to modify or revoke role assignments requires Enterprise Admin privileges.

SSP role assignments can be applied to individual remote users or to remote user groups through mapping to groups in external identity providers, including Active Directory and LDAP-based directories. When organizational group membership is updated to reflect a personnel role change, the change propagates to vDefend access controls through the group mapping. The Enterprise Admin role holds full access to configure authentication and authorization, making it the role responsible for executing access revocation within the vDefend management plane.

Broader organizational access revocation following role changes across VCF, VMware vCenter, and other systems is handled through VCF SSO and enterprise identity lifecycle processes, which are outside vDefend's scope.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM

Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control CC6.4

The entity restricts physical access to facilities and protected information assets (for example, data center facilities, backup media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.

SCF Controls: AST-10, HRS-09.1, PES-01, PES-02, PES-02.1, PES-03, PES-03.3, PES-05, PES-06.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CC6.5

The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.

SCF Controls: AST-09, DCH-01, DCH-08, DCH-09, DCH-21, PRI-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support secure logical disposal and sanitization of virtual resources, though the physical destruction or secure disposal of hardware remains an organizational responsibility outside VCF's scope.

vSAN data-at-rest encryption uses a two-tier key architecture with Key Encryption Keys (KEK) and Data Encryption Keys (DEK), managed through an external Key Management Server (KMS) or vSphere Native Key Provider. When decommissioning encrypted storage, destroying the encryption keys renders the data unrecoverable without requiring a full disk wipe, a technique known as cryptographic erasure. vSAN also provides an "Erase disks before use" option during encryption configuration that wipes existing data from storage devices. For devices being added to or removed from vSAN disk groups, residual data and partition information can be cleaned before the device is reclaimed or released. Administrators can wipe ineligible disks through the vSAN Management API after verifying the partition table and stored data. vSphere provides API methods for cryptographic key lifecycle management, including `removeKey` and `removeKeys` operations that delete encryption keys from host caches. These methods support a `force` parameter for definitive key removal.

VCF Operations includes a Reclamation dashboard and associated settings that help administrators identify virtual resources eligible for cleanup and disposal. The Reclamation Settings interface surfaces powered off VMs, idle VMs, snapshots, and orphaned disks, quantifying the resources that can be reclaimed. The Datastore Capacity Dashboard and ESX Capacity Dashboard both identify three specific reclamation opportunities: powered off VMs, snapshots, and orphaned VMDKs. These dashboards give operations and capacity teams visibility into resources that should be reviewed for secure removal before equipment is repurposed or decommissioned. The Reclamation Report tracks CPUs reclaimed, memory reclaimed, and storage reclaimed across different time periods, providing evidence of resource cleanup activity.

For the actual deletion of virtual resources, VCF Operations provides a `DELETE VM(s)` capability that removes selected powered off VMs, and a `RECLAIM RESOURCES` function that allows immediate execution of resource reclamation processes. VCF Automation extends this with a `Delete` action on Deployments that destroys an entire deployment and deletes all associated resources for reclamation. VCF Automation also supports the creation and deletion of secret reusable properties through its secrets management interface under Administration Secrets, which is relevant when sanitizing credential material before equipment reuse.

VCF Operations can disable virtual disk wiper and disk shrink operations on virtual machines through the `isolation.tools.diskWiper.disable` setting, which blocks data recovery attempts from within guest operating systems.

Core dump handling is another area where VCF provides disposal-relevant guidance. VMware recommends considering disabling core dumps on VMware vCenter systems to protect sensitive information. Unlike virtual machine core dumps, which are encrypted when VM encryption is active, vCenter core dumps are not encrypted by default; vCenter systems support core dump encryption through the `core-dump-encryption` setting, and encrypted core dumps can be decrypted or re-encrypted as needed. Core dumps may contain sensitive information such as host keys, and organizations should follow their security and privacy policies to protect this data. When decommissioning or repurposing hosts, addressing core dumps is an important step for reducing the likelihood of information recovery.

VCF also recommends securely deleting decrypted backup files after restore operations for VCF Operations, vCenter, and NSX components.

Auditors should verify that the organization has defined procedures for securely disposing of or repurposing VCF-managed infrastructure. This includes confirming that virtual resources (VMs, snapshots, orphaned disks, secrets) are deleted through

VCF's reclamation and deletion tools before physical equipment is removed from service, and that encryption keys are destroyed via cryptographic erasure for storage that held sensitive data. Physical chain-of-custody procedures, media sanitization verification, and equipment tracking through the disposal lifecycle are organizational processes outside the scope of VCF.

VMware vDefend (Contributes)

VMware vDefend contributes to secure information disposal through mechanisms built into its security analytics and threat prevention components. While vDefend is not a storage or media sanitization product, it collects and retains security-relevant data including network flow records, threat analytics, security policy metadata, and classification labels, and provides mechanisms for disposing of that data when it is no longer needed.

Security Services Platform provides deactivation paths that result in permanent deletion of associated data. Graceful deactivation of Bare Metal Security Service deletes all associated server information including certificates and inventory, and blocks the decommissioned server from reconnecting to the platform. A forceful deactivation path is also available that performs the same permanent data removal and deregistration. When an NDR Sensor is offboarded, Security Services Platform clears all registration and trust data from the system. The force offboard endpoint capability in Endpoint Management immediately deletes all endpoint data from the License Hub. Deleting a Security Services Platform instance removes the platform and all its associated components.

Security Services Platform supports certificate management with an explicit Remove action, including deletion of certificates for web proxies. Role assignments for remote users and groups can be deleted when LDAP is configured as an authentication provider. The platform backs up tokens and Bare Metal server inventory as part of inventory backup, supporting controlled lifecycle management and enabling intentional disposal after a backup is confirmed.

Malware Prevention Service rules and Service Virtual Machines can be deleted through Security Services Platform. The platform records metrics for purged records from Malware Prevention Service tables, covering inspection events, intercepted entities, and malware classification data, providing visibility into automated data purge activity.

Security Intelligence supports label deletion, which clears all associated label assignments to compute entities in the Security Intelligence visualization. Label assignments are also automatically cleared up to 30 days after an associated compute entity is deleted from inventory.

These capabilities address the disposal of vDefend's own operational and security analytics data. Broader information disposal requirements, such as sanitizing storage media, managing organizational data retention schedules, enforcing disposal verification processes, and cryptographic erasure of application data, fall outside vDefend's scope and are handled by other VCF components or organizational processes.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to

isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control CC6.6

The entity implements logical access security measures to protect against threats from sources outside its system boundaries.

SCF Controls: CRY-01, IAC-01, IAC-01.2, IAC-06, IAC-10.1, IAC-13, NET-01, NET-02, NET-03, NET-03.1, NET-04, NET-04.1, NET-08.1, NET-12, NET-12.1, NET-13, NET-14, NET-14.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting

direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Meets)

VMware vDefend provides the primary data flow enforcement mechanism within VCF through its Distributed Firewall, Gateway Firewall, and Security Intelligence capabilities. These capabilities function as software-defined access control lists governing traffic between workloads, segments, and external networks.

The vDefend distributed firewall enforces Layer 2-7 access policies at the vNIC level on every workload. Administrators define firewall rules that explicitly permit or deny traffic based on source and destination groups, ports, protocols, application identity, user identity via Active Directory integration through Identity Firewall, and fully qualified domain names (FQDN filtering). Because enforcement happens at the workload's virtual network interface, traffic is filtered before it reaches the physical network, and policies follow the workload as it moves between hosts. The Application Connectivity Strategy's "Allow Intra, Deny Other Traffic" mode automatically generates an intra-group ALLOW rule with optional logging plus a default ANY/ANY/DROP rule to isolate the group, providing a structured default-deny posture that restricts traffic to only what is explicitly authorized.

URL filtering provides an additional access control layer, enabling rule-based restrictions based on URL categories, URL reputation scores, and custom URL lists applied to both HTTP and HTTPS traffic. Identity Firewall rules can specify source users or groups, destination resources, services, and context profiles to allow or deny traffic based on Active Directory group membership. These rules support Allow and Reject actions and can be applied to physical devices where users log in, as well as to tier-0 and tier-1 gateways. Role-based access control within the Distributed Firewall governs who can create or modify firewall rules, restricting policy changes to authorized personnel.

The vDefend gateway firewall provides stateful North-South traffic inspection at Tier-0 and Tier-1 gateways, enforcing ACL-equivalent rules on traffic entering or leaving network segments. The Gateway Firewall supports Identity Firewall integration with Active Directory for identity-based access control at the perimeter. Together, the Distributed and Gateway Firewalls address both East-West (inter-workload) and North-South (perimeter) data flow enforcement.

Security Intelligence, hosted on the Security Services Platform, supports ACL governance by observing traffic flows between applications and environments. Security Intelligence classifies flows as allowed, blocked, or unprotected and generates policy recommendations with segmentation strategy actions of Allow (creates a default traffic flow allow rule) or Drop (creates a default traffic flow drop rule). When a security policy is published, a rule is automatically generated to allow intra-application traffic. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, helping administrators identify unauthorized communication patterns and tighten ACL governance over time.

The Security Services Platform governs access to Security Intelligence operations through role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Three permission levels apply across operations: Full Access (Create, Read, Update, and Delete), Read, and None. This restricts policy recommendation and enforcement actions to authorized security personnel.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) protects data in transit between its components and to clients through TLS. The minimum TLS protocol version is configurable through the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file, and PNR requires that this setting be applied consistently across the system when it is modified. The TLS version in use by the PNR Server can be verified by running `openssl s_client` against the appliance endpoint.

PNR uses SSL/TLS server endpoint certificates and private keys to protect network communication and to establish identity between clients and the PNR Server. PNR Server SSL/TLS certificates must be server certificates with x509v3 Extended Key Usage indicating TLS Web Server Authentication. Operational log files written by PNR are designed to omit sensitive material such as private keys and passwords.

For inter-site replication, PNR supports optional network encryption of replication traffic between protected and recovery sites, and vSphere Replication can be configured to enable data encryption for replication traffic. To preserve cryptographic context across a failover, PNR requires that the recovery and protected sites use a common Key Management Server (KMS), or that KMS clusters at both sites use common encryption keys, so encrypted virtual machines remain accessible after recovery.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides boundary protection mechanisms at the application delivery layer for traffic it proxies. Network Security Policies in Avi evaluate incoming client traffic based on network-level parameters and determine whether a connection should be accepted, discarded, or rate-limited. These policies apply IP-based traffic filtering at the virtual service level; a deny rule stops further policy evaluation, preventing downstream HTTP Security, Request, or Response policies from executing for that traffic. Network security policies are configurable per virtual service and per Virtual IP address, giving administrators auditable and consistent access controls across the deployment.

Avi's Web Application Firewall (WAF) inspects application-layer traffic at the proxy boundary using positive and negative security models. Positive Security rules define what constitutes allowed application behavior and enforce restrictions on traffic that does not conform to that model. WAF Application Rules provide protection against known attack patterns, including rules targeting specific CVEs; rules are automatically updated through the Controller Cloud Services connection, and existing rules continue to protect applications when that connection is unavailable. WAF rule actions support pass and deny options for controlling traffic based on policy matches. Administrators can also enable the Application Rules service through the Avi Cloud Console, which delivers automatically updated CVE-targeted rules directly to Avi Controllers.

For DDoS mitigation, Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework. This includes protection against DNS Reflection Ingress attacks, which involve sending DNS queries with spoofed IP addresses to flood a victim with unsolicited DNS server responses.

In Kubernetes deployments, the Avi Kubernetes Operator (AKO) extends boundary controls to Kubernetes ingress traffic. The L4 Rule custom resource definition (CRD) in AKO allows administrators to express custom Security Policies applied to virtual service traffic, including configuration for DDoS attack detection and mitigation. The ``insecureEdgeTerminationPolicy`` setting in AKO controls handling of insecure traffic, with a redirect option that enforces secure traffic routing through HTTP Request policies applied per FQDN.

Avi Service Engines implement traffic isolation between the data plane and the management and control plane using a dedicated management vNIC bound to the default Linux network namespace, with health monitor traffic further isolated through Linux network namespace features in the kernel. Service Engine IP addresses egressing the Data Plane vNIC are routed through the external network and subjected to routing isolation and ACL/firewalling controls present in that external network. A dedicated management network is required for communication between Avi Controllers and Service Engines. In isolated network deployments, each Avi Controller supports a second management IP address or DNS-resolvable FQDN for Service Engines connecting from an isolated segment, configured via the ``isolated-network-management-address`` setting.

In VCF deployments using the Avi-for-VCF integration, the Management Network hosts the Avi Controller and provides connectivity to vCenter, ESX hosts, and Supervisor control plane nodes, maintaining a defined boundary between management and workload traffic.

Incoming HTTP(S) traffic can be replicated to logging and sideband servers at the protocol level via the Virtual Service Sideband Profile, enabling deep traffic inspection by external appliances such as web application firewalls and supporting compliance and auditing requirements.

Avi also supports a Firewall Sandwich Topology, where virtual services and firewall pool members are chained so that application traffic traverses configured firewall members on its path from the Internet to internal servers. In this topology, a sample of traffic is inspected by the firewall while remaining traffic considered trusted is directly routed to the internal network.

Boundary protection for segments and layers outside Avi's application delivery scope, including network-level perimeter controls, east-west enforcement between application tiers, and internal boundary protection across the broader VCF environment, requires the VCF networking infrastructure and VMware vDefend, which is a separate product.

Control CC6.7

The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.

SCF Controls: AST-05, CFG-02, CFG-03, CFG-04.2, CRY-01, CRY-01.1, CRY-03, CRY-05, CRY-05.1, DCH-01, DCH-10, DCH-12, DCH-13, DCH-13.2, DCH-14, DCH-17, END-01, MDM-01, MDM-03, NET-03.5, NET-04.1, NET-12.2, NET-13, NET-17

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations

that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl snapshot save` command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Meets)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides cryptographic protection for data transmitted during disaster recovery operations, covering management communications and replication data flows.

All communications between the PNR server and VMware vCenter (vCenter) instances take place over TLS connections. PNR requires an SSL/TLS certificate, with x509v3 Extended Key Usage indicating TLS Web Server Authentication, as the endpoint certificate for all TLS connections to the PNR server. PNR defaults to the current TLS version for all communication endpoints and supports administrative configuration of the minimum acceptable protocol version. Administrators configure the minimum TLS protocol version by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file; when changing the minimum version, the update must be applied consistently across all occurrences in the system. PNR uses TLS certificates and private keys to protect network communication and authenticate with other servers.

For replication data, vSphere Replication encrypts replication traffic in transit for both new and existing replications. Network encryption is mandatory when using vSphere Replication 9.0.3 and later and is enabled by default. PNR also supports configuring network encryption of replication traffic as an option for replication scenarios where mandatory encryption does not apply automatically. PNR supports protection and recovery of encrypted virtual machines through both array-based and vSphere Replication protection groups, allowing VM disk encryption to persist through the replication process. Recovery of encrypted virtual machines requires that the protected and recovery sites share a common Key Management Server (KMS), or that the KMS clusters at both sites use common encryption keys, to maintain key availability after failover.

Defining the encryption policy for environments with stricter requirements and validating that workload traffic running on protected virtual machines meets confidentiality standards are organizational data-policy decisions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the ``ssl_min_protocol_version`` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable ``sslmode`` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has ``require_secure_transport`` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the ``ssl_fips_mode`` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the ``network.tlsProtocols`` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts

the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control CC6.8

The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.

SCF Controls: CFG-05, CFG-05.1, CFG-05.2, CHG-01, CHG-02, CHG-02.1, END-03, END-03.1, END-04, END-04.7, END-06, END-07, MON-01.7, NET-03, NET-08

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend, a separately licensed advanced service, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Meets)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to

suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) restricts the ability to perform privileged operations, including software updates, database provisioning, and version management, to users assigned administrative roles. This role-based access structure limits who can install, update, and configure database software within the DSM environment.

DSM implements role-based access control with two distinct role types. The DSM Admin role provides full access to all data services and administrative functions. The DSM User role is limited to creating and maintaining databases within the namespaces to which the user has been assigned access. This separation is enforced at the console level; the DSM UI restricts the views and actions available based on each user's role, so standard users cannot perform operations reserved for administrators. RBAC can be extended through directory service group integration, allowing administrators to map directory service groups to specific DSM roles.

Software updates to DSM itself are gated on administrator access. DSM requires a user with administrator credentials to log in to the UI before software update operations can proceed. Similarly, deploying the DSM plugin into a VCF environment requires VCF SSO global administrator privileges. These requirements confine initial installation and subsequent updates to authorized privileged accounts.

Version management for database services is an administrator-only function. The Version Management menu in the DSM UI allows administrators to enable or disable specific versions of data services, controlling which database software versions are available for provisioning in the environment. Users in the DSM User role cannot access or modify these settings.

Namespace-based access control further limits which users can provision new database instances. DSM namespaces govern database creation permissions so that only users associated with a given namespace can create databases within it. Users can manage and monitor only the data services they own; they cannot provision databases or modify services in other users' namespaces. Administrators can edit only a user's role and the namespaces to which the user has access. Role and user management is configured through the vSphere Client Permissions interface under the DSM Configure tab.

In multi-tenant deployments, DSM administrators can assign object stores and data service policies to specific tenants, restricting which database services and resources each organization can access and provision. When DSM is integrated with VCF Automation, creating a PostgreSQL database requires either the system administrator role or the project advanced user role, scoping provisioning to users with sufficient privileges.

DSM adds SQL Server as a managed database service. SQL Server instance provisioning and server-level configuration management, including Active Directory integration and high availability configuration, are restricted to DSM administrators only. DSM's internal management login (dsm_mgmt) isolates administrative operations within a secure context, preventing users from accessing or modifying system-level objects. The dsm_db_user custom database role denies TAKE OWNERSHIP on the database to prevent privilege escalation. User-defined DDL triggers that execute during DSM management operations run within a restricted database-level security context, preventing them from accessing or exploiting server-level permissions of the internal management login.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Control CC7.1

To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.

SCF Controls: AST-02.2, CFG-01, CFG-02, CFG-02.2, END-06, END-06.1, MON-01.7, VPM-06

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several integrated automated mechanisms for governing, monitoring, and reporting on baseline configurations across the infrastructure stack.

VCF Operations is the centralized configuration monitoring engine through its Configuration Drifts feature. Administrators define desired-state configuration templates and assign them to VMware vCenter instances and vSphere clusters. When a configuration value changes from the assigned template value, VCF Operations generates a drift notification, allowing administrators to identify and remediate unauthorized or unintended changes. The Configuration Drift dashboard provides a consolidated view of all detected drifts, and drift status reports can be downloaded for offline review or evidence collection. Configuration templates can be integrated with a source control repository, enabling versioned and auditable management of configuration baselines. This integration supports change control workflows with reviews and automated validation through continuous integration and continuous delivery pipelines. Drift detection is skipped if the template does not exist in the source control repository, so maintaining the repository is a prerequisite for continuous monitoring.

VCF Operations alert definitions provide an additional layer of configuration monitoring. Administrators can configure alerts that use Metric/Property symptoms based on operational or performance values and configuration properties collected from target objects. These alert definitions monitor infrastructure components and notify administrators when configuration properties deviate from expected baselines. Associated remediation recommendations are attached to each alert, providing actionable guidance when violations are detected. Custom groups can be designated to update automatically with membership criteria, supporting structured monitoring strategies and enabling automated policy application across managed objects.

VCF Operations Diagnostics extends configuration verification by providing integrated issue detection and remediation. The Diagnostic Findings feature discovers known issues and applies fixes based on industry-standard best practices and knowledge base articles. Diagnostics derives its findings from properties and product log data collected across the full VCF stack, including VMware vCenter, VMware ESX, NSX, VCF Operations, vSAN, and VCF Automation. This cross-component visibility enables centralized verification of configuration baselines across all major platform services. Diagnostic Findings consolidates log-based and property-based findings with specific resolution guidance, integrating with VCF Log Management for additional depth in identifying configuration drift or misalignment.

VCF includes built-in compliance benchmarks based on the VCF Security Baseline and the Security Configuration Guide. These benchmarks evaluate both default and non-default settings across infrastructure components and report on compliance status. DISA STIG regulatory benchmarks are available for securing and configuring systems, and organizations can create, import, and export custom compliance benchmarks that monitor selected alert definitions and policies. Compliance management continuously monitors infrastructure objects against these benchmarks and provides actionable remediation recommendations when violations are detected.

For automated remediation and configuration enforcement, Automation Central in VCF Operations allows administrators to create scheduled jobs that automate management actions. Jobs with ten or fewer resources run immediately, while larger jobs run in parallel groups of ten. The VCF Automation plug-in provides out-of-the-box workflows for common tasks such as host configuration and infrastructure management, reducing reliance on manual configuration processes. Infrastructure operations can be further automated through integration with tools such as Terraform and Ansible for agile templating and workflow-driven configuration management.

VCF supports centralized agent-based configuration distribution. Once connected to its server, the agent automatically retrieves and applies configuration settings based on defined Agent Groups, providing a push-based mechanism for maintaining baseline configurations across managed endpoints.

At the host level, vSphere Lifecycle Manager (vLCM) defines desired software state images for ESX clusters and supports validation of the desired state and detecting drifts from it. VCF Operations supports up to 25 simultaneous cluster compliance checks per instance, and the VCF Operations API provides endpoints for performing image compliance checks programmatically. vSphere Host Profiles provide a complementary automated mechanism for host configuration compliance. Administrators define a reference host configuration that is captured as a Host Profile and applied across managed hosts; scheduled compliance checks then determine whether any configuration parameters on a host differ from those specified in the profile, and deviations are flagged for remediation.

VCF Automation integrates with VCF Operations to expose metrics and monitoring data for deployments. When monitoring is enabled, VCF Automation retrieves VCF Operations health status and associated alerts, providing a unified view of deployment health and configuration state. Tags applied to deployments support governance by expressing capabilities and constraints that define how resources are provisioned and managed. VCF Automation IaaS Resource Policies extend this governance to the Kubernetes cluster tier, supporting baseline pod security level enforcement that requires provisioned clusters to meet a defined pod security standard before resources are deployed into them.

The VMware Kubernetes Service (VKS) and vSphere Supervisor layer extends baseline configuration governance to containerized workloads through a declarative model. All Kubernetes resources, including Deployments, ConfigMaps, NetworkPolicies, Pod Security Admission labels, ResourceQuotas, and LimitRanges, are defined as desired-state manifests enforced through the Kubernetes API server. Pod Security Admission is applied at the namespace level in three configurable modes: enforce mode rejects non-compliant pods at admission time, audit mode records violations in the cluster audit log without blocking admission, and warn mode generates warnings for non-compliant submissions. The security standard applied to a namespace can be set to privileged, baseline, or restricted using `pod-security.kubernetes.io/` labels; VKS applies Pod Security Admission to namespaces by default, with the standard configurable per cluster and namespace. System namespaces such as `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from enforcement by default. The three-mode design enables automated reporting on pod security baseline violations through the audit and warn modes independently of enforcement, supporting continuous assessment of compliance posture across the workload layer. Controllers continuously reconcile the actual cluster state against the declared desired state, automatically correcting configuration drift without manual intervention. This continuous reconciliation loop addresses the real-time verification requirement for the workload consumption layer in the same way that CDM-style programs require continuous verification of all technology assets.

The Argo CD Supervisor Service extends this declarative model to GitOps-based configuration governance. Desired configurations are stored in Git as the authoritative baseline, and Argo CD continuously compares the live cluster state against that baseline, surfacing discrepancies through its dashboard, health status indicators, and alerting integrations. Depending on the sync policy configured, Argo CD can automatically reconcile the cluster to the declared state or flag deviations for operator review. The service is designed to minimize manual intervention through automation. When configuration is managed as immutable infrastructure in version control, the combination of Git history and Kubernetes audit logs creates a durable, chronological record of every authorized change to the cluster configuration.

VKS Cluster Management provides policy-driven governance of the VKS cluster estate. Security policies can be assigned to clusters and enforced across the organization, and custom policies are implemented using OPA Gatekeeper as the policy engine. VKS cluster management proactively monitors the cluster estate to verify that assigned policies are enforced correctly and generates Policy Insights when configuration conflicts or environmental errors are detected, providing automated reporting of policy compliance status across all managed clusters.

Admission controllers built into the Supervisor API server enforce baseline security and configuration requirements at the point of resource admission. A validating admission webhook rejects Kubernetes resources that do not conform to the organization's defined configuration baseline before they are persisted to etcd, making off-baseline configurations inexpressible at submission time rather than relying on after-the-fact detection. Kubernetes Operators extend this model to

application-level configuration governance by automating repeatable configuration tasks and continuously monitoring and enforcing configuration requirements for the applications they manage.

The Kubernetes audit logging subsystem records all API server interactions, including configuration creates, updates, and deletes, according to a configurable audit policy. Audit events can be captured at multiple stages and shipped to an external log backend via webhook, providing an automated and continuous record of all configuration changes across the cluster. Node Problem Detector runs as a DaemonSet across cluster nodes, continuously monitoring node-level health conditions and reporting anomalies through Kubernetes Events and Node status conditions, providing automated detection of node-level configuration deviations that may indicate drift from the expected baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the va-configurator.xml file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides technical mechanisms that contribute to automated baseline configuration governance. Avi Load Balancer events are the building blocks of configuration automation: every change made through the web interface, CLI, or REST API is recorded as an event and automatically propagated to all Controller cluster members, giving operators a continuous record of what changed and maintaining cluster consistency.

User-Defined Metrics allow administrators to define and extract highly customized telemetry data for specific enterprise compliance or reporting needs via API calls. This supports continuous monitoring of configuration state against defined thresholds and provides the raw data for compliance-oriented reporting workflows.

Avi's REST API and CLI provide the interfaces for infrastructure-as-code configuration management. Official Ansible and Terraform integrations allow organizations to declare Avi Load Balancer baseline configurations as code, enforce those baselines through CI/CD pipeline runs, and detect drift when the running configuration diverges from the declared state. Ansible can be integrated with CI/CD pipelines to trigger automated Controller deployments upon code changes. Terraform modules support automatic scaling of service pool members through Network Infrastructure Automation (NIA) integration with Consul backend state management.

In VCF deployments, Avi integrates with VCF Automation's Provider Management Portal, which enables provider administrators to define infrastructure boundaries, create regions and organizations, and set region quotas for capacity allocation. This integration extends Avi's configuration governance surface to include multi-tenant resource governance and capacity planning for organizations consuming load-balancing services through the VCF stack.

Defining the configuration baselines, scheduling continuous comparison across the broader environment, and reporting deviation findings to management are organizational responsibilities fulfilled outside Avi through tooling and processes that operate against Avi's API and audit data.

Control CC7.2

The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.

SCF Controls: CFG-02.2, CPL-03.2, GOV-02, MON-01, MON-01.1, MON-01.12, MON-01.2, MON-01.3, MON-01.4, MON-01.5, MON-01.6, MON-01.8, MON-02, MON-02.1, MON-06, MON-16, NET-08.2, OPS-01.1, OPS-02, RSK-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several capabilities that contribute to anomalous behavior detection and user activity monitoring, though it does not include a dedicated User & Entity Behavior Analytics (UEBA) or User Activity Monitoring (UAM) solution.

VCF Operations includes anomaly detection capabilities that use both dynamic and static thresholds to identify when metrics deviate from normal operating behavior. Dynamic thresholding is enabled by default and uses historical data analysis to establish baselines for each monitored object. The Smart Early Warning feature analyzes the number of applicable metrics that violate the dynamic threshold determining normal operating behavior, triggering alerts when the number of anomalies on an object exceeds a trending threshold. When an anomalous entity is detected, VCF Operations generates an outlier violation alert (vmwAnalyticsOutlierEvent, OID 37002), notifying administrators of unexpected behavior. A Critical threshold violation alert is also generated when anomalous entities are detected.

The Anomalies widget displays detected anomalies for a resource over the past six hours at configurable time intervals, with color-coded criticality indicators. The Anomaly Breakdown widget shows likely root causes for symptoms on a selected resource, helping operators triage issues. The Troubleshooting Workbench includes an Anomalous Metrics card that surfaces metrics exhibiting drastic changes within a selected scope and time window, ranked by degree of change with the most recent anomaly given the highest weighting. Administrators can also examine outlier VMs detected by VCF Operations to identify unexpected behavior and take corrective actions. VCF Operations supports outbound SNMP trap notifications, enabling alert delivery to external SNMP management systems with up to four configurable trap destinations.

For user activity monitoring, VCF Operations provides a User Activity Audit report that offers traceability of user actions including logging in, operations on clusters and nodes, changes to system passwords, certificate activation, and logging out. Each audit event has a detailed view containing information that supports analysis of events in the virtual infrastructure for suspicious user actions or system issues. Event auditing across the VCF platform provides visibility into platform interaction changes and surfaces suspicious access events and policy violations. Administrators should continuously monitor user security aspects to detect security risks early and respond to potential threats. VCF SSO maintains a dedicated audit log that captures user management events, including account creation, modification, deletion, and activation or deactivation, as well as changes to account credentials and profile information. The vSphere Client's Advanced Export feature allows administrators to export tasks performed by a specific user during a specified time range, providing targeted audit data for investigating suspicious activity.

Audit logging extends across VCF components. NSX Manager generates audit log messages that record user operations with fields for UserName, ModuleName, Operation, and Operation status, along with detailed resource change information and timestamps. NSX Manager audit logs also record failed login attempts with username and timestamp information, enabling tracking of access patterns across the environment. VCF Operations for Networks captures audit logs of administrative actions, including CRUD operations and login/logout events.

VCF Operations supports forwarding user activity audit logs to an external syslog server, enabling integration with dedicated SIEM or UEBA platforms for broader correlation and behavioral analysis. VCF Log Management includes content packs that offer pre-built dashboards, alerts, and queries for VCF components. These content packs support security monitoring use cases such as tracking failed login attempts and privilege escalations.

VCF's built-in anomaly detection is primarily oriented toward infrastructure metrics and operational health rather than user behavior profiling. A dedicated UEBA or UAM solution consuming VCF's audit data would be needed to establish user behavior baselines, detect credential compromise through behavioral deviation, and provide the full scope of analytics this control requires. For organizations requiring deeper behavioral analysis, VMware vDefend extends VCF's monitoring foundation with IDS/IPS, network traffic inspection, and threat intelligence integration.

VMware vDefend (Meets)

VMware vDefend generates security event logs across its Distributed Firewall (DFW), Gateway Firewall (GFW), and IDS/IPS components. In 9.1, vDefend integrates with VCF Log Management, which collects Unified Security Logs covering DFW, GFW, Identity Firewall, FQDN Analysis, TLS Inspection, IDPS, and URL Filtering events in a consolidated stream suitable for forwarding to external SIEM platforms.

The Security Overview Dashboard's Threat Event Monitoring tab provides ongoing visibility into security issues across the data center, displaying statistics on Malicious IPs, Top Blocked IPs, Top VMs Accessing Malicious IPs, and Top Blocked Categories. Administrators can filter the view by All Traffic, Distributed Only, or Gateway Only events, and a trend graph shows intrusion events over time categorized by Intrusion Severity.

The dedicated IDS/IPS Security Dashboard supports event monitoring for both Distributed and Gateway deployments. Intrusion events can be filtered by Attack Target, Attack Type, and CVSS score threshold to focus review on the highest-priority activity. IDS/IPS events can also be exported directly to syslog by enabling the `ids_events_to_syslog` setting on ESX hosts, providing centralized log collection through existing syslog infrastructure independent of the NDR component; this setting is disabled by default and must be explicitly enabled. In 9.1, vDefend IDS/IPS and Network Detection and Response (NDR) support date range filtering for event detail review through the Intelligent Assist triage interface, enabling temporal analysis of security events and intrusion attempts.

Security Intelligence, accessible through Security Explorer, provides a View Full Event History capability that surfaces all events associated with a given signature ID along with their intrusion severity, supporting focused review of specific threat patterns. File event statistics are available through the Threat Monitoring dashboard in Security Services Platform, with graphs filterable by configurable time period.

NDR collects and analyzes security event data for real-time monitoring and supports SIEM integration for centralized event management. The organizational processes of reviewing logs on an ongoing basis and escalating incidents in accordance with defined timelines and procedures must be established and managed outside vDefend through SIEM tooling and documented response procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates structured audit events and alarm notifications across its disaster recovery components, providing the event sources and escalation mechanisms that support ongoing security event monitoring.

PNR supports event logging where each event type has a corresponding alarm that can trigger when the event occurs. Events carry three severity levels: Info for normal operational information, Warning for conditions requiring attention that do not affect system operation, and Error for failed operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Audit events for user actions include the event name, user identity, and source IP address. vSphere Replication maintains a dedicated audit log at `/opt/vmware/support/logs/hms/hms-audit.log` and records login events with timestamps, user identity, session keys, and locale information. Authorization error messages include timestamps and component information to support security event tracking.

PNR audits changes to protection configurations: it logs when consistency groups are added to protection groups as Info-level events and when protected consistency groups enter error or warning states as Error-level events. PNR monitors connections between sites by sending periodic ping requests and logging Site Status Events that reflect the connection state between protected and recovery sites. vSphere Replication generates typed audit events when virtual machines and hosts are configured or unconfigured for replication. The PNR health monitor service checks each health finding every five minutes and

raises Warning-status alerts for expired snapshot schedules, replication errors such as missing VMs, and site connectivity issues.

Alarms can be configured to send email notifications, SNMP traps, or execute scripts when specified event conditions are met, allowing DR events to feed into established incident response and escalation procedures. PNR maintains an Alarms list that provides a searchable, severity-filterable history of notifications that required attention, supporting periodic review.

VCF Operations collects configuration, component health, and usage information from PNR servers and site pairs to populate Protection and Recovery dashboards. These dashboards display alerts about configurations requiring attention and health status for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. The Inventory view provides object-level monitoring of health status, metrics, and alerts across all protected objects.

The Clean Room Orchestrator maintains a global collection of events, tasks, and alarms for ransomware recovery operations. Event forwarding from PNR to VCF Log Management (version 9.0 and above) is supported for centralized log collection and review.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) generates system alerts for conditions within its operational scope, covering database engine health, infrastructure connectivity, cybersecurity events, and data protection activities. The Dashboard displays Global Alerts at a glance, and a dedicated Global Alerts page, accessible from both the plug-in UI within vSphere Client and the standalone UI, provides a consolidated view of non-catastrophic alerts and overall system status. An Alerts pane in the Monitoring tab gives administrators a database-scoped view of active conditions for individual instances.

DSM categorizes alert conditions at three severity levels: OK, WARNING, and CRITICAL. Named alert types include `INFRASTRUCTURE_POLICY_VC_ALARMS`, triggered when one or more infrastructure resource alarms found in VMware vCenter (vCenter) are active; `VCENTER_CONNECTIVITY`, triggered when vCenter connectivity fails; `DATABASE_ENGINE_HEALTH_ALERT`, triggered when the database engine service is experiencing problems or disruptions; and alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates alerts for authentication failures, backup and restore corruptions, and certificate errors. When critical alarms are active for vCenter hosts, DSM surfaces guidance to avoid create, upgrade, and scale operations to reduce the risk of failures during degraded infrastructure states. Each alert includes resolution suggestions that give operators actionable steps to resolve conditions without disrupting database services. Alert notification settings and threshold values for database alerts are configurable.

To support integration with broader monitoring and incident response workflows, DSM can forward alerts as email notifications or as webhook notifications to external systems. Named integration targets include Slack channels and ServiceNow. Webhooks support customizable payload templates and AlertLevel filtering, restricting delivery to CRITICAL or WARNING conditions as appropriate for the operational model. Alert payloads include the alert name, alert level, alert description, trigger timestamp, alert message, database cluster identifier, cluster name, triggered user email, task status, previous status, and task type. At the individual database level, administrators can configure alert notifications to route to Email, Slack, or ServiceNow endpoints. This mechanism supports routing DSM-generated alerts into enterprise monitoring platforms, SIEM systems, or ticketing workflows.

DSM integrates with VCF Operations to surface monitoring data for database services, providing an additional visibility channel for triggered or active alerts scoped to individual nodes or the overall cluster within the broader VCF observability stack.

DSM's alert coverage is scoped to the database-as-a-service layer: database instance health, infrastructure policy compliance, connectivity to platform components, authentication events, and backup operation outcomes. Physical security, network-level cybersecurity events, and supply chain activities are outside DSM's scope and require monitoring through the broader VCF platform and organizational tooling. Correlating DSM alerts with alerts from other platform components, and implementing a coordinated response workflow that spans physical, cybersecurity, data protection, and supply chain domains, requires organizational processes and enterprise monitoring capabilities beyond what DSM provides on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer anomaly detection mechanisms that contribute to meeting this control. The Anomalies Overlay feature, available in Virtual Service Analytics, Service Engine Analytics, and Pool Analytics, flags statistical deviations in traffic metrics as anomaly events when a specific metric deviates from the historical norm by more than four sigma during the anomaly period. Monitored metrics include CPU utilization, bandwidth, disk I/O, server response time, and connection rates. Each anomaly event is identified by entity name, entity type (Virtual Machine, Virtual Service, or Service Engine), and metric value, with a timestamp indicating when the deviation occurred. Anomaly detection operates against a moving-average baseline calculated from recent historical traffic. The Pool Anomalies Overlay also displays prediction interval upper and lower bounds alongside the anomalous value. Administrators can adjust detection granularity by changing the statistics time interval, and can configure alert filter sensitivity to tune the threshold for new alert generation. Note that anomaly recording is disabled when the statistics interval is set to Real Time; a non-real-time statistics interval is required for anomaly capture to function.

The Bot Management module adds a behavioral detection layer focused on credential stuffing and web attack patterns at the application proxy boundary. Bot Management detects malicious bots responsible for online fraud and credential stuffing attacks. The IP Reputation service extends detection by maintaining a database of categorized IP addresses and identifying anomalous traffic patterns, including DoS and DDoS activity and anomalous SYN floods.

For authentication-related anomalous behavior, Avi provides the `AUDIT_COMPLIANCE_EVENT` mechanism to log authentication failures for audit purposes, persisting them via the alerts infrastructure. The Web Application Firewall (WAF) App Log Analytics component captures events whenever a WAF application rule is triggered, recording the type of attack detected. Service Engines generate `DOS_ATTACK` alert events that include attack type, source IP addresses, virtual service UUID and name, and a report timestamp, supporting audit and forensic analysis of detected attacks. Avi also supports DataScripts for custom identification of suspicious traffic and execution of appropriate mitigation actions, enabling organizations to define custom behavioral detection logic beyond the built-in statistical baselines.

Avi monitors over 500 real-time metrics to support DDoS detection and attack visibility. Alerts from any of these mechanisms can be forwarded proactively to email, syslog, SNMP, or custom APIs, enabling integration with a central SIEM or security operations platform. Avi integrates with Splunk via the Avi Load Balancer Splunk Add-on, generating events that serve as an audit trail for user logins, configuration changes, and runtime state changes.

These capabilities operate at the application delivery and load balancing layer. An organization requires a dedicated UEBA or UAM platform to fulfill the full scope of this control, including identity-level behavioral baselines, user session correlation, and cross-system entity analytics that extend beyond application traffic visible to Avi.

Control CC7.3

The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.

SCF Controls: END-06.2, IRO-01, IRO-02, IRO-02.4, IRO-04, IRO-04.1, IRO-09, IRO-10, IRO-10.2, MON-02, MON-02.1, MON-06, RSK-01.1, RSK-04, TPM-11

Aggregate Coverage: Meets

VCF (Meets)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response

documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis: results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short_description, description, close_code, and close_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control CC7.4

The entity responds to identified security incidents by executing a defined incident-response program to understand, contain, remediate, and communicate security incidents, as appropriate.

SCF Controls: BCD-01, BCD-05, HRS-03, HRS-07, IRO-01, IRO-02, IRO-04, IRO-04.2, IRO-07, IRO-09, IRO-10, IRO-10.2, IRO-10.4, IRO-11.2, IRO-13, IRO-14, RSK-06, VPM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as `callerId`, `propagateAlertUpdates`, `retrieveIncidentUpdates`, and `incidentReopenState`, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and

evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short_description, description, close_code, and close_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control CC7.5

The entity identifies, develops, and implements activities to recover from identified security incidents.

SCF Controls: BCD-01, BCD-01.6, BCD-02, BCD-02.1, BCD-02.2, BCD-02.3, BCD-04, BCD-05, BCD-06, BCD-11, BCD-11.1, BCD-12, BCD-13, IRO-10

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides built-in capabilities for secure recovery and reconstitution of infrastructure and workloads to a known state after a disruption, compromise, or failure. These capabilities span compute-level high availability, storage-level data protection, structured backup and restore workflows for management components, and disaster recovery across sites.

At the compute layer, vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts following a physical machine failure, restoring workloads to their prior operational state. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure with no data loss or downtime. Proactive HA supports maintenance mode as a remediation method, allowing the platform to respond to hardware degradation indicators. On TPM-equipped hosts, VMware ESX supports a Secure ESX Configuration recovery key that is required to restore the host configuration following TPM failure, TPM reset, motherboard replacement, or TPM device replacement; administrators can retrieve and store this key using `esxcli system settings encryption recovery list` and should keep it in a secure, off-host location.

At the storage layer, vSAN fault domains distribute data according to storage policy so that it remains available even when hardware failures occur. vSAN stretched clusters extend a cluster across two availability zones, providing site-level resiliency against the loss of an entire availability zone. When one site becomes unavailable, the surviving site continues operations, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSAN Data Protection uses native snapshots stored locally on a vSAN Express Storage Architecture (ESA) cluster to support point-in-time recovery from operational failures or ransomware attacks. Changed Block Tracking (CBT) tracks changes on disk sectors, enabling incremental backups through VADP-integrated partner backup solutions.

For large-scale disruptions, Application Disaster Recovery enables failover to a secondary site, with data replication so recovery options exist in the event of catastrophic failure. Disaster recovery can also be implemented for fleet-level components, covering the management plane itself. VCF documentation recommends planning and testing disaster recovery strategies regularly to validate that recovery time objectives (RTO) and recovery point objectives (RPO) can be met.

VCF includes structured backup and restore workflows for its management components. Administrators create a series of backup jobs that capture the state of related components, including VCF Operations, NSX Manager, and VMware vCenter, at a common point in time. VCF Operations backup is configured to take a backup on state change. VMware vCenter supports both file-based and image-based backup methods. The file-based restore procedure is a two-stage operation: stage 1 deploys a new vCenter appliance, and stage 2 transfers data from the backup location to that appliance; the restored appliance operates in non-HA mode, so vCenter High Availability must be reconfigured after recovery completes. Simultaneous backups of VCF Operations fleet management component nodes support restoring the nodes to a logically consistent state, so further integrity remediation is not required after a restore. The platform also recommends backing up the management domain vCenter and VCF Identity Broker appliance following any substantial modifications to the identity source configuration, such as a VCF SSO reset, to preserve a known-good recovery point.

For VMware vCenter specifically, the vCenter Management API provides a unified restore process that handles multiple vCenter components in a single operation. After a file-based or image-based restore, the reconciliation API checks whether vCenter partners in embedded linked mode are available, synchronizes vCenter data and services with the partners, and runs vCenter services. The appliance recovery API exposes a restore client interface for programmatic restore operations, supporting automation of recovery workflows.

VCF Operations supports image-based backup and restore as a recovery process for single node, primary node, replica node, data node, and collector failures. VCF Operations for Networks supports backup and restore of its deployment data to enable recovery when the existing setup is unrecoverable. VCF Operations HCX provides backup and restore operations through its appliance management interface, and its Mobility Groups support workload migration with state tracking, retry capabilities, and reverse migration from destination back to the original source.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere namespaces, and VCF Services consumption, extends recovery and reconstitution capabilities to containerized workloads and self-service deployments. At the Kubernetes control-plane level, ReplicaSets and Deployment controllers continuously monitor pod health and reschedule workloads to healthy nodes when pods or nodes fail. Liveness probes detect application-level failures and trigger container restarts; readiness probes gate traffic until a workload recovers from transient faults or overloads. These self-healing mechanisms operate without manual intervention for transient failures. Pod Disruption Budgets allow administrators to define minimum availability constraints that the platform respects during voluntary disruptive actions such as node upgrades or certificate rotations, so those operations proceed without taking down an entire service.

VKS clusters support structured backup and restore through VKS Cluster Management and Velero-based mechanisms. VKS Cluster Management backup operations can capture an entire cluster or a subset of data resources, and restore operations allow the operator to specify the scope of resources to recover. Restore operations include file system backups by default; CSI volume snapshots can be optionally selected for restoration. CSI Volume Snapshots deliver crash-consistent backups with support for block mode and file system mode, incremental backups, deduplication, compression, and encryption, and provide a resilient safety net for VKS clusters when primary storage infrastructure fails. CloneFromSnapshot custom resources expose a status.phase field that tracks restore progress through multiple phases, giving operators visibility into the state of ongoing recovery operations. The Velero plugin for vSphere supports backup and restore of vSphere pods, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

Deploying workloads across multiple failure zones using the Cluster API defines worker nodes across multiple failure domains with automatic healing rules that reschedule workloads when a zone becomes unavailable. Replicating control plane components across at least three failure zones limits the impact of a single-zone failure on the Kubernetes control plane itself. For VM Service workloads, the IaaS Services Console and Local Consumption Interface provide a Resources tab where users can create snapshots with optional memory capture and guest file system quiescence, and can revert a VM to a prior snapshot to restore it to a known state.

Deployment rollback is available natively in Kubernetes through Deployments with revision history, allowing administrators to return to a previous known-good revision when a newly deployed version fails. The Harness CI/CD Supervisor Service extends this with automated rollback capabilities that can revert to a previous stable state when deployment failures are detected.

Immutable infrastructure patterns supported by Kubernetes, combined with infrastructure-as-code stored in version control, provide a reproducible mechanism for reconstituting a cluster to a known, authorized state. Every change to the declared state is recorded in version control, and the cluster can be rebuilt from that record after a compromise or failure. VKS Cluster Management Policy Insights expose Sync signals that indicate when policy definitions fail to propagate from the management plane to the targeted VKS cluster estate, helping operators detect and remediate policy drift before it affects recovery posture.

Restore operations require that the target infrastructure be in place before a restore can proceed. VCF documentation recommends implementing a consistent backup strategy to safeguard the infrastructure against unforeseen disruptions and to support effective disaster recovery.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) supports backup and restore operations executed as Kubernetes jobs within the nsxi-platform namespace, enabling recovery of the security platform configuration needed to resume distributed firewall enforcement, IDS/IPS, and other network security functions after a contingency event. Job status is tracked as Completed or Error states, giving administrators visibility into recovery progress. SSP backup and restore operations must

meet specific preconditions before proceeding; the platform validates these conditions before backup or restore actions are initiated.

SSP 9.1 provides an Update & Redeploy option that resumes a failed deployment from the point at which it was stopped, reducing recovery time when the SSP control plane encounters errors during restoration. For licensing continuity during recovery, SSP 9.1 also includes a Private Mode that bypasses license validity checks and expiration timelines, allowing security enforcement to continue when the licensing infrastructure is temporarily unavailable.

After recovery, endpoint readiness status must be set to Ready to avoid configuration errors or licensing disruptions before full security enforcement resumes.

These capabilities contribute to resuming essential security missions within a defined timeframe. The broader organizational recovery timeline, RTO definitions, and non-security workload resumption remain outside vDefend's scope.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides mechanisms for secure recovery and reconstitution of virtual machine workloads to a known state after a disruption, compromise, or failure.

Recovery is organized through protection groups and recovery plans. Protection groups define which virtual machines are protected, while recovery plans orchestrate the sequence of steps required to recover those workloads at the recovery site. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state governs which operations are permitted at each stage of the DR lifecycle. Recovery plans support two primary modes: planned migration for orderly, scheduled failover, and disaster recovery for unplanned site failures. A single recovery plan can also be configured to serve both disaster recovery and cyber recovery operations, allowing organizations to maintain consistent recovery procedures across different incident types.

Recovery plan testing is a built-in capability. Recovery plans should be tested before use for planned migration or disaster recovery to validate their functionality. This confirms that the recovery process will bring protected virtual machines online at the recovery site and that inventory mappings correctly place workloads on the appropriate networks, storage, and compute resources.

Cyber Recovery extends reconstitution capabilities with an Isolated Recovery Environment (IRE) designed for compromise scenarios such as ransomware incidents. The IRE provides a dedicated, isolated segment of the recovery environment that blocks direct private network connections from production, allowing compromised workloads to be analyzed and validated before being returned to production. Cyber Recovery transitions virtual machines through a controlled sequence of states, including Entering validated, Validated, Staging, and Staged, to prepare them for recovery. This state-based workflow supports data integrity validation prior to production restoration.

Recovery plan compliance checks verify that protection groups are actively replicating, that sufficient point-in-time snapshots are available for each virtual machine in the plan, and that all workflow steps can execute without conflict. Continuous compliance monitoring provides warnings when VM configuration status deviates from expected state.

The Configuration Import/Export Tool enables administrators to export PNR server configuration data, including inventory mappings, placeholder datastores, advanced settings, array manager configurations, and protection group definitions. This capability supports configuration backup and reconstitution of the PNR environment itself after a failure or migration.

PNR integrates with VCF Operations for recovery plan lifecycle visibility. The Recovery Plans Details dashboard shows the current phase of the DR lifecycle, including whether a plan is ready, whether a test is in progress, and whether incomplete recovery or cleanup operations require attention. PNR also supports recovery of VCF Automation and VCF Operations services: when a disaster event affects the management domain containing these services, PNR enables service recovery in another management domain.

All communications between PNR and VMware vCenter instances use TLS certificates and private keys. The PNR Appliance supports importing server certificates signed by a certificate authority to establish secure communications across both protected and recovery sites.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the secure recovery and reconstitution of database services to a known state following a disruption, compromise, or failure.

For backup-based recovery, DSM supports point-in-time recovery (PITR), which restores a backup to a newly created database VM. During the restore operation, the administrator can specify the database name, choose the target datastore location, and configure management settings. DSM supports restoring backups from either local or cloud-compatible (S3-compatible) storage, with restoration permitted to any point in time within the configured backup retention period. When restoring a deleted database, DSM's Archives tab allows users to access databases with retained backups and create a new database VM from a selected restore point, including options to restore to the most recent available timestamp or a custom point in time. PITR coverage extends across PostgreSQL, MySQL, and SQL Server database engines. For SQL Server, DSM automatically manages the database recovery model based on backup status, using Full Recovery for databases with automated backups enabled and Simple Recovery otherwise. Cloning a MySQL or PostgreSQL database is functionally equivalent to PITR to the latest available time, giving operators an additional path for rebuilding a known-good database instance. For failed clusters, DSM supports restoration to a different cluster with the option to target either the latest available time or a specific custom restore point.

For active recovery and failover of PostgreSQL databases, DSM provides a multi-site disaster recovery deployment model in which a secondary instance replicates from the primary across sites. When a failover is needed, DSM provides a switchover workflow that reverses the roles of instances, redirecting the secondary to become the new primary and restoring the database service to a fully operational state. DSM also provides a switchover workflow for failback, allowing operators to reverse instance roles again after the primary site is restored. DSM requires trust validation of the new primary database certificate when redirecting secondary instances during disaster recovery switchover, and operators with the DSM user role must manually establish trust between primary and secondary instances by retrieving the Certificate Authority from the primary and adding it to the Provider VM that will host the secondary. For backup-location certificates, DSM supports a Trust On First Use (TOFU) configuration that extracts and trusts certificates for specific backup locations, and at least one backup location must be configured with a trusted root certificate when a data service policy requires or allows automated backups. DSM also preserves the backing virtual machines of removed database nodes in an idle state until an instance is promoted again, maintaining infrastructure capacity for disaster recovery operations.

The resiliency of the DSM Provider Appliance itself is supplied by the underlying VCF platform (see VCF Coverage); DSM relies on vSphere High Availability to restart the appliance on another host in the event of a host failure, and does not add a separate management-plane HA mechanism. If a DSM provider restore fails for any reason, the documented procedure is to re-deploy the appliance and then follow the recovery procedure again rather than re-attempting the restore workflow on the same appliance.

DSM tracks recovery operations through its audit and operations interfaces. Event logs record Provider Restore Success events with timestamps, allowing operators to verify that recovery operations completed. Restore operation progress is visible in the Operations tab and Operations view, and a new entry appears in the Databases view table when a restore completes. To support integrity of recovery artifacts, the DSM Consumption Operator deployment includes Signature Verification of packages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer recovery and reconstitution mechanisms at the load balancing and application delivery tier.

The Avi Controller cluster can be deployed across two availability zones, with defined failure scenarios and documented recovery actions for each zone-loss case. Availability zones should be configured based on fault domains associated with shared power supplies, shared networking devices, or other common infrastructure to reduce the risk of virtual service unavailability. When the cluster enters manual recovery state following a failure or compromise, Avi automatically revokes all Service Engine secure channel credentials and causes Service Engines to reboot themselves, halting all application traffic

delivery. This returns the data plane to a controlled, known state. Service Engines that subsequently re-establish connectivity to a recovered Controller node reconfigure themselves automatically to connect only to that node.

If all three Controller cluster nodes are permanently unavailable, recovery must be performed using a backup and restore procedure. When a Controller node fails but is not permanently lost, it can be recovered by bringing the existing node back online, which is transparent to existing data traffic, or by rebuilding a new Controller node, which is disruptive to existing connections. Factory reset recovery is irreversible and deletes all Controller configuration, requiring the database to be recreated from the configuration archive. When a Service Engine is compromised or rebooted independently, all configurations including private keys and public certificates are wiped from the Service Engine, providing a clean starting state for reconstitution.

Elastic High Availability (Elastic HA) provides fast recovery for individual virtual services following the failure of a Service Engine, redistributing workloads to surviving Service Engines without requiring a full cluster-level recovery event. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, so application services are restored in a defined sequence.

Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling global-level recovery and reconstitution for applications served across multiple sites.

Avi provides configuration backup and restore capabilities for the Controller. A remote backup destination should be specified to protect against non-recoverable Controller cluster failures. The Controller checks and obtains user consent prior to performing a restore operation. After a storage failure requiring a full restore, the Controller is restored from the configuration archive. The restore process follows a defined sequence: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Post-restore validation verifies the count of restored configuration objects, including clouds and Service Engine groups, confirming that the reconstituted state matches the backup. Restore operations report state information including the operation type, image version, and cluster node name. The Controller logs restore completion events with timestamps, node IP addresses, task status, and success or failure messages for audit trail purposes.

Avi's recovery mechanisms address the application delivery tier. VM-level backup and restore for the Controller and Service Engine VMs, storage-level recovery, and infrastructure reconstitution depend on the underlying VCF platform. See VCF Coverage for those mechanisms.

Control CC8.1

The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.

SCF Controls: BCD-01, CFG-01, CFG-02, CFG-02.1, CFG-02.2, CHG-01, CHG-02, CHG-02.1, CHG-02.2, CHG-02.3, CHG-03, CHG-04, CHG-04.1, CHG-04.4, CHG-05, DCH-01, DCH-01.2, IAC-15.9, PRI-01, PRI-04, PRI-04.1, PRM-07, SEA-01, SEA-01.2, VPM-01, VPM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides mechanisms that enforce organization-defined change authorization through approval workflows, role-based access controls, policy hierarchies, allowlist-based action restrictions, and configuration drift detection. These mechanisms require organization-approved change requests before modifications take effect.

VCF Automation includes approval policies that require designated administrators to review and approve changes before they are applied. These policies can be configured to require project administrator review of all changes to deployed catalog items, particularly those used by multiple teams. When approval policies are active, change requests that remain unapproved after a defined period can be configured to be automatically rejected, blocking deployment or modification of cloud resources without explicit authorization. An enforced policy can also be set to automatically approve or reject a request if the approver does not take action within the configured timeframe. Custom user roles can be created to grant specific permissions, including the ability to review and respond to approval requests, allowing organizations to designate appropriate change approvers.

Day 2 action policies in VCF Automation further restrict what modifications users can make to existing deployments and their component resources. These policies operate by creating a list of permitted actions, so any change not explicitly listed is prohibited by default. Project administrators can selectively entitle project members to specific operations, such as snapshot and revert actions, without requiring administrator intervention for those particular operations while still restricting all other changes. This keeps the approval process proportionate to the risk of each action.

Role-based access controls restrict which users can initiate changes at multiple levels of the platform. NSX Manager applies role-based access control to restrict system access to authorized users by assigning roles with specific permissions. Organization administrators cannot edit global roles published to their organizations, and organization users can exercise only those rights from their roles that have been published to their organizations, limiting the scope of changes any individual can perform. Runtime defined entities can only be modified by users who hold both the appropriate Edit right and a change-level ACL entry. Access to specific entity types can be granted only to designated users and organizations. System administrators with the Manage General ACL right can create, modify, and remove specific access control lists through the accessControls API, providing granular control over who can make what changes. These authorization controls apply consistently regardless of operational context.

VCF enforces a policy hierarchy that restricts unauthorized weakening of security controls. A restrictive security policy created by an organization administrator at the organization level cannot be overwritten by a less restrictive policy at the project level. Inherited policies cannot be modified or deleted at lower levels, though direct policies for a given object can be edited or removed. This hierarchy maintains consistent change controls across the environment and restricts lower-level administrators from circumventing organization-wide restrictions.

The Consumption layer of VCF, which includes VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends these change controls into Kubernetes workload environments. The Kubernetes API server is the single supported path for all resource changes in a cluster, with every write operation requiring authentication followed by authorization. Kubernetes RBAC Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings define precisely which subjects can perform which verbs on which resources, and the RBAC API includes built-in privilege escalation protection that helps prevent users from editing roles or role bindings to obtain permissions they do not already hold, enforced at the API level regardless of the authorizer mode in use. VKS Cluster Management Policies apply a strict hierarchical enforcement model

where policies can only be modified or deleted at their source of origin; inherited policies are immutable at the tenant level, extending the platform-level change restriction hierarchy into Kubernetes workload management. Cluster administrators can deploy `ValidatingAdmissionPolicy` to declaratively restrict what changes can be made via the Kubernetes API, protecting platform namespaces from deletion and restricting write actions on specific resource types beyond what RBAC alone covers. When `ValidatingAdmissionPolicy` is configured with a match policy of `Equivalent`, it applies to requests regardless of which API group or version was used to access the resource, maintaining consistent enforcement as APIs evolve. For sensitive workloads, `ValidatingAdmissionPolicy` can further narrow the permitted change surface; `ValidatingAdmissionPolicy` is also the recommended mechanism for protecting specific resources such as `ResourceQuota` objects from unauthorized modification. Admission control modules, including admission webhooks, can reject or modify requests to create, modify, delete, or connect to objects at the API boundary before they take effect. VKS Cluster Management Mutation Policies can enforce pod specification conformance at admission time, and because mutation policies follow the same hierarchical enforcement model, inherited mutation policies cannot be modified at child levels. VKS Cluster Management Policy Templates are the source blueprints for policies across the cluster estate; they can only be created and managed through their full lifecycle by Organization Administrators. Project Administrators can apply these templates within their projects and clusters but cannot modify the original templates. VKS Cluster Management custom policies can only be edited or deleted by users assigned the Organization Administrator or Project Administrator role, restricting policy modification to designated roles. Pod security policies on system namespaces (`kube-system`, `tkg-system`, and `vmware-system-cloud-provider`) cannot be changed, establishing a baseline that tenant operations cannot override. VKS local content libraries support Security Policy enforcement that controls access to and usage of vSphere Kubernetes releases. Supervisor enforces vSphere Namespace RBAC to restrict connections to Supervisor and VKS clusters based on user permissions, applying consistent authorization at the Consumption layer boundary. The Consumption layer also supports immutable infrastructure patterns, where automated processes overwrite unauthorized changes or systems are configured to reject changes outright, making unauthorized modifications easier to detect and remediate. Where organizations deploy the Argo CD Supervisor Service for GitOps-based change delivery, Argo CD enforces access controls across all components and manages secrets securely outside of Git, providing a controlled delivery pipeline through which changes are tracked and deployed consistently. Organizations should separately restrict access to underlying cluster components such as `etcd` and node-level configurations, as direct access to those layers bypasses API server controls.

At the infrastructure level, VCF validates proposed changes against compliance requirements before applying them. vSAN rejects storage policy changes immediately when they violate policy compliance or when the underlying storage capabilities do not support the requested change, such as attempting a RAID-5 to RAID-6 change on a cluster that cannot support it. At the virtual networking layer, the default security policy of a distributed virtual switch is to reject MAC address changes. Both standard and distributed virtual switches can be configured to accept or reject promiscuous mode, MAC address changes, and forged transmits, giving administrators explicit control over which network-level configuration changes are permitted on virtual switch ports.

VCF Operations provides configuration drift detection that compares the current state of VMware vCenter and cluster objects against desired-state configuration templates. Drift detection can be scheduled to run automatic checks at a configurable interval, and drift reports can be viewed and downloaded for each vCenter instance. When configuration templates are managed in source control, VCF Operations tracks whether the current template reflects the desired state and detects divergence. This allows administrators to identify unauthorized or unintended configuration changes and take corrective action.

User permission changes are tracked to provide an audit trail of when such changes were made and who made them, supporting after-the-fact review of change authorization.

VMware vDefend (Contributes)

VMware vDefend contributes to testing and documenting proposed changes before production deployment through its draft configuration management system for firewall policy, migration evaluation tooling, and pre-deployment validation workflows. Establishing formal non-production environments remains an organizational responsibility; vDefend provides structured workflows that allow changes to be reviewed and validated before taking effect in the production environment.

The vDefend distributed firewall supports a draft-based change workflow that separates authoring firewall rules from their enforcement. Administrators create draft configurations representing proposed changes. These drafts are saved as working configurations before being published, and the draft details view displays the required changes needed to synchronize the current firewall configuration with the draft, giving administrators visibility into the impact of proposed changes before committing them. Publishing the draft applies all visible changes to the active firewall configuration, providing a clear boundary between proposed and enforced policy states. During publishing, a new auto draft is created capturing the pre-publish configuration, which can be republished to revert to the previous state if a change produces unexpected results. In Global Manager deployments, both automatic and manual drafts follow the same rules as local Distributed Firewall drafts, extending this workflow to federated environments.

The 9.1 documentation introduces a migration tool for workload transitions from VCD to VCF Automation. Before any changes are committed, the tool runs an Evaluation phase that generates an Evaluation Plan providing upfront insight into which components will be migrated or skipped. Administrators can remediate identified issues in the source environment before rerunning migration plan generation. The migration tool records a detailed plan capturing the previous state and new state of every rule for audit and compliance purposes. A successful rollback is confirmed when the infrastructure state in VCF Automation matches the state documented before the migration began.

The Security Services Platform deployment wizard conducts validations before implementing configuration changes to verify that configurations are correct and compatible. When upgrades are planned, conducting prechecks on all components is essential to detecting issues before proceeding. The Security Services Platform also evaluates whether workloads are protected by environment-specific segmentation policies covering Dev, Prod, and Test tiers, and the documentation recommends blocking all traffic between Testing and Production environments as an initial segmentation step, supporting isolation between non-production and production workloads. Isolating development, staging, and production environments through segmentation can reduce the risk of cross-environment contamination.

For IDS/IPS signature management, vDefend recommends exporting the existing custom signature bundle to a local system before modifying it with new signatures and uploading the revised bundle. The IDS/IPS system provides bulk edit functionality to modify signature action settings (Alert, Drop, or Reject) and operational status (Included or Excluded) across multiple pages simultaneously, enabling efficient review of signature configuration changes before deployment. The vDefend Threat Intelligence Service Portal includes a Bundle Change Log where administrators can review updates and modifications made to application IDs and IDS signatures over time, supporting documentation of signature changes as part of a change management workflow. NDR sensor upgrades include a verify upgrade-bundle command that extracts the bundle contents and verifies the bundle signature before the upgrade proceeds.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site

or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports configuration management by providing structured mechanisms for defining, applying, and monitoring the configuration of database infrastructure components. Administrators interact with DSM through two primary interfaces: the Provider UI for system-wide settings and the vSphere Client for infrastructure configuration. The Settings view in the Provider interface is the central location for managing system-wide settings, including LDAPS integration, SMTP configuration, and directory service settings. The Administrator Dashboard displays at-a-glance metrics covering the number of configured users, their assigned roles, and the types and counts of provisioned database services, giving administrators a current view of deployment state.

Infrastructure configuration in DSM is governed by infrastructure policies. These policies define which VM classes are available for database VMs, which storage policies apply, and which vSphere clusters and namespaces are used during provisioning. Infrastructure policy configuration requires that placements, storage policies, VM classes, and IP ranges be correctly configured for valid policy status. Policies that are actively in use by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added; unused policies can be changed at any time. VM classes are configurable resource profiles that specify vCPU cores and memory allocation, and can be defined to match organizational capacity standards. Infrastructure policies also establish guardrails that restrict the quantity and quality of resources DSM users can consume from vSphere clusters. Configuration tasks performed during initial deployment include configuring IP pools, defining VM classes, assigning user permissions, creating infrastructure policies, and selecting storage policies.

Database-level configuration is managed through the database instance settings. DSM allows configuration of database instances using either custom or default configuration profiles, with configuration properties varying by database type (PostgreSQL, MySQL, MinIO, or SQL Server). DSM automates provisioning, backups, and security patch application for managed database instances. After initial provisioning, database VM resource configuration can be adjusted at runtime. Optional database configuration parameters for PostgreSQL and MySQL databases can be added or removed after database creation. Maintenance windows can be configured to control when software updates and database option changes are applied, providing a mechanism for scheduled, controlled configuration changes.

DSM provides a Maintenance Policy editor, accessible from the Version & Upgrade section under the DSM System tab, for configuring automatic software updates of the DSM plug-in within defined maintenance windows. The DSM controller manages component and feature dependencies through status monitoring and automated remediation.

When integrated with VCF Automation, DSM supports data service policies that define and enforce configurations for each tenant or organization. These policies can be enforced across different namespaces and namespace labels to maintain a uniform configuration posture. The Consumption Operator automates database deployments based on predefined infrastructure and backup policies, reducing the scope for manual configuration drift.

DSM provides visibility into configuration activity through the Operations tab, which displays the progress of database configuration changes, resource changes, and disk extension tasks. A support bundle can be created and downloaded to collect diagnostic information for troubleshooting system configuration failures. DSM system configuration is also managed through a `dsmsystemconfig` Custom Resource within the gateway, which can be inspected via SSH access to the appliance VM to review directory service status and configuration details.

DSM's contribution to a configuration management program is at the platform level: it provides technical mechanisms for defining baseline configurations through policies and VM classes, enforcing them during provisioning, and tracking changes through operational visibility. The broader configuration management program, including change control processes,

configuration baseline documentation and approval, configuration audits against external standards, and periodic review cycles, must be established and maintained by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: CONFIG_CREATE, CONFIG_UPDATE, and CONFIG_DELETE. CONFIG_UPDATE events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

Control CC9.1

The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.

SCF Controls: BCD-01, BCD-07, RSK-01, RSK-03, RSK-03.1, RSK-06.2, RSK-08, THR-01, THR-09, TPM-01, TPM-02, TPM-03, TPM-03.1, TPM-03.2, TPM-03.3, TPM-04.4, TPM-05, TPM-06, TPM-07, TPM-08, TPM-09, TPM-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's ability to implement alternative or compensating security controls when primary security functions are unavailable or compromised. VCF's layered security architecture means that multiple independent controls address the same security objectives, providing natural compensating coverage when any single control is disrupted. While the decision to select and activate compensating controls is an organizational process, VCF offers the mechanisms through which those controls can be implemented at the infrastructure layer.

For network isolation, VCF provides several complementary mechanisms that can function as alternatives to one another. The distributed switch includes built-in security controls that help protect network traffic at the virtual layer. NSX segments enforce logical network separation and VLANs provide Layer 2 isolation. If one isolation mechanism is bypassed or unavailable, the others continue to restrict lateral movement. VMware vDefend, a separate product that extends NSX with security functions, adds Gateway Firewall for Layer 3 and Layer 4 perimeter rules and Distributed Firewall (DFW) policies on the virtual distributed switch. vDefend organizes DFW policies into categories that include an Emergency category specifically designed for quarantine or allow rules, which administrators can use to rapidly deploy compensating firewall rules when a normal security function is disrupted. vDefend also supports microsegmentation as an additional independent layer.

VCF Automation provides security groups that can be used to define isolation settings for on-demand private or outbound networks. These security groups offer an alternative means of enforcing network segmentation and isolation when other controls may be unavailable. The platform also enforces a policy hierarchy in which a restrictive security policy created by an organization administrator at the organization level cannot be overwritten by a less restrictive policy at the project level, helping to maintain a security baseline even when individual controls are adjusted or replaced.

For access control, VCF implements role-based access control at multiple levels. VMware vCenter allows fine-grained control over authorization with permissions and roles, associating roles to users or groups on objects in the vCenter object hierarchy. Custom roles with granular privilege assignment and permission propagation to vSphere objects can be created. VCF Operations restricts the ability to modify security configurations to authorized users through its own RBAC model, helping to maintain control integrity during transitions between primary and alternative security measures. VCF SSO provides centralized management of federated access through unified identity configuration, and identity federation allows organizations to use the same corporate identity source across their environment. If an identity provider is temporarily unavailable, local fallback accounts can maintain administrative access, and organizations can configure multiple identity sources as alternatives to one another.

For data protection, VCF supports multiple independent controls operating at different layers of the stack. TLS encryption protects management interfaces and API endpoints, with components such as NSX Manager supporting TLS protocol version configuration and cipher suite management. Certificate-based authentication secures communication between components. vSAN can encrypt data at rest in the vSAN datastore, encrypting all files, virtual machines, and their corresponding data. vSAN also supports data-in-transit encryption. These are independent controls, and the availability of one does not depend on the others. For workloads running on AMD hardware, vSphere supports AMD Secure Encrypted Virtualization-Encrypted State (SEV-ES), which can be added to virtual machines as an additional hardware-based memory protection layer independent of software-level encryption controls.

The VCF security baseline provides a framework for tailoring security configurations to meet compliance requirements without impacting the platform's ability to meet its design objectives. This baseline can be used to evaluate both default and non-default configurations, allowing organizations to identify where compensating controls may be needed and to validate that

alternative measures maintain the required security posture. The baseline addresses industry-standard best practices, giving organizations a reference point for determining whether alternative controls satisfy the same security functions as the primary ones they replace. Within vCenter, security administrators can also create user-defined security baselines representing organizational security standards and compare individual hosts and virtual machines against those baselines to identify and remediate configuration drift.

VCF Security Operations helps security stakeholders gain visibility into the environment and plan for risk management. VCF Operations provides compliance monitoring that surfaces the security posture of the environment, helping administrators detect when a primary security control has drifted from its baseline configuration. Combined with proactive monitoring capabilities, this provides the ability to detect when a primary security function has become unavailable or compromised, which is a prerequisite for activating compensating controls.

For environments with specific security requirements, VCF supports disconnected or air-gapped deployments where systems operate without internet access. This is an alternative security posture that organizations can adopt as a compensating control when network-based threats are a concern.

The selection, documentation, and activation of compensating controls when a primary control fails is an operational decision that requires organizational processes beyond what VCF provides as a platform. Organizations must define policies for identifying when primary controls have failed, selecting appropriate compensating measures, and validating that the alternative controls satisfy the original security requirement.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between

emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to this control by providing an independent set of application-layer security mechanisms that operate at the application delivery tier, separate from platform-level controls in the VCF stack.

The primary Avi mechanism relevant here is its Web Application Firewall (WAF), which offers a Positive Security model as an application-layer enforcement point. The Positive Security model defines explicitly allowed application behavior: only traffic conforming to defined positive security rules is permitted, and any traffic that does not match is restricted at the proxy boundary. Positive Security Groups are created and configured within a WAF Policy to define allowed request patterns and enforce the positive security model. Because the WAF Positive Security model operates at the proxy boundary independently of network-layer controls, it can act as an application-layer compensating control when lower-level enforcement points are degraded or misconfigured.

The WAF also implements application learning, through which Avi collects behavioral data from application traffic and uses it to refine positive security rules over time. WAF Policies attach a Positive Security group to apply this learned data for ongoing enforcement and to define hit and miss actions. This learning capability allows the Positive Security model to adapt to legitimate application behavior while maintaining its enforcement posture.

Avi's Network Security Policy provides a complementary enforcement layer. The policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. Network Security Policy rules can match on IP address and apply IP Groups to control access, and can block traffic from specific addresses by dropping TCP SYN packets before connections are established. Through the Controller CLI's `configure networksecuritypolicy` command or the UI, administrators can create or modify a Network Security Policy scoped to individual virtual services. This policy can be tightened as a compensating measure while remediation of a compromised platform control is in progress.

Avi Controller ControlScripts add an automation layer: when invoked by alert actions, they can automatically add offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts can also integrate with external systems through API sessions to respond to security alerts.

In 9.1, the Avi Cloud Console introduces a Live Security Threat Intelligence service that includes an Application Rules Service customers can enable on their Avi Controllers to protect applications from known vulnerabilities. This cloud-delivered

capability provides an additional application-layer enforcement mechanism that operates independently of on-premises controls and can supplement or substitute for local WAF rule sets when primary enforcement paths are degraded.

Identifying which scenarios require compensating controls, determining when to activate them, formally documenting those decisions, and reviewing their adequacy over time are organizational risk management processes. Organizations must establish and maintain the governance framework that determines when and how these Avi capabilities are invoked as compensating controls.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CC9.2

The entity assesses and manages risks associated with vendors and business partners.

SCF Controls: RSK-09, RSK-09.1, THR-01, THR-02, THR-03, TPM-01, TPM-03, TPM-04.1, TPM-05, TPM-05.1, TPM-05.2, TPM-05.4, TPM-05.5, TPM-05.6, TPM-05.7, TPM-07, TPM-08, TPM-09, TPM-10, VPM-01, VPM-01.1, VPM-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P1.0

Privacy Criteria Related to Notice and Communication of Objectives Related to Privacy

SCF Controls: PRI-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P1.1

The entity provides notice to data subjects about its privacy practices to meet the entity's objectives related to privacy. The notice is updated and communicated to data subjects in a timely manner for changes to the entity's privacy practices, including changes in the use of personal information, to meet the entity's objectives related to privacy.

SCF Controls: GOV-02, PRI-01.2, PRI-01.3, PRI-02, PRI-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P2.0

Privacy Criteria Related to Choice and Consent

SCF Controls: PRI-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P2.1

The entity communicates choices available regarding the collection, use, retention, disclosure, and disposal of personal information to the data subjects and the consequences, if any, of each choice. Explicit consent for the collection, use, retention, disclosure, and disposal of personal information is obtained from data subjects or other authorized persons, if required. Such consent is obtained only for the intended purpose of the information to meet the entity's objectives related to privacy. The entity's basis for determining implicit consent for the collection, use, retention, disclosure, and disposal of personal information is documented.

SCF Controls: PRI-03, PRI-03.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P3.0

Privacy Criteria Related to Collection

SCF Controls: PRI-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P3.1

Personal information is collected consistent with the entity's objectives related to privacy.

SCF Controls: PRI-04, PRI-04.1, PRI-04.2, PRI-06.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P3.2

For information requiring explicit consent, the entity communicates the need for such consent as well as the consequences of a failure to provide consent for the request for personal information and obtains the consent prior to the collection of the information to meet the entity's objectives re-

SCF Controls: PRI-03, PRI-03.1, PRI-03.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P4.0

Privacy Criteria Related to Use, Retention, and Disposal

SCF Controls: PRI-05, PRI-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P4.1

The entity limits the use of personal information to the purposes identified in the entity's objectives related to privacy.

SCF Controls: PRI-05.1, PRI-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P4.2

The entity retains personal information consistent with the entity's objectives related to privacy.

SCF Controls: PRI-01.6, PRI-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P4.3

The entity securely disposes of personal information to meet the entity's objectives related to privacy.

SCF Controls: AST-09, DCH-08, DCH-09.3, DCH-21, PRI-05, PRI-06.4, PRI-06.5

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several mechanisms that facilitate the sanitization of personal data across the platform's storage, compute, automation, and operations components.

vSAN data-at-rest encryption protects data on storage devices, and when encryption keys are destroyed through the key management server (KMS) or vSphere Native Key Provider, all associated data becomes cryptographically inaccessible. This cryptographic erasure approach supports sanitizing personal data without requiring physical media destruction. vSAN also includes an "Erase disks before use" option during encryption configuration, which wipes existing data from storage devices as they are encrypted. When devices are added to a vSAN disk group containing residual data or partition information, the device must be cleaned before it can be claimed. Administrators can wipe ineligible disks through the vSAN Management APIs after verifying partition tables and stored data. VMware recommends enabling data-at-rest encryption and secure erasure features in vSAN.

For key lifecycle management, vSphere supports both shallow rekeying (rotating key encryption keys only) and deep rekeying (generating new data encryption keys and rewriting encrypted data). Deep rekeying replaces all keys and rewrites encrypted data on powered-off virtual machines and their disks. The vSphere Web Services API provides `removeKey` and `removeKeys` methods that allow programmatic deletion of cryptographic keys from VMware vCenter, with an optional `force` parameter. The `force` option is intended for cases where a key has been compromised or expired, removing it from use across the environment. On VMware ESX hosts, calling `removeKey` without the `force` option deletes the key from the host's key cache and renders any encrypted virtual machine using that key unusable. These API methods support automated key destruction workflows as part of a cryptographic erasure process.

For virtual machine data, VM encryption encrypts all virtual machine files containing sensitive information, including guest data not stored in the VMDK file. VM encryption supports encrypting virtual machine files, virtual disk files, and core dump files. Deleting an encrypted VM along with its associated keys renders the data unrecoverable.

VCF Automation includes a sensitive data masking capability that protects passwords, credentials, and other sensitive information within machine configurations, image profiles, and projects. The API supports a dedicated (`(sensitive:...)`) notation that masks sensitive values, preventing their exposure in configuration outputs and logs. This mechanism applies broadly to any sensitive data stored within Automation workflows, including personal data embedded in configuration payloads.

For components that store structured data, vSphere provides data set management capabilities that include the ability to delete data sets entirely. The platform documentation directs that sensitive data such as passwords or private keys should not be stored in plain text in data sets. When data sets are no longer needed, the deletion capability supports sanitization by removing the stored content.

VCF Automation and VCF Automation for VM Apps both implement explicit consent mechanisms for exposing user names, designed to support compliance with privacy regulations. These controls restrict the display of personally identifiable information unless explicit consent has been granted, providing a privacy-by-default posture that limits personal data exposure. Administrators can configure whether user names are displayed or hidden in the interface.

VCF Operations provides the option to store sensitive information in orchestrator configuration elements or in external password vaults. Using external vaults centralizes sensitive data management and simplifies sanitization, since credentials and personal data can be rotated or removed from a single location rather than scattered across individual component configurations.

Administrators should be aware that ESX core dumps may contain sensitive information such as host keys. The platform documentation directs organizations to follow their data security and privacy policies when handling core dumps, which may include sanitizing or securely disposing of dump files that could contain personal data. Disabling data protection features does not automatically remove previously created backups, so sanitization of personal data within backup stores requires explicit action to delete or purge those backup artifacts.

Identifying which workloads contain personal data, defining sanitization policies meeting jurisdictional requirements, and operating sanitization workflows when devices are decommissioned or repurposed are organizational data-policy decisions.

VMware vDefend (Contributes)

VMware vDefend contributes to secure information disposal through mechanisms built into its security analytics and threat prevention components. While vDefend is not a storage or media sanitization product, it collects and retains security-relevant data including network flow records, threat analytics, security policy metadata, and classification labels, and provides mechanisms for disposing of that data when it is no longer needed.

Security Services Platform provides deactivation paths that result in permanent deletion of associated data. Graceful deactivation of Bare Metal Security Service deletes all associated server information including certificates and inventory, and blocks the decommissioned server from reconnecting to the platform. A forceful deactivation path is also available that performs the same permanent data removal and deregistration. When an NDR Sensor is offboarded, Security Services Platform clears all registration and trust data from the system. The force offboard endpoint capability in Endpoint Management immediately deletes all endpoint data from the License Hub. Deleting a Security Services Platform instance removes the platform and all its associated components.

Security Services Platform supports certificate management with an explicit Remove action, including deletion of certificates for web proxies. Role assignments for remote users and groups can be deleted when LDAP is configured as an authentication provider. The platform backs up tokens and Bare Metal server inventory as part of inventory backup, supporting controlled lifecycle management and enabling intentional disposal after a backup is confirmed.

Malware Prevention Service rules and Service Virtual Machines can be deleted through Security Services Platform. The platform records metrics for purged records from Malware Prevention Service tables, covering inspection events, intercepted entities, and malware classification data, providing visibility into automated data purge activity.

Security Intelligence supports label deletion, which clears all associated label assignments to compute entities in the Security Intelligence visualization. Label assignments are also automatically cleared up to 30 days after an associated compute entity is deleted from inventory.

These capabilities address the disposal of vDefend's own operational and security analytics data. Broader information disposal requirements, such as sanitizing storage media, managing organizational data retention schedules, enforcing disposal verification processes, and cryptographic erasure of application data, fall outside vDefend's scope and are handled by other VCF components or organizational processes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to the sanitization of Personal Data (PD) through application-layer log masking controls that limit how personally identifiable information appears in logged traffic data.

Avi's Analytics Profile includes a Sensitive Log Profile that controls the handling of sensitive data in client logs. Administrators configure this profile to mask or suppress fields matching defined patterns, including REQUEST_COOKIES, Args:Password, and other sensitive parameters the organization specifies. Maintaining a common Analytics Profile across all WAF virtual services with these masking rules helps limit PD exposure in logs. The Sensitive Log Profile applies to both standard application logs and WAF logs, masking cookies and other sensitive fields before log records are stored or forwarded. Avi documentation includes a dedicated section on masking and removing personally identifiable information in application logs, covering URI masking and cookie suppression as specific use cases.

DataScripts provide programmable policies that can inspect and manipulate client HTTP requests and server HTTP responses, including content switching, header manipulation, and logging behavior. This capability supports use cases such as stripping sensitive fields from application traffic before it is logged or forwarding data with specific headers removed.

These capabilities address log-level and traffic-layer handling of PD within Avi's application delivery scope. Storage-level sanitization of PD on underlying disk media is handled by VCF through hypervisor-level controls. Organizational processes for PD lifecycle management, including data subject deletion workflows and retention policy enforcement, require capabilities and governance frameworks beyond what Avi provides.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P5.0

Privacy Criteria Related to Access

SCF Controls: PRI-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P5.1

The entity grants identified and authenticated data subjects the ability to access their stored personal information for review and, upon request, provides physical or electronic copies of that information to data subjects to meet the entity's objectives related to privacy. If access is denied, data subjects are informed of the denial and reason for such denial, as required, to meet the entity's objectives related to privacy.

SCF Controls: DCH-22.1, PRI-06, PRI-06.4, PRI-07.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P5.2

The entity corrects, amends, or appends personal information based on information provided by data subjects and communicates such information to third parties, as committed or required, to meet the entity's objectives related to privacy. If a request for correction is denied, data subjects are informed of the denial and reason for such denial to meet the entity's objectives related to privacy.

SCF Controls: DCH-22.1, PRI-06.1, PRI-06.2, PRI-06.3, PRI-06.4, PRI-07.4, PRI-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P6.0

Privacy Criteria Related to Disclosure and Notification

SCF Controls: DCH-03.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF restricts the disclosure of sensitive and regulated data to authorized parties through layered access controls, data classification mechanisms, and audit capabilities that enforce need-to-know principles across the platform.

VCF SSO provides centralized authentication, and all components enforce role-based access control (RBAC) against that identity. VMware vCenter's authorization model maps users and groups to roles containing specific privilege sets and applies those mappings at the level of individual managed objects such as clusters, folders, resource pools, and virtual machines. This means administrators can scope access so that users see only the resources relevant to their responsibilities. The Datastore > Browse datastore privilege, which controls the ability to view, upload, and download files directly on datastores, should be assigned only to users or groups with a specific operational need, as broad access to this privilege can expose virtual machine data stored on shared datastores.

VCF Operations enforces privilege-based access control that restricts users without appropriate privileges from viewing collected data for managed objects. This limits visibility into operational metrics and configuration details on a per-object basis. Scope-based access control further limits what objects a user or group can see at all. VCF Operations also supports VCF SSO integration with an identity provider for centralized authentication across VCF components.

VCF Automation enforces granular entity-type access control, allowing administrators to grant access to specific entity types only to designated users and organizations. This restricts who can view or interact with particular resources, limiting data exposure to those with a legitimate need. Content sharing policies in VCF Automation support a hard enforcement mode that controls access to catalog items, restricting which users can discover and consume shared content. Where catalog items require additional governance, administrators can apply content sharing policies to those items with enforcement that helps prevent access by users outside the designated scope.

VCF Automation supports field-level access control on defined entity type properties, which can be marked as public, protected, or private. Public fields are visible to all users, while protected and private fields require elevated rights. Only users with Admin Full Control or both Full Control and a Full Control ACL can create and modify protected or private fields, restricting sensitive entity data to authorized administrators.

For sensitive data in provisioning workflows, VCF Automation allows data to be explicitly marked as sensitive using a dedicated prefix syntax. Marked data is encrypted by default, and only the encrypted form is visible in API responses, preventing inadvertent disclosure through the API. HTTP-REST plug-in objects treat sensitive information as internal and do not expose it through scripting properties; instead, sensitive values can be stored in VCF Operations Orchestrator configuration elements or delegated to external password vaults, keeping secrets out of general-purpose storage. The platform guidance for vSphere data sets explicitly directs administrators not to store sensitive data such as passwords or private keys in plain text.

VCF Automation and VCF Automation for VM Apps include a data compliance consent mechanism that must be explicitly enabled before the names of users are exposed through the platform. This setting provides administrators with a deliberate control point for restricting disclosure of personally identifiable information in support of data privacy requirements.

For cryptographic operations, vSphere provides a "No Cryptography Administrator" role that carries all Administrator privileges except Cryptographic Operations. Administrators can clone this role and create custom roles with only specific cryptographic privileges, such as allowing encryption but not decryption. This separation of duties restricts a single administrator from having unrestricted access to encrypted virtual machine data.

For Kubernetes workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, the platform provides a dedicated Secrets resource type for storing sensitive data such as credentials, tokens, and certificates, separating this data

from ordinary configuration stored in ConfigMaps. Platform guidance directs operators to use Secrets rather than ConfigMaps for confidential data. vSphere Namespaces restrict access through three permission levels (Owner, Edit, and View) that map to Kubernetes ClusterRoles, limiting who can see or interact with containerized workload resources and their data. The Namespace Owner, Edit, and View roles are scoped to namespace-level resources, while broader vSphere Administrator and Supervisor Administrator roles control access to cluster-level and infrastructure objects. Namespace boundaries provide structural isolation: RBAC grants within one namespace do not extend to others, supporting the mapping of access domains to teams, applications, or data sensitivity tiers.

Kubernetes RBAC rules can be configured with least-privilege access to Secrets, restricting which users and service accounts can read or modify them. Because list and watch operations on Secrets return their full contents, platform guidance recommends restricting these permissions to only the most privileged system-level components and granting only get access where a component's normal behavior requires it. Granting broader list or watch access on Secrets constitutes a privilege escalation risk, as these operations expose Secret contents through list responses. Secrets can be mounted into specific containers within a Pod rather than being made available to all containers, scoping exposure to only those containers with a demonstrated need. Short-lived Secrets can limit the impact of inadvertent exposure. Administrators can configure audit rules to alert on specific events, such as concurrent reading of multiple Secrets by a single user, supporting detection of anomalous access patterns. When a Pod that depends on a Secret is deleted, the kubelet deletes its local copy of the confidential data. For environments with access control requirements beyond standard RBAC, such as restricting access to Secrets based on resource annotations, Kubernetes supports integration with third-party authorization mechanisms to enforce finer-grained policies. Platform guidance also directs that applications reading Secrets from environment variables or mounted volumes must not log those values in clear text or transmit them to untrusted parties, since the application itself becomes a potential disclosure point once it has read the value.

The Secret Store Service on vSphere Supervisor stores sensitive data such as credentials, tokens, and access keys as encrypted values, and enforces role-based access control for administrators, DevOps engineers, and application tenants when managing and distributing that data across the Supervisor environment. Secrets can be created, updated, and deleted through the VCF CLI or the Secrets Service page. For environments requiring external secret management, the platform supports integration with third-party Secrets store providers via the Kubernetes Secrets Store CSI driver, keeping sensitive data outside the cluster and granting workloads access through narrowly scoped credentials. The Argo CD Supervisor Service manages secrets securely outside of Git and enforces access controls across all CI/CD pipeline components; Harness CI/CD integration references HashiCorp Vault for managing API keys, passwords, and certificates within the pipeline.

Node isolation in multi-tenant workload environments limits the risk of information disclosure at the compute level: if a workload escapes a container, it has access only to containers and volumes mounted to that node. The Harbor Registry, available as a standard package for VKS clusters, enforces RBAC and artifact security policies to restrict access to container images and other build artifacts that may include sensitive content. The etcd datastore, which stores all Kubernetes Secrets, should be configured to limit access and not be publicly exposed.

Administrators should be aware that core files and audit logs generated by NSX may contain sensitive information such as passwords or encryption keys. Access to these artifacts should be restricted through operating system and network-level controls. Secrets held within the database of each vSphere Supervisor workload cluster are stored in clear text unless the Secret Store Service or encryption at rest is configured, which means that database access controls remain the primary mechanism for restricting disclosure of those secrets in the absence of additional controls. At the individual virtual machine level, setting the `isolation.tools.setinfo.disable` parameter to true helps prevent VMware Tools from passing information from guest operating systems to the hypervisor management plane, providing an additional mechanism to limit information disclosure from guest workloads.

VCF Operations Security Operations provides visibility into permission changes by logging user permission events with details including the event type, status, the user who initiated the change, a description, and a timestamp. This audit trail supports detection of unauthorized changes to access controls that could lead to improper disclosure of sensitive data.

Defining who has need-to-know, classifying which data is sensitive, and operating the role and entitlement policy that determines disclosure across the environment are organizational responsibilities.

VMware Private AI Services (PAIS) provides layered access control mechanisms across the AI infrastructure stack that restrict disclosure of model data, AI service endpoints, and configuration credentials to parties with authorized access.

The Model Gallery uses Harbor project access capabilities to restrict access to ML models and to the sensitive data used to train and tune those models. Project-scoped access defines which users and groups can pull from or push to the registry, giving administrators a primary control point for which artifacts each tenant can reach.

PAIS enforces service-level access control through OIDC group-based authorization. When activating PAIS in an organization namespace, administrators configure the `authorizedGroups` field with the identity provider group memberships that are required to reach PAIS endpoints. Only user accounts that belong to those configured groups can access PAIS. HTTPS-based communication with the OIDC provider is required, and PAIS uses YAML-formatted CA trust bundles to authenticate connections to the OIDC provider, Harbor registries, content management systems hosting knowledge data, and MCP servers that supply tools to models.

At the VCF Automation layer, PAIS catalog items are governed by project membership in VCF Automation. Secrets used by PAIS, such as private container registry passwords, are stored in VCF Automation under `Administer > Certificates & Secrets > Secrets`. The secret key and value cannot be viewed after creation, only updated, which restricts disclosure of credentials embedded in catalog items. The PAIS DSM database can also be scoped to be shared between developers and catalog users through a single toggle that creates a dedicated catalog item, giving administrators control over who can reach the vector store underlying retrieval workflows.

For knowledge bases used in Data Indexing and Retrieval, PAIS authenticates to external data sources such as Microsoft SharePoint on-premises sites and Amazon S3 compatible stores using credentials configured at data source creation time. These per-source credentials control which external content repositories PAIS can reach for indexing and model context. A knowledge base can be linked to a maximum of ten data sources, and data source types are fixed at creation, which limits the scope of repositories any single retrieval workflow can pull from.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through several network-layer mechanisms that restrict the disclosure of sensitive data to authorized parties.

The Network Detection and Response (NDR) feature anonymizes sensitive customer information when sharing threat data to the cloud, limiting exposure of environment details to authorized channels. Organizations can further control whether threat telemetry leaves the environment through NDR data-sharing settings.

Security Intelligence identifies risky application protocols that transmit data in cleartext, such as HTTP, Telnet, FTP, TFTP, and LDAP, enabling security teams to detect and remediate unauthorized disclosure paths across the network. The Security Services Platform recommends that organizations restrict or block these cleartext protocols and enforce minimum secure versions of commonly used protocols, reducing the risk of data exposure through unprotected network flows.

The Security Services Platform defines an Auditor role that provides read-only access to view information and track activity without the ability to make changes, supporting least-privilege access to sensitive platform information. Platform role-based access controls restrict who can generate, modify, or view security recommendations and flow data.

Full restriction of unauthorized data disclosure extends beyond vDefend to encompass data loss prevention, endpoint controls, and data classification capabilities outside vDefend's scope.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) restricts disclosure of replicated and recovery data through role-based access controls applied at the protection and recovery layer. PNR access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, scoping who can view or modify protection groups, replication configuration, and recovery plans. Authorized administrators on both source and recovery sites must hold appropriate PNR roles before they can interact with protected workloads or initiate recovery actions.

PNR records operational information in log files that do not contain sensitive material such as private keys or passwords, reducing the risk of inadvertent disclosure through diagnostic output. The Protection and Recovery Global Console maintains a unidirectional data flow from PNR servers to VCF Operations, with VCF Operations not pushing information back to PNR servers or site pairs, keeping central monitoring isolated from the protected environment.

PNR generates permission events that record changes to PNR permissions, providing accountability for changes to the access controls that govern disclosure of recovery-protected data. Recovery plan execution details, including plan name, status, folder location, and mode of operation, are recorded, supporting after-the-fact review of who initiated recovery actions. Events are captured with timestamp, priority, message content, component name, severity level, configuration ID, component ID, and event type, supporting reconstruction of administrative actions on protected data.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to this control through application-layer mechanisms that restrict which clients receive application data and how sensitive information is handled within Avi's own logs and analytics.

At the application access control layer, Avi's DataScript scripting engine supports credential-based authorization enforcement at the proxy boundary. DataScript can check incoming client credentials or user IDs against string groups configured with key-value pair whitelists and redirect unauthenticated users to a login page, enforcing need-to-know access at the point where requests enter the Avi Service Engine. DataScript also supports blocklist-based access control, checking client IP addresses against named IP groups and terminating connections from listed addresses.

Avi's tenant isolation model provides data plane separation between tenants. Tenants configured in Tenant Context receive both control plane and data plane isolation, scoping which workloads and data are accessible within each tenant boundary. Tenants in Provider Context receive control plane isolation only, which is a relevant consideration when planning multi-tenant deployments that carry sensitive application traffic.

Avi's controller RBAC limits administrative disclosure by restricting which users and teams can read configuration and operational data. Extended granular RBAC uses markers to restrict user permissions to specific resources based on label matching. Label-based permissions for cloud objects are enforced through the `restrict_cloud_read_access` field in controller properties, scoping which users can read cloud configuration data.

Avi supports OAuth and OIDC for client authentication, allowing applications to use delegated access without requiring users to share their credentials directly with third-party applications. The identity provider issues tokens to authorized applications, limiting credential exposure at the application layer.

Avi's Analytics Profile supports a sensitive log profile that controls how sensitive data appears in client-facing logs. Operators can configure this profile to mask or remove sensitive HTTP headers, including cookies and authorization tokens, from application log records, reducing the risk of exposing user credentials and identity data through log access. Avi also supports masking of personally identifiable information (PII) in application logs by removing or masking matched fields in URI and header content.

Avi's Central Licensing service collects only the data outlined in the Privacy document, with no additional data collected by or for the licensing service, which limits administrative data exposure through that channel.

Organizational data classification processes, data handling policies, and the broader platform-level access controls provided by VCF are also required to fully satisfy this control, which is why coverage is Contributes rather than Meets.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control P6.1

The entity discloses personal information to third parties with the explicit consent of data subjects and such consent is obtained prior to disclosure to meet the entity's objectives related to privacy.

SCF Controls: DCH-03.1, PRI-01.7, PRI-07, PRI-07.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P6.2

The entity creates and retains a complete, accurate, and timely record of authorized disclosures of personal information to meet the entity's objectives related to privacy.

SCF Controls: PRI-14.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P6.3

The entity creates and retains a complete, accurate, and timely record of detected or reported unauthorized disclosures (including breaches) of personal information to meet the entity's objectives related to privacy.

SCF Controls: IRO-04.1, IRO-10, IRO-12, PRI-14.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's response to sensitive or regulated data spills, though the procedural and policy aspects of spill response remain organizational responsibilities.

VCF documentation explicitly addresses the handling of sensitive data within the infrastructure. Core dumps generated by VMware ESX hosts can contain sensitive information such as host keys and other credential material. The documentation directs organizations to follow their data security and privacy policies when handling core dumps. This guidance is directly applicable to data spill scenarios, as diagnostic artifacts produced during troubleshooting or incident response may inadvertently expose regulated data. Organizations should incorporate core dump handling procedures into their broader data spill response plans, including secure collection, storage, and disposal of dump files.

When a data spill is identified, VCF offers containment mechanisms at the virtualization layer. NSX projects and security configurations can isolate affected workloads from the broader network, limiting further data exposure. VCF Automation APIs support creating network profiles with isolation by subnet, VLAN transport zone, external subnet, or security group, which can be applied to quarantine contaminated systems and restrict lateral movement during spill containment.

VM snapshots capture the memory, disk, and settings state of a virtual machine at a particular moment. This capability is relevant to spill response because it preserves evidence for forensic analysis while corrective actions are underway. Reverting to a snapshot returns all these items to the state they were in at the time the snapshot was taken, providing a mechanism to restore a VM to a known-good state before contamination occurred.

VCF Operations provides compliance monitoring capabilities that can support the detection of conditions associated with a data spill. The compliance management feature continuously monitors infrastructure against defined policies, detects violations, highlights risk areas, and provides actionable remediation recommendations. When a compliance alert is triggered on VMware vCenter instances, ESX hosts, virtual machines, distributed port groups, or distributed switches, the compliance violations are recorded for investigation. VCF Operations also enables discovery of non-compliant objects and their associated compliance violations to support remedial measures. These detection and alerting capabilities can indicate that configurations have drifted into a state where sensitive data may be exposed, helping response teams identify and scope a potential data spill. Before these monitoring capabilities can be used, organizations must configure the relevant data sources within VCF Operations so that compliance can be measured against them. This configuration step should be part of the organization's readiness planning for data spill response, so that monitoring is active before an incident occurs rather than being stood up reactively.

VCF Log Management provides centralized log aggregation that collects logs from all VCF components, including vCenter, ESX, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. Multiple VCF Log Management instances can be configured for log forwarding, where instances forward logs to a single integrated instance. Log data can also be forwarded to enterprise SIEM platforms for correlation with spill investigation workflows, providing the audit trail needed to determine the scope and timeline of a data exposure event.

For data protection and recovery during spill remediation, the vSAN Snapshot Service provides local recovery points and supports restoring deleted virtual machines from snapshots through its REST API. vSphere Fault Tolerance provides continuous availability for workloads in the event of a hardware failure, supporting workload continuity when contaminated infrastructure needs to be taken offline for remediation. The vSphere documentation notes that Fault Tolerance logging traffic can contain sensitive data, and organizations should secure this network segment to reduce the risk of interception,

particularly against man-in-the-middle attacks. Fault Tolerance log traffic can be encrypted, which limits exposure of sensitive information that may flow through this channel during incident response activities.

The organizational components of a data spill response program, including notification procedures, containment workflows, forensic investigation processes, legal chain-of-custody procedures, regulatory reporting, data classification reassessment, and affected-party communication, must be established and maintained separately from the platform capabilities described above.

VMware vDefend (Contributes)

VMware vDefend contributes to sensitive and regulated data spill response through its Security Intelligence and Security Services Platform (SSP) capabilities. Security Intelligence monitors traffic flows across environments, detects flows not covered by existing VMware vDefend (DFW) rules, and identifies unauthorized data movement between workloads. Administrators can use the Flow Details view filtering capabilities to narrow and investigate specific flows relevant to a spill scenario.

Segmentation Monitoring displays Traffic Flow Trend data including external flows, east-west flows, intraapplication flows, and a graph showing protected versus unprotected traffic flows, giving administrators a clear picture of traffic patterns during an incident investigation.

The Security Segmentation Score and Report Generation capability quantifies the number of unprotected data flows hitting default allow rules out of total unique traffic flows associated with known risk factors, providing a measurable indicator of segmentation coverage that helps administrators assess the scope of a potential spill. Security Intelligence also discovers environments through CSV-based inventory ingestion and provides recommendations based on inter-environment traffic flows, enabling administrators to identify which workloads may be involved in unauthorized data movement.

The Policy Recommendations engine in Security Services Platform analyzes observed leaked flows and generates or modifies DFW rules to contain unauthorized traffic. When a leaked flow is detected, the engine identifies existing rules with matching sources or destinations and modifies non-matching sides to include groups containing the affected workloads, or creates new rules where no existing rule applies. Administrators are directed to monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules as part of the remediation workflow. Segmentation Monitoring tracks protected flows that match pair protection rules or the environment category default rule for an environment pair, supporting verification that containment rules are operating as intended after publication.

Network Detection and Response (NDR) in VMware vDefend anonymizes sensitive customer information when telemetry is shared to cloud-based analysis services, which supports data handling requirements during the investigation phase of a spill response.

Broader data spill response activities, such as legal notification, forensic investigation, and regulatory reporting, remain outside vDefend's scope.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P6.4

The entity obtains privacy commitments from vendors and other third parties who have access to personal information to meet the entity's objectives related to privacy. The entity assesses those parties' compliance on a periodic and as-needed basis and takes corrective action, if necessary.

SCF Controls: DCH-03.1, PRI-01.7, PRI-07.1, TPM-03.2, TPM-05, TPM-05.2, TPM-05.7, TPM-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P6.5

The entity obtains commitments from vendors and other third parties with access to personal information to notify the entity in the event of actual or suspected unauthorized disclosures of personal information. Such notifications are reported to appropriate personnel and acted on in accordance with established incident-response procedures to meet the entity's objectives related to privacy.

SCF Controls: TPM-03.2, TPM-05.7, TPM-09, TPM-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P6.6

The entity provides notification of breaches and incidents to affected data subjects, regulators, and others to meet the entity's objectives related to privacy.

SCF Controls: IRO-04.1, TPM-03.2, TPM-05.7, TPM-09, TPM-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P6.7

The entity provides data subjects with an accounting of the personal information held and disclosure of the data subjects' personal information, upon the data subjects' request, to meet the entity's objectives related to privacy.

SCF Controls: IRO-04.1, IRO-10, PRI-02.1, PRI-04.1, PRI-06.4, PRI-06.6, PRI-06.7, PRI-17, PRI-18, PRM-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P7.0

Privacy Criteria Related to Quality

SCF Controls: PRI-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P7.1

The entity collects and maintains accurate, up-to-date, complete, and relevant personal information to meet the entity's objectives related to privacy.

SCF Controls: PRI-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P8.0

Privacy Criteria Related to Monitoring and Enforcement

SCF Controls: PRI-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control P8.1

The entity implements a process for receiving, addressing, resolving, and communicating the resolution of inquiries, complaints, and disputes from data subjects and others and periodically monitors compliance to meet the entity's objectives related to privacy. Corrections and other necessary actions related to identified deficiencies are made or taken in a timely manner.

SCF Controls: PRI-06.4, PRI-08, PRI-14

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PI1.1

The entity obtains or generates, uses, and communicates relevant, quality information regarding the objectives related to processing, including definitions of data processed and product and service specifications, to support the use of products and services.

SCF Controls: OPS-03, PRM-05, PRM-06, RSK-10, TDA-01.1, TDA-02, TDA-06, TDA-06.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PI1.2

The entity implements policies and procedures over system inputs, including controls over completeness and accuracy, to result in products, services, and reporting to meet the entity's objectives.

SCF Controls: TDA-01, TDA-06, TDA-18

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in input data validation mechanisms across its automation, orchestration, and management components. These capabilities allow administrators and developers to enforce data quality at the point of entry, whether through interactive forms or programmatic interfaces.

The VCF Automation custom form designer supports data validation by adding constraints to form fields. Administrators can configure field-level validation using regular expressions (which must follow both Java and ECMAScript syntax), minimum and maximum value constraints, maximum character length limits, and required field checks. For example, the deploymentName field supports a maximum character length constraint of 900 characters. VCF Automation input properties also support maxLength and minLength attributes to constrain the number of characters allowed for string inputs. Validation rules can be set as constant values or as conditional values determined by expressions, allowing dynamic validation logic that adapts based on other field selections or inputs. Numeric fields support minimum value validation with configurable error messages displayed to the user when input falls outside acceptable ranges. Regular expression validation supports custom error messages following JavaScript syntax, so users receive clear feedback when their input does not match the expected pattern.

VCF Automation also supports external validation through VCF Operations orchestrator action scripts. These external validations run when a user submits a catalog request form from either the UI or the API. The validation action scripts evaluate input parameter values and return a string describing the error when invalid data is detected. When input is valid, the external validation returns nothing, allowing the request to proceed. The names of validation action input parameters must match the names of the workflow input parameters being validated, enforcing a structured approach to validation design. VCF Automation provides a Content and Policies interface to identify which custom forms contain actions that cannot be validated, giving administrators visibility into validation coverage across the environment.

The VCF Operations orchestrator Input Form Designer provides its own input validation capabilities, including regular expression-based validation, minimum and maximum value or length constraints for input parameters, and external actions to validate the inputs of custom workflows. This enables validation at the orchestration layer for automated processes and workflows that accept user or system-provided input.

At the infrastructure layer, VMware vCenter includes a configuration validation process that examines configuration files for possible errors and conflicts and returns output to help administrators avoid configuration issues or loading incorrect configuration files.

At the Consumption layer, VMware Kubernetes Service (VKS), the Supervisor-based Kubernetes environment embedded in VCF, brings input validation to the Kubernetes control plane. The Kubernetes API server embedded in VKS enforces schema-based field validation on all incoming API requests; when configured in strict mode via the ServerSideFieldValidation feature gate, the API server validates each request against the resource's OpenAPI schema and rejects submissions that contain unknown or incorrectly typed fields, whether submitted through kubectl, the API server, or automation tooling.

VKS supports ValidatingAdmissionPolicy, a declarative mechanism for policy-based validation of API objects before they are persisted. Policies are expressed in Common Expression Language (CEL), which supports comparisons, map key existence checks, string pattern matching (including prefix checks via methods such as startsWith()), date calculations, and list membership validation. The Kubernetes CEL format library extends this with a Format.validate(string) function that validates a string against a specified format and returns a list of error strings when invalid. The spec.validations.message field carries human-readable error text to the caller on failure, while spec.validations.reason provides a machine-readable failure code from values including Unauthorized, Forbidden, Invalid, and RequestEntityTooLarge. A spec.variables field supports defining

named CEL expressions that can be composed and reused within the same policy, reducing duplication and computational expense. Policies are bound to resources through `ValidatingAdmissionPolicyBinding` objects, which scope enforcement to specific namespaces via label selectors; when multiple parameter objects match the label selector, policy rules are evaluated for each and the results are ANDed together. For validation logic that cannot be expressed declaratively in CEL, validating admission webhooks provide an extension point for integration with external validation services. The `ValidatingAdmissionPolicy` `status.conditions` array records the latest system observations of a policy's current state, and `status.typeChecking` records type-checking results for each CEL expression to detect missing fields and type confusion.

For user attribute validation, `UserValidationRule` applies a required CEL expression evaluated against `UserInfo` objects to enforce attribute-level constraints on who may interact with specific API resources; the `message` field customizes the error returned when a rule returns false. The Kubernetes declarative validation system supports tags including `+k8s:required` (indicating a field must be specified by clients), `+k8s:minimum` (a numeric minimum value constraint), and `+k8s:neq` (disallowing a specific value, with type inferred from the disallowed value). Custom resource definitions support `FieldValueForbidden` validation, which reports values that would be acceptable under some conditions but are prohibited by current security policy. Organizations are responsible for defining and maintaining the admission policies appropriate to their security requirements; VKS provides the control plane infrastructure on which those policies operate.

For integrations with external systems, the ServiceNow ITSM Plug-in for VCF Automation supports required field validation on data source choices, though regular expression and min/max value constraints are not available for all data types such as dropdown and checkbox fields.

Input validation for customer applications running on VCF is the responsibility of those applications and their developers. VCF provides infrastructure on which workloads run; the application-level input validation required by web applications, APIs, microservices, and data pipelines is implemented in the application code or in security overlays such as VMware vDefend (which provides Web Application Firewall capabilities through Avi Load Balancer) and dedicated DLP, WAF, or API security tooling deployed alongside the platform.

VMware Private AI Services (PAIS) provides a structured ML model validation workflow that checks the validity of model inputs before they are admitted to production use. Before a model can be uploaded to a Model Gallery for use by AI application developers, it must pass a mandatory validation sequence performed in a Deep Learning VM acting as a sandbox environment.

The validation sequence includes integrity verification by hash-code comparison, malware scanning to detect supply chain contamination, scanning for serialization attacks (a class of vulnerability specific to ML model files that can execute arbitrary code on deserialization), and inference behavior testing using Triton Inference Server. Models must be downloaded into the Deep Learning VM from trusted sources such as the NVIDIA NGC catalog, Hugging Face, or another model hub before validation. The Model Gallery preserves the integrity of stored models by assigning a unique digest to each revision when the same model is pushed multiple times, and PAIS uses a Harbor registry in the Supervisor (or an OCI-compliant registry from another vendor) as the model storage backend, requiring authentication and certificate-based trust for model retrieval.

Beyond technical file-level checks, MLOps engineers validate ML models against the security, privacy, and technical requirements of the organization before upload. This includes examining inference requests for malicious behavior and performing hands-on functional tests to confirm the model performs as expected. PAIS guidance is that models be sourced and validated internally rather than consumed directly from the Internet, where they could contain malicious code or be tuned for malicious behavior.

For agent and retrieval-augmented generation workflows, PAIS extends input validation to two additional surfaces. Knowledge Bases that supply context to model responses can be linked to a bounded number of data sources, and PAIS requires examination and approval of MCP server tools and capabilities before they are used in agents, helping prevent unsafe or untrusted external capabilities from being introduced into AI applications.

VMware vDefend (Contributes)

VMware vDefend checks the validity of information inputs across several of its network security subsystems, contributing to the organization's broader input validation posture.

Security Intelligence parses and validates the content format and inventory asset data in administrator-provided CSV files used during segmentation planning imports. When data mapping fails due to file errors, an error notification appears with a link to an annotated CSV file that highlights the specific errors for correction. Administrators can correct and re-upload the file, or allow analysis to continue with incorrect entries excluded from processing. Administrators are advised to validate inventory asset data for completeness before importing CSV files into the Security Services Platform.

Security Intelligence stores system-inferred infrastructure classifications in a "Not reviewed" state until an administrator explicitly accepts or modifies them. This classification review mechanism applies to compute entity classifications used in segmentation planning and policy generation, requiring human acceptance before automated classifications can influence policy decisions.

Security Intelligence Policy Recommendations includes a Monitoring capability that checks for changes in the scope of input entities every hour when enabled. When the monitoring feature detects a change in input scope, administrators are prompted to review the detected changes and rerun recommendation analysis to regenerate policy based on the updated inputs.

Security Intelligence enforces input limits on policy recommendation generation: a maximum of 100 VM entities can be selected as direct input, and the total number of effective VMs when groups are included cannot exceed 500. These constraints are enforced before analysis begins, validating that inputs fall within the range where analysis results are reliable.

The vDefend distributed firewall includes an auditing and remediation workflow that validates rule components, requiring rules to use IPv4 addresses for successful validation through the security gate before deployment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) validates inputs across its recovery-plan, replication, and management surfaces. Configuration data exported in XML format can be validated against an XSD schema, providing structural validation of imported and exported configuration data (p.288). After PNR upgrades, administrators must re-verify that protection groups and recovery plans remain valid before they are placed back into operational use (p.108).

For recovery-plan IP customization, the DR IP Customizer tool uses a structured comma-separated value file with a header row defining column meanings and one or more rows for each placeholder virtual machine in a recovery plan (p.379, p.382). The `dr-ip-customizer` command supports a `--verbose` option that enables additional diagnostic logging for validation of customizer inputs (p.376).

PNR's Cyber Recovery workflow includes explicit validation states for VMs prior to recovery. Cyber Recovery VMs transition through a Preparing validation state and then an In validation state when an administrator selects a snapshot and initiates validation (p.575). Cyber Recovery supports on-demand vulnerability analysis through the Analysis tab to validate workload integrity before completing recovery validation (p.574).

Integrated Security and Vulnerability Analysis with CrowdStrike examines VMs in the clean room using behavioral analysis and machine learning during validation, with continuous analysis of running software and processes on the guest operating system to detect suspicious behavior (p.580). The integration performs vulnerability analysis combining Common Vulnerability Scoring System (CVSS) information with proprietary threat data and advanced modeling from Kenna Security, and identifies vulnerabilities by their CVE designation (p.582). Operators use these signals to select a clean snapshot for recovery rather than restoring a compromised one.

PNR logs certificate verification error messages in security-related log files for audit trail purposes, so that input-validation failures on certificate fields are captured (p.133). For operational health checks, PNR can adjust the number of status check attempts before declaring a check failed using the `connections.hmsPingFailedDelay` parameter (p.440). Trusted environment setup for the PNR Appliance requires text values for organization and organization unit during configuration (p.112). The Clean Room Orchestrator categorizes validation events using Info and Warning severities so that operators can act on input or state conditions surfaced during recovery operations (p.562).

Input validation for customer applications running on workloads protected by PNR is the responsibility of those applications and their developers. PNR provides input validation for its own recovery-plan, configuration import/export, customizer, API,

and orchestration surfaces, and provides Cyber Recovery validation states and CrowdStrike-driven analysis to validate workload integrity before recovered VMs return to production.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to input data validation through mechanisms built into its configuration, policy management, and integration interfaces.

At the policy layer, DSM data service policies support allowlist creation, restricting users to selecting only from administrator-defined sets of approved parameters when provisioning or configuring databases. In 9.1, SQL Server data service policies include an "Allow with a List" option that creates a specific allowlist of approved parameter values users can select from. Policies also enforce required-field validation: administrators must supply a name, description, and target data service before a policy can be saved. When applying a policy to existing databases, DSM displays a preview of any policy violations that would result, allowing review and correction before the policy is created or modified.

DSM validates configuration inputs for backup storage at multiple points. During monitoring, DSM checks the connection to the backup storage repository, verifies the correctness of the bucket name, confirms certificate expiration dates, validates credential currency, and verifies that sufficient available space exists in the repository. Administrators can view these validation results through the database monitoring interface.

In System Settings, DSM validates SMTP configuration inputs when settings are saved and returns an error if validation fails. DSM also requires validation of the SMTP certificate as part of SMTP configuration. NTP server entries are validated and flagged for correction if invalid values are present.

For webhook integrations, DSM provides a TEST function that sends the configured payload to the endpoint URL before the webhook is created, allowing administrators to verify that the endpoint is reachable and that the payload is accepted before deployment.

DSM introduces a "latest" certificate validation mode as the default for version 9.1 and later. This mode enforces strict cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. The validation mode is configurable through the advanced-system-config ConfigMap.

For PostgreSQL databases, DSM includes the amcheck extension, which provides functions for verifying relation integrity at the database engine level.

For local user accounts, DSM enforces password complexity requirements: passwords must be between 8 and 20 characters and include at least one uppercase letter, one lowercase letter, one number, and at least one special character. This validates credential inputs at the authentication boundary. DSM does not send a verification message to confirm the validity of local user email addresses.

DSM's input validation mechanisms cover its own administrative and configuration interfaces. They do not extend to application-layer validation for data flowing through the PostgreSQL, MySQL, or MinIO databases it manages. Input validation for workloads connected to DSM-managed databases is an organizational and application development responsibility.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer input validation through three complementary mechanisms: WAF signatures and the Positive Security Model, DataScript programmable rules, and Avi Kubernetes Operator (AKO) configuration validation.

Avi WAF signatures perform input and output validation by analyzing all incoming and outgoing traffic. The WAF Positive Security Model, also called Application Specific Policy, describes expected application behavior and enforces it by setting an accepted range and length of characters for HTTP fields. Requests that do not meet those specifications are reported as policy violations before reaching backend workloads, allowing administrators to restrict inputs to known-valid character sets and field lengths on a per-application basis. The WAF also provides analytics to identify possible false positives and allows operators to add exceptions through a modal dialog that generates suggested values pre-computed from log entries and related findings, supporting ongoing policy refinement.

DataScript extends input validation with programmable, event-driven logic executed within Avi Service Engines. Using Lua-based scripting with relational, logical, and arithmetic operators, DataScript rules can inspect and validate request parameters, HTTP headers, and request body content. Specific capabilities include an external request validation API that offloads validation decisions to an external service and returns a response object containing status code, headers, and HTTP response body; XML body parsing via the Parse function, which returns a success indicator and either the parsed result or error information if parsing fails; client certificate validation via the `avi.ssl.check_client_cert_validity()` function, which returns distinct values when the certificate is not presented, is valid, or is invalid; conditional clearing of certificate verification errors based on error code evaluation; string pattern functions including `string.contains()` and `string.startswith()` for field content checks; and group-based user identity validation using `avi.stringgroup.equals`, which checks whether a user ID is in an approved list and can redirect unauthenticated users to a login page. DataScript rules should be tested and validated after modification to confirm that the intended validation logic operates correctly without affecting other virtual services.

The Avi Kubernetes Operator (AKO) performs syntactical validations at the time of Custom Resource Definition (CRD) object creation to verify configuration correctness and provides effective status messages. The AKO CRD Operator `condition-status` field indicates whether conditions are 'True' or 'False', supporting automated validation of AKO configuration inputs in Kubernetes environments.

Control PI1.3

The entity implements policies and procedures over system processing to result in products, services, and reporting to meet the entity's objectives.

SCF Controls: OPS-03, PRM-06, TDA-01, TDA-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PI1.4

The entity implements policies and procedures to make available or deliver output completely, accurately, and timely in accordance with specifications to meet the entity's objectives.

SCF Controls: DCH-01, MON-03, MON-08, OPS-03, PES-12.2, PRM-06, TDA-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PI1.5

The entity implements policies and procedures to store inputs, items in processing, and outputs completely, accurately, and timely in accordance with system specifications to meet the entity's objectives.

SCF Controls: DCH-01, DCH-18, MON-08, OPS-03, PRM-06, TDA-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configurable data retention controls within VCF Operations that allow administrators to align operational data retention periods with organizational requirements. These controls do not address the full scope of media and data retention governance, but they give administrators granular tuning over how long different categories of platform-generated data are kept.

VCF Operations exposes data retention settings through Administration > Global Settings > Data Retention. Administrators can configure retention periods independently for several data categories. Metrics data supports a retention window between 1 month and 13 months. Entities and configuration data can be retained for a minimum of 1 month and a maximum of 3 months. Organization reports support a maximum data retention period of 1,440 days. At the normal retention tier, VCF Operations retains data at 5-minute granularity for 6 months, then rolls up the seventh month into 1-hour aggregations. A real-time retention tier provides 5-minute granularity, a standard tier retains data for 1 month, and a long-term tier retains data for 13 months. Different data retention policies can be configured and controlled for each category according to organizational requirements. Log data is governed separately through VCF Log Management, where administrators define log partitions that each carry their own retention period in days, with logs removed from disk automatically once a partition's period elapses and the option to archive partitions to external NFS or S3 storage for longer-term preservation.

VCF Operations for Networks provides additional granular retention controls. The default data retention period is 1 month in the advanced license edition. Flow data retention is fixed at a 1-month window within the platform. For organizations that need to retain flow data beyond one month, the Streaming Databus provides a mechanism to export flows to an external subscriber via HTTPS/HTTP for extended retention. Miscellaneous data retention can be configured with up to 100 GB of additional disk space.

VCF Operations also provides backup capabilities that support regulatory and operational retention needs. Administrators can take regular backups of both custom and out-of-the-box content. When reducing an entity metrics retention period in VCF Operations for Networks, the recommendation is to back up log files first to prevent data loss, which supports the principle of preserving data before modifying retention windows.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds Kubernetes-native persistent storage lifecycle controls relevant to data retention for containerized workloads. Persistent volumes in Supervisor namespaces store application data outside the lifecycle of individual pods and workloads, so data remains available when workloads restart or scale. The central mechanism governing retention behavior is the PersistentVolume reclaim policy, which controls what happens to the underlying storage and its data when the associated PersistentVolumeClaim is deleted. The Retain policy preserves the volume and its data in a Released state for manual administrator reclamation, leaving the data intact for inspection, archival, or transfer before final disposal. The Delete policy causes the storage asset to be removed when the claim is released. Retain is the default for manually provisioned PersistentVolumes. StorageClass definitions carry a ReclaimPolicy field that sets the default behavior for all dynamically provisioned volumes within a given storage class, allowing cluster administrators to enforce organization-wide retention defaults at the storage class level rather than per-volume. For StatefulSet workloads, Kubernetes provides a persistentVolumeClaimRetentionPolicy setting with a whenDeleted field that controls whether PVCs and their backing volumes are retained or deleted when the StatefulSet is removed; scaling a StatefulSet down does not delete the associated volumes by default. Organizations subject to retention obligations should configure StorageClasses with the Retain policy so that workload termination does not destroy data that must be kept for a defined period.

Storage Policy Based Management (SPBM) provides a unified control plane across VKS storage, enabling storage policies to be associated with persistent volumes that capture the storage characteristics required by a given workload or retention regime. VKS clusters surface a storage compliance status per volume: a Compliant status indicates that the datastore backing the volume satisfies the requirements of the associated policy; an Out of Date status indicates the policy has been updated but the new requirements have not yet been communicated to the datastore, requiring the policy to be reapplied to bring the volume back into compliance. This policy-driven model allows administrators to codify storage requirements and verify adherence continuously.

For Harbor Registry deployments on VKS clusters, administrators should note that configuring a StorageClass or PersistentVolume with a Delete reclaim policy results in all Harbor data being deleted when the Harbor package is removed. Image artifact retention requirements should drive reclaim policy selection for Harbor-backing storage. Platform teams should also manage data protection storage locations in VCF Automation to align with company-specific data residency and infrastructure standards.

These retention controls apply to the operational, monitoring, and configuration data that VCF Operations collects and manages, and to the persistent volume lifecycle for containerized workloads on VKS. They do not extend to application data stored within virtual machines outside the Kubernetes layer, user-generated content on datastores not managed by Kubernetes, or media outside the VCF platform. Organizations must establish broader data retention policies, classification schemes, and lifecycle management processes that address all media and data types subject to statutory, regulatory, and contractual obligations. VCF's retention settings are one component of a larger retention program that requires organizational governance, legal review of applicable obligations, and potentially additional tools for archival and disposition of data beyond what VCF Operations and VKS storage lifecycle controls manage.

VMware vDefend (Contributes)

VMware vDefend provides configurable data retention capabilities for the security telemetry and flow data it collects, contributing to an organization's ability to retain security-relevant data in accordance with statutory, regulatory, and contractual obligations.

Security Services Platform, which underpins Network Detection and Response (NDR) and related analytics services, offers control over flow data retention. Flow data is retained for 30 days by default via the flow-data-retention setting. If storage capacity is insufficient to handle flow volume from workloads, some flow metadata may be lost, flow ingestion may be paused, or data retention may be reduced dynamically to stay within available storage. Administrators can monitor retention health through the `ssp_flow_storage.avg_flow_storage_ratio` metric, which reports the ratio of current retention days to predicted full days for flow storage, and through the `ssp_analytics_storage.avg_predicted_tabl_retention_days` metric, which tracks predicted retention for the correlated flow visualization table (default 30 days). Security Services Platform persistent storage collects data even when the License Hub is offline, providing resilience against brief service interruptions that might otherwise affect data continuity.

Network Detection and Response retains detection events and campaign data for 12 months, providing a fixed retention window for threat detection artifacts.

For organizations using cloud-connected vDefend features, Security Services Platform maintains defined retention periods for data collected under active service subscriptions: IDS events and other network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year during an active subscription, and for 90 days following subscription expiration.

Administrators should note that when the Malware Prevention Service feature is deleted, all previously gathered data analytics are permanently removed. Organizations with compliance-driven retention requirements should account for this before decommissioning that service.

These retention controls allow organizations to align vDefend's security data storage with their compliance requirements. The broader scope of media and data retention across the full infrastructure stack, including operational data, log archives, backup snapshots, and storage-level data protection, is handled by other VCF components such as VCF Operations, VCF Log Management, and vSAN Data Protection.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable retention mechanisms that allow administrators to align disaster recovery and cyber recovery data with retention obligations. PNR snapshot schedules define a retention policy that determines how long each snapshot is retained, with hourly, daily, weekly, and monthly cadences and a maximum retention duration of three years. Administrators can also select predefined retention templates that combine recovery point objective (RPO) and snapshot retention parameters for quick configuration of protection groups.

For vSphere Replication, the retention policy determines the expiration of point-in-time copies, and storage consumption drops after all point-in-time copies referring to the original disk are expired. Administrators configure the number of retention slots and the spacing between recovery points, so older instances expire automatically once the configured limit is exceeded.

Cyber Recovery snapshot schedules in PNR follow the same retention model, defining a retention policy that controls how long each snapshot is retained. Administrators should account for storage capacity when configuring longer retention schedules, since extended retention periods increase storage consumption on the underlying datastores.

These retention controls allow organizations to align disaster recovery and cyber recovery data retention with applicable statutory, regulatory, and contractual obligations. PNR provides the technical mechanisms; determining the specific retention durations that satisfy each obligation is an organizational policy decision.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides configurable backup retention controls that support an organization's data retention requirements for its managed databases. These controls do not define retention obligations, which come from the organization's legal and compliance functions, but they provide the technical means to implement those obligations for PostgreSQL, MySQL, SQL Server, and MinIO data.

Retention periods are configured through Data Service Policies in the DSM administration interface. Each policy supports a backup-retention-period setting that defines the duration for which backups are kept. When multiple policies apply to a namespace, DSM aggregates the retention constraints by selecting the more restrictive minimum and maximum retention day values, producing a resultant retention window that reflects all applicable policies. Data service policies can also be tailored to specific requirements and enforced across different tenants, giving administrators a consistent mechanism for applying retention standards in multi-tenant deployments.

For deleted databases, DSM retains automated backups according to the configured retention period and exposes an Archives tab in the administration interface where administrators can access and adjust the retention period of retained backups. This allows organizations to maintain access to backup data even after a database instance has been removed, supporting retention obligations that outlast the operational lifetime of a specific database. When a database is deleted, automated backups continue to be retained until the retention policy is met.

DSM also supports point-in-time restore within the backup retention period, enabling recovery to any point within the retained window. On-demand backups behave differently from automated backups: they are permanent and do not expire automatically. On-demand backups remain in the backup storage location until an administrator manually deletes them, which means they can consume storage quota indefinitely and require separate tracking for retention compliance.

Data service policies also define backup storage locations (S3-compatible targets) alongside retention duration. If a data service policy that is in use is deleted, the data services associated with that policy become non-compliant, alerting administrators to a configuration gap.

Meeting this control fully requires the organization to determine the applicable retention periods, communicate those requirements to DSM administrators, and configure policies accordingly. DSM does not automatically derive retention obligations from regulatory or contractual sources. Its retention controls also cover only the database data it manages and do not address retention of all media and data types that may fall within an organization's broader retention obligations.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

